UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Fecha: 15 de octubre del 2026

INFORME DE SEGURIDAD OFENSIVA: INTERAFAS-LAB

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Alcance y Metodología 4
Objetivo y Alcance del Entorno 4
Metodología de Evaluación y Herramientas Utilizadas 4
Reglas del Ejercicio, Limitaciones y Nota Técnica sobre el Registro de Actividad 4
Resumen Ejecutivo 5
Inventario de Vulnerabilidades 6
Análisis Detallado de Vulnerabilidades 8
VULN-01: Exposición de paquete de despliegue y listado de directorios 8
VULN-02: Exposición de metadatos de compilación y endpoints de QA en Frontend 10
VULN-03: Referencia Directa a Objetos Insegura (IDOR) en consulta de expedientes 12
VULN-04: Exposición de código fuente mediante archivo de respaldo residual (.bak) 15
VULN-05: Manejo inadecuado de excepciones y modo Debug habilitado en producción 17
VULN-06: Escalamiento vertical de privilegios mediante cookie de rol manipulada 20
VULN-07: Inyección SQL Ciega basada en Booleanos (Boolean-based Blind SQLi) 23
VULN-08: Cross-Site Scripting Almacenado (Stored XSS) en reportes ciudadanos 27
VULN-09: Salto de directorio (Path Traversal) en descarga de constancias 29
VULN-10: Fijación y reutilización de sesión (Session Fixation / Session Replay) 33
VULN-11: Exposición de endpoint de API no documentado (Shadow API) 36
VULN-12: Autorización rota a nivel de objeto (BOLA / IDOR) en API de historial de servicio 39
VULN-13: Manipulación de importe por fallo de lógica de negocio en pasarela de pagos 41
VULN-14: Deficiencia de validación relacional entre contratos y proveedores 43
VULN-15: Divulgación de arquitectura y topología de red OT en endpoint público 45
VULN-16: Evasión del Gateway Operacional mediante suplantación de cabecera X-Forwarded-For 48
VULN-17: Falta de autenticación en endpoint crítico de telemetría de planta 51
VULN-18: Uso de hash débil (SHA-1) e instalación de firmware sin verificación de firma criptográfica 54

VULN-19: Exposición y abuso de alcance en la cadena de dependencias de activos OT 59

VULN-20: Manipulación de puntos de ajuste (Setpoints) de presión en RTU y colapso operacional 62

Cadena de Ataque: Del Perímetro Web al Entorno Operacional OT 66

Conclusiones 67

Referencias 68

Alcance y Metodología

Objetivo y Alcance del Entorno

El presente informe documenta los resultados de la auditoría técnica realizada sobre **INTERAFAS-LAB**, un entorno académico controlado que simula al *Organismo Intermunicipal Metropolitano de Agua Potable, Alcantarillado, Saneamiento y Servicios Conexos* que abastece a los municipios de Cerro de San Pablo, Saint Louis y Soledade. El alcance abarcó los portales web públicos e institucionales, el portal ciudadano, las APIs de consulta, el gestor de bases de datos subyacente y los módulos de interconexión hacia la red de Tecnología Operacional (OT) de la Planta Metropolitana Norte y sus estaciones remotas.

Metodología de Evaluación y Herramientas Utilizadas

La evaluación se ejecutó bajo un enfoque práctico de caja gris, siguiendo las fases de reconocimiento, enumeración, análisis de vulnerabilidades, comprobación (explotación controlada) y análisis de propagación hacia el entorno operacional. El laboratorio se operó desde una máquina virtual con **Parrot OS 7.3 KDE Security Edition** conectada mediante un túnel SSH local hacia los puertos 8080 (portal web/OT) y 8092 (consola del auditor).

Reglas del Ejercicio, Limitaciones y Nota Técnica sobre el Registro de Actividad

Durante las pruebas se respetó la disponibilidad del contenedor, limitando las acciones a la obtención de las 20 banderas de validación.

Nota importante sobre las herramientas y la bitácora del laboratorio: En la primera etapa de la auditoría (Banderas 01 a 05 y pruebas iniciales de la 10 a la 14), se utilizó intensivamente la herramienta de línea de comandos curl junto con grep y gobuster por comodidad y rapidez en la terminal. Sin embargo, a mitad del ejercicio se detectó una limitación importante: las peticiones lanzadas desde curl de forma aislada no enviaban por defecto la cookie de rastreo del laboratorio (INTERAFAS_LAB_TOKEN), provocando que el contador de actividad en el panel del auditor no sumara todos los intentos manuales realizados en consola. Para corregir esto y asegurar que la bitácora reflejara fielmente el trabajo realizado (cerrando con

862 eventos registrados, 533 eventos web/OT y 20/20 banderas), se migró el flujo de trabajo hacia el navegador integrado con el proxy **Burp Suite Community Edition** (*HTTP History* y *Repeater*), garantizando que cada petición conservara las cabeceras y cookies de sesión del laboratorio.

Resumen Ejecutivo

La evaluación de seguridad realizada sobre la infraestructura digital de **INTERAFAS** reveló un total de **20 vulnerabilidades** que, al encadenarse, permitieron pasar desde un acceso público sin privilegios en el portal web hasta el control total y desbloqueo de dispositivos críticos en la red industrial (OT).

En una primera fase, diversos descuidos en los procesos de despliegue y desarrollo dejaron expuestos archivos de configuración (.env), manifiestos de compilación y respaldos de código fuente (.bak) dentro del directorio público del servidor web. Estos hallazgos iniciales se vieron agravados por fallas de control de acceso y autorización (IDOR/BOLA) tanto en el portal ciudadano como en las APIs internas, permitiendo consultar expedientes personales (incluyendo CURP y domicilios) e historiales de facturación de otros ciudadanos, así como escalar privilegios hacia el módulo administrativo de contrataciones mediante la simple edición de una cookie controlada por el cliente.

Posteriormente, se identificaron vulnerabilidades críticas de inyección (Blind SQL Injection y Stored XSS), salto de directorios (*Path Traversal*) y errores severos en la lógica de negocio que permitían liquidar recibos de agua por un monto de $1.00 o validar vínculos contractuales falsos entre proveedores. Finalmente, la deficiencia más grave radicó en la falta de aislamiento entre la red de Tecnologías de la Información (IT) y la red de Tecnología Operacional (OT): un endpoint público filtró el segmento de red interno (10.40.20.0/24) y el gateway operacional confió en la cabecera X-Forwarded-For para autorizar el paso hacia el Centro de Operaciones. Una vez dentro del segmento industrial, la ausencia de firmas criptográficas en las actualizaciones de firmware y el uso de contraseñas débiles (SHA-1) permitieron modificar los parámetros de presión de la unidad terminal remota (RTU-GW-07), provocando un estado catastrófico simulado en la red metropolitana de agua.

Inventario de Vulnerabilidades

ID	Componente Afectado	Categoría (OWASP / CWE)	Bandera / Resultado Obtenido
VULN-01	/robots.txt y /assets/docs/public/revision/	Configuración Incorrecta / Listado de Directorios	UPSLP_CNOIV-OPEN-DOOR-01
VULN-02	/assets/runtime-config.js y /assets/meta/build-manifest.php	Exposición de Metadatos de Desarrollo	UPSLP_CNOIV-LOOK-CLOSER-02
VULN-03	/expediente.php?id=2	Control de Acceso Roto / IDOR	UPSLP_CNOIV-NOT-YOURS-03
VULN-04	/transparencia.php.bak	Archivos Residuales / Exposición de Código Fuente	UPSLP_CNOIV-OLD-MEMORIES-04
VULN-05	/exportar.php?tipo=xyz123	Manejo Inadecuado de Errores / Modo Debug Activo	UPSLP_CNOIV-TOO-MUCH-INFO-05
VULN-06	/gestion-proveedores.php	Escalamiento Vertical de Privilegios	UPSLP_CNOIV-WRONG-ROLE-06
VULN-07	/validar-referencia.php?ref=	Inyección SQL Ciega basada en Booleanos	UPSLP_CNOIV-SILENT-ANSWER-07
VULN-08	/reportes.php y /seguimiento-reporte.php?id=6	Cross-Site Scripting Almacenado - Stored XSS	UPSLP_CNOIV-STORED-WORDS-08
VULN-09	/descargar-documento.php?file=Path Traversal /	Lectura Arbitraria de Archivos	UPSLP_CNOIV-TOO-DEEP-09
VULN-10	/login.php y /perfil.php (PHPSESSID)	Fijación y Reutilización de Sesión	UPSLP_CNOIV-WHO-ARE-YOU-10
VULN-11	/api/account-context.php y /api/service-history.php	Gestión Inadecuada Inventario	UPSLP_CNOIV-HIDDEN-HISTORY-11
VULN-12	/api/service-history.php?account=40010002	Autorización Rota a Nivel de Objeto - BOLA	UPSLP_CNOIV-SECOND-ACCOUNT-12

VULN-13	/pago.php(Parámetro POST monto)	Fallo de Lógica de Negocio en Pasarela de Pago	UPSLP_CNOIV-PAYMENT-PATH-13
VULN-14	/validar-vinculo-contractual.php	Fallo de Validación Relacional de Entidades	UPSLP_CNOIV-TRUSTED-SUPPLIER-14
VULN-15	/api/infrastructure-status.php	Fuga de Topología y Segmentos de Red OT	UPSLP_CNOIV-BEHIND-THE-DESK-15
VULN-16	/operations/gateway.php	(X-Forwarded-For) Evasión de Frontera de Red por Suplantación de IP	UPSLP_CNOIV-BEYOND-THE-WEB-16
VULN-17	/operations/telemetry.php	Falta de Autenticación en Telemetría Crítica	UPSLP_CNOIV-EYES-ON-THE-PLANT-17
VULN-18	/operations/updates/install.php y Hash SHA-1	Fallo de Integridad de Firmware y Hash Débil	UPSLP_CNOIV-TRUST-THE-PACKAGE-18
VULN-19	/operations/asset-context.php?asset=ZONE-SL-A	Exceso de Alcance en Cadena de Dependencias OT	UPSLP_CNOIV-CHAIN-REACTION-19
VULN-20	/operations/firmware.php y /system.php	Manipulación de Setpoint en RTU y Colapso OT	UPSLP_CNOIV-NOW-YOU-CONTROL-20

Análisis Detallado de Vulnerabilidades

VULN-01: Exposición de paquete de despliegue y listado de directorios

Descripción técnica y causa raíz: El servidor Apache/2.4.68 mantiene habilitada la opción de listado de directorios (*Directory Listing* / Options +Indexes) en rutas internas de activos. Además, el equipo de operaciones intentó ocultar la ruta /assets/docs/public/revision/ colocándola en el archivo /robots.txt en lugar de restringir sus permisos de acceso o eliminar los archivos tras el despliegue. Aunque el archivo release-check.env tenía la bandera CLEANUP_RELEASE_FILES=yes, el script de limpieza no se ejecutó.

Comprobación de los hallazgos

1. Se ejecutó un escaneo inicial de directorios con gobuster dir -u http://localhost:8080 -w /usr/share/wordlists/dirb/common.txt, detectando /robots.txt con código 200 OK.
2. Al consultar robots.txt, se identificó la directiva Disallow: /assets/docs/public/revision/.
3. Se accedió desde el navegador a http://localhost:8080/assets/docs/public/revision/, visualizando el índice de archivos y descargando portal-release_20260407_rc3.zip.
4. En la terminal se descomprimió el archivo (unzip portal-release_20260407_rc3.zip) y se inspeccionó release/deploy/release-check.env, obteniendo la bandera en la variable SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01.

Evidencia:

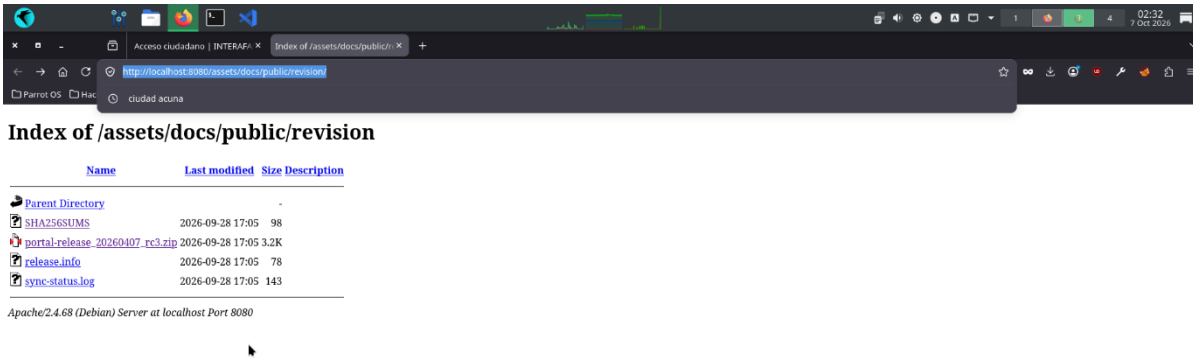


Figura 1.1: Listado de directorio expuesto en /assets/docs/public/revision/ mostrando el archivo comprimido de despliegue portal-release_20260407_rc3.zip

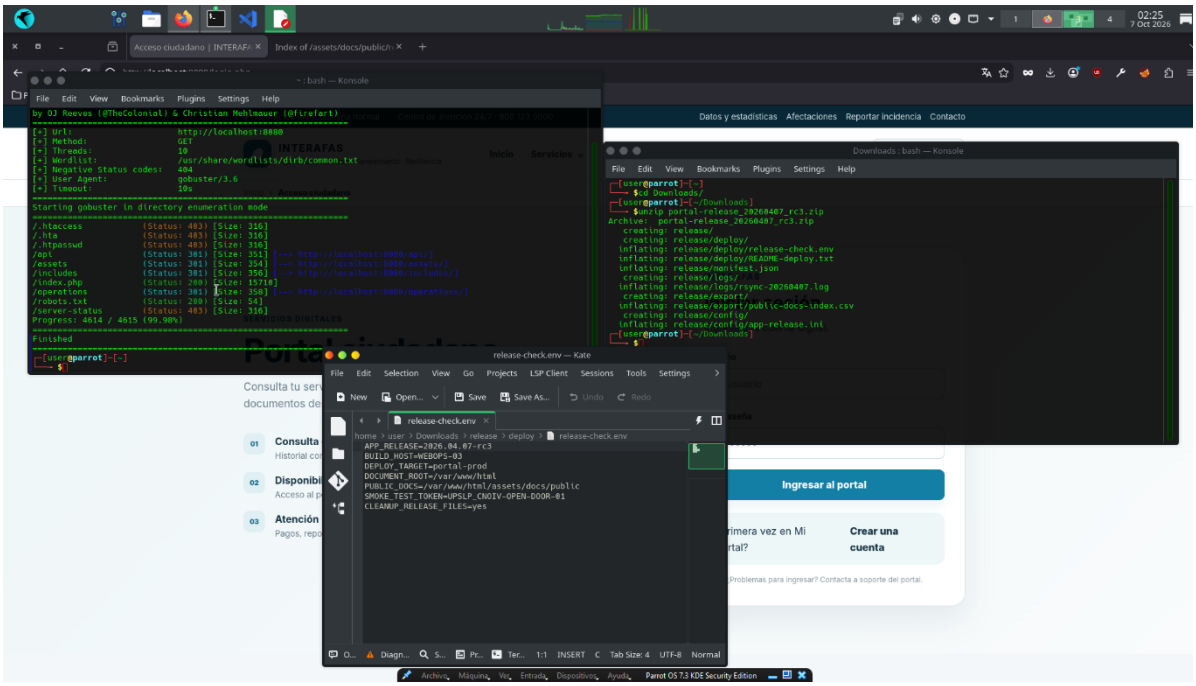


Figura 1.2: Escaneo inicial con Gobuster, extracción del paquete .zip en consola y lectura del archivo release-check.env con la bandera UPSLP_CNOIV-OPEN-DOOR-01

Impacto y riesgo: Afecta directamente la **confidencialidad**. Expone nombres de servidores internos (BUILD_HOST=WEBOPS-03), rutas absolutas del servidor (DOCUMENT_ROOT=/var/www/html), bitácoras de sincronización (rsync) y notas de despliegue que facilitan el reconocimiento para ataques posteriores.

Mitigaciones: Deshabilitar el listado de directorios en la configuración de Apache (Options -Indexes en el bloque <Directory /var/www/html>), retirar rutas sensibles de robots.txt y automatizar en el pipeline de CI/CD la eliminación de archivos .zip, .env y .log antes de pasar a producción.

VULN-02: Exposición de metadatos de compilación y endpoints de QA en Frontend

Descripción técnica y causa raíz: La aplicación carga en el cliente un script de configuración (runtime-config.js) que congela un objeto global window.INTERAFAS_RUNTIME. En dicho objeto se dejó expuesta la propiedad buildManifest: '/assets/meta/build-manifest.php', la cual apunta a un recurso de aseguramiento de calidad (QA) que no requiere autenticación y devuelve tokens internos de validación en formato JSON.

Comprobación de los hallazgos:

1. Estando en http://localhost:8080/login.php, se abrieron las herramientas de desarrollo del navegador (*Debugger / Sources*) y se inspeccionó el archivo /assets/runtime-config.js?v=1790615155.
2. Se localizó la ruta /assets/meta/build-manifest.php en la línea 11 del script.
3. Al abrir http://localhost:8080/assets/meta/build-manifest.php en el navegador, el servidor respondió con un objeto JSON que contenía el nodo quality_assurance y la clave release_validation_token: "UPSLP_CNOIV-LOOK-CLOSER-02".

Evidencia:

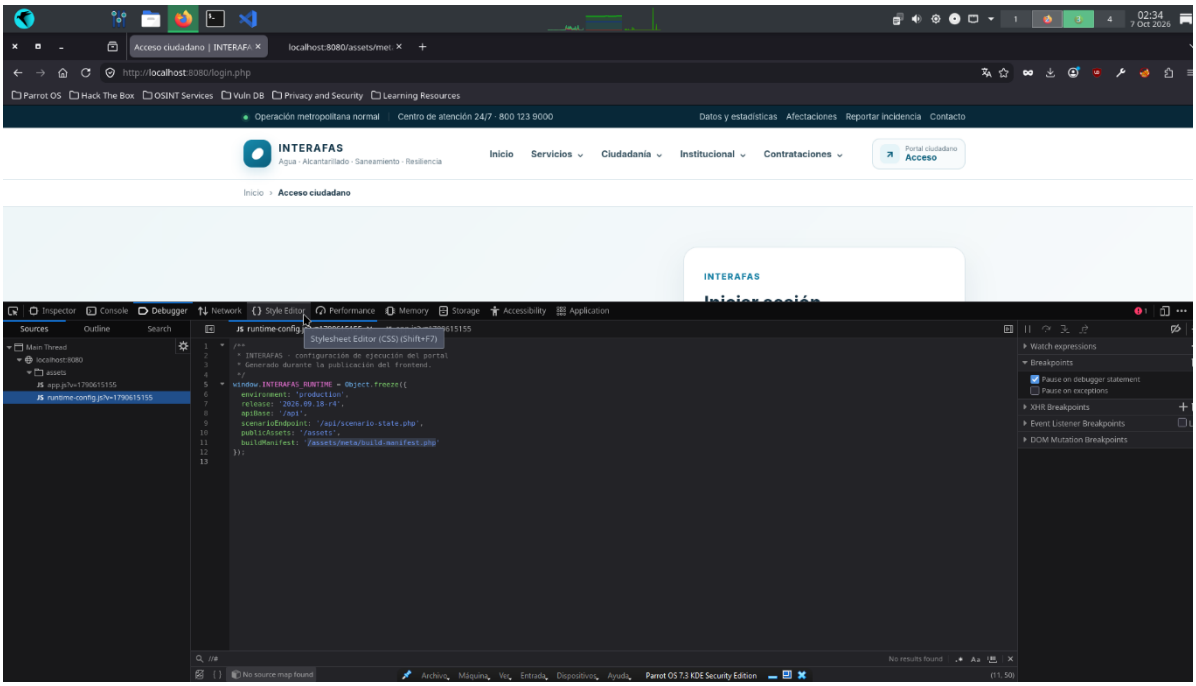


Figura 2.1: Inspección del archivo runtime-config.js en las herramientas de desarrollo mostrando la ruta hacia build-manifest.php

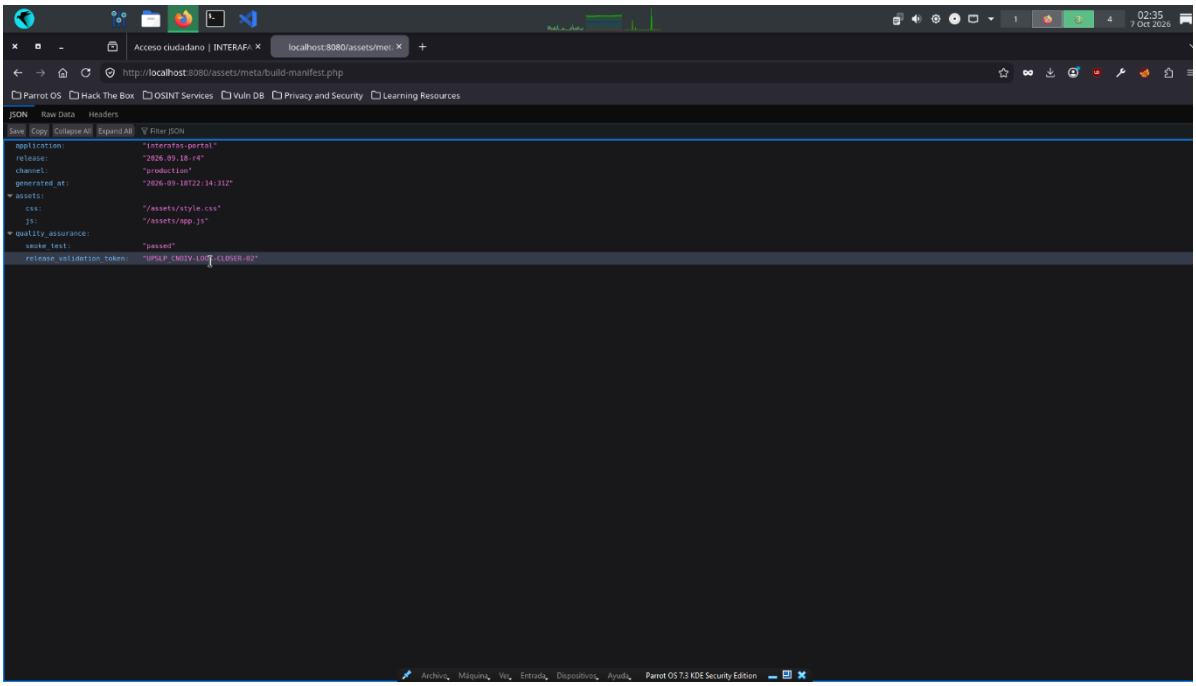


Figura 2.2: Respuesta JSON de /assets/meta/build-manifest.php revelando la versión del release y el token UPSLP_CNOIV-LOOK-CLOSER-02

Impacto y riesgo: Compromete la **confidencialidad** operativa al revelar versiones exactas de compilación (2026.09.18-r4), rutas de API internas (/api/scenario-state.php) y tokens de pruebas de humo (*smoke tests*) en un canal de producción.

Mitigaciones: Segregar las variables de entorno entre desarrollo/QA y producción para que runtime-config.js únicamente incluya rutas públicas necesarias, y restringir el acceso al directorio /assets/meta/ mediante reglas de control de acceso en el servidor web.

VULN-03: Referencia Directa a Objetos Insegura (IDOR) en consulta de expedientes

Descripción técnica y causa raíz: El módulo de consulta de expedientes ciudadanos (expediente.php) recibe como parámetro GET el identificador numérico del registro (?id=). La causa raíz radica en un control de acceso roto a nivel de objeto: el backend verifica únicamente que exista una sesión iniciada en el portal, pero no comprueba en la consulta SQL que el id solicitado pertenezca al usuario autenticado (ciudadano01).

Comprobación de los hallazgos:

1. Se inició sesión en http://localhost:8080/login.php con la cuenta ciudadano01 (Mariana Torres, asociada originalmente a id=1).
2. En la barra de direcciones se modificó manualmente el parámetro a http://localhost:8080/expediente.php?id=2.
3. La aplicación cargó sin restricciones los datos personales de un tercero (**Carlos Rivera**, usuario ciudadano02, CURP RIRC791103HSPVVR02) y en la sección "03 Expediente administrativo" (folio EXP-2026-00422) mostró la bandera UPSLP_CNOIV-NOT-YOURS-03.

Evidencia:

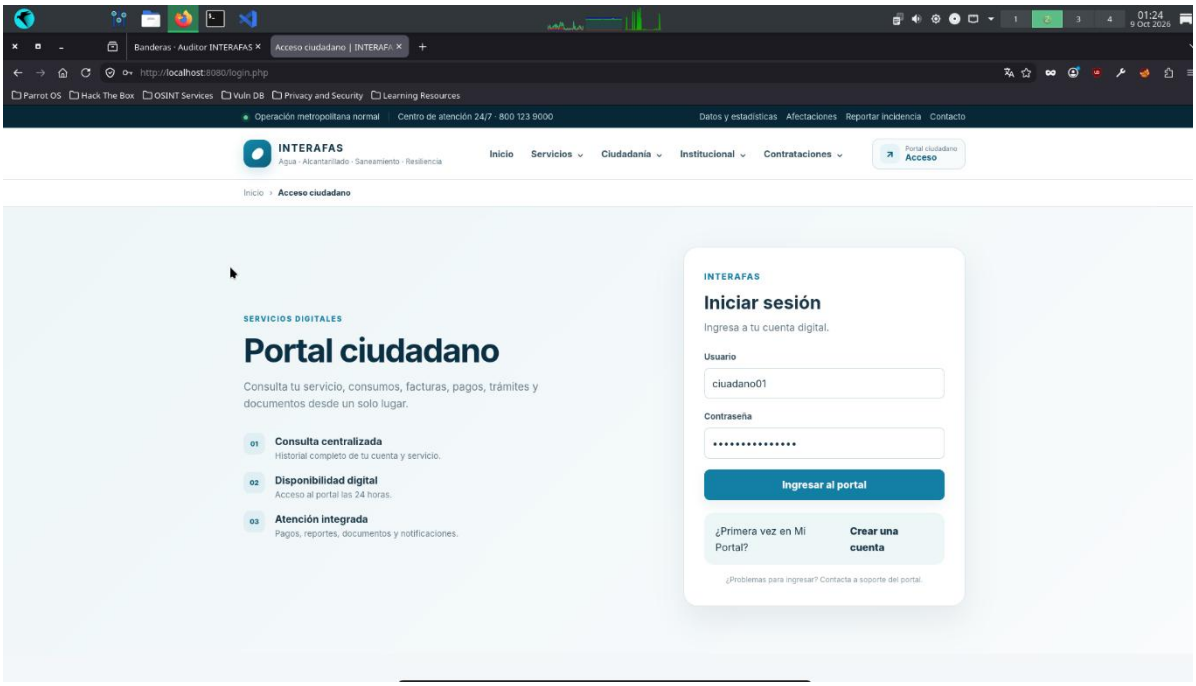


Figura 3.1: Inicio de sesión en el Portal Ciudadano con el usuario ciudadano01

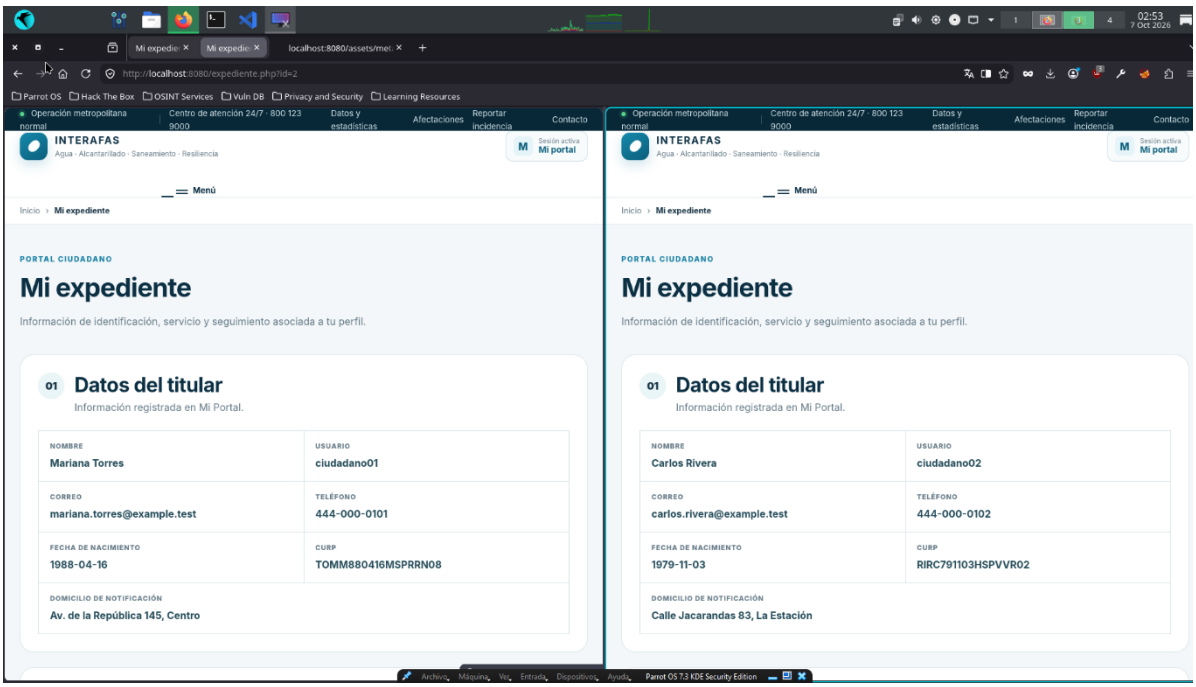


Figura 3.2: Comparativa lado a lado mostrando los datos del titular legítimo (ciudadano01 - Mariana Torres) frente a la exposición de datos personales de otro titular (ciudadano02 - Carlos Rivera) al cambiar el parámetro id=2

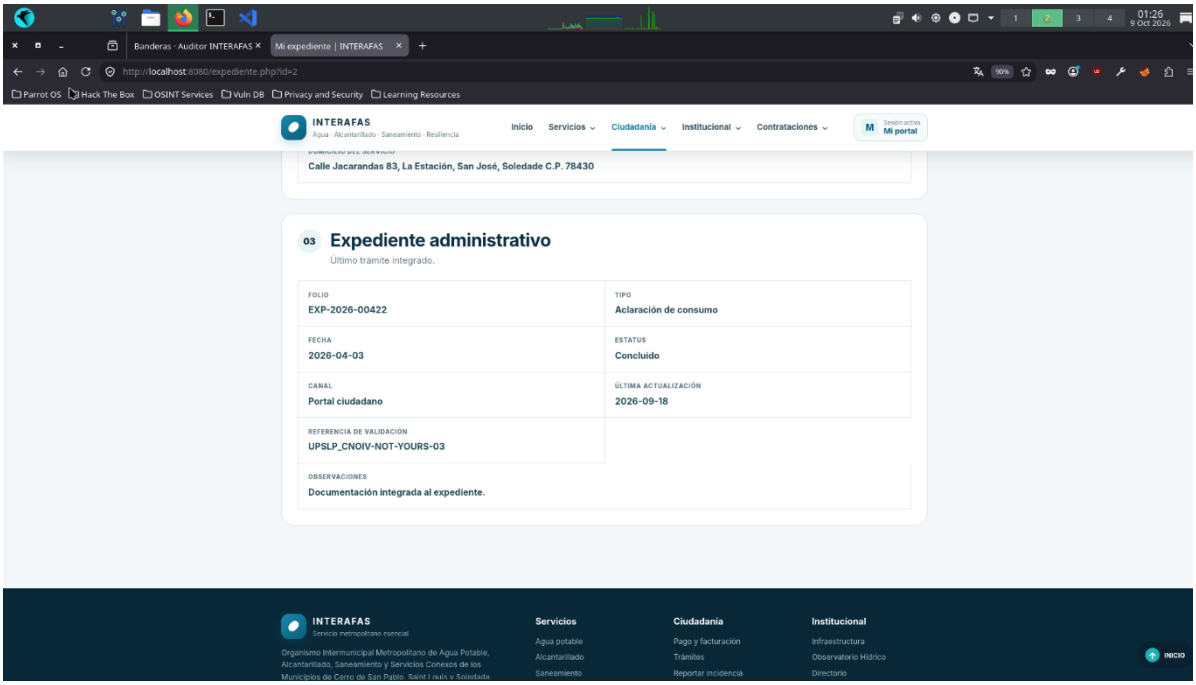


Figura 3.3: Detalle del expediente administrativo ajeno (EXP-2026-00422) exponiendo la bandera UPSLP_CNOIV-NOT-YOURS-03

Impacto y riesgo: Alto impacto en la **confidencialidad** y cumplimiento legal (protección de datos personales). Cualquier usuario registrado puede iterar secuencialmente el parámetro id para extraer nombres completos, correos, teléfonos, fechas de nacimiento, CURP y domicilios de todo el padrón de ciudadanos.

Mitigaciones: Implementar validación de pertenencia en el servidor vinculando la consulta al ID de usuario almacenado en $_SESSION['user_id'] (ej. SELECT * FROM expedientes WHERE id = ? AND usuario_id = ?), o bien obtener el expediente directamente a partir de la sesión activa sin recibir el id por URL.

VULN-04: Exposición de código fuente mediante archivo de respaldo residual (.bak)

Descripción técnica y causa raíz: Durante una actualización previa del portal, los desarrolladores conservaron una copia de seguridad del módulo de transparencia (transparencia.php.bak) dentro del directorio raíz público (/var/www/html). Debido a que Apache únicamente pasa al intérprete de PHP los archivos con extensión .php, al solicitar un archivo terminado en .bak el servidor lo entrega como un archivo ordinario (Content-Type: application/x-trash), exponiendo todo el código fuente PHP y comentarios internos en texto plano.

Comprobación de los hallazgos:

1. Inicialmente se intentó buscar respaldos sobre prensa.php siguiendo una nota del archivo README-deploy.txt, pero al resultar una pista distractiva que devolvía 404 Not Found, se optó por un método sistemático.
2. Se extrajeron todas las rutas .php enlazadas en el portal mediante curl -s http://localhost:8080/ | grep -oP 'href="/[a-z0-9_-]+\.php"' | sort -u.
3. Al probar extensiones de respaldo comunes (.bak, .old, ~, .orig, .save, .swp) sobre las páginas identificadas, curl -I http://localhost:8080/transparencia.php.bak devolvió HTTP/1.1 200 OK.
4. Se descargó el contenido con curl http://localhost:8080/transparencia.php.bak, visualizando el código fuente PHP y la variable $releaseValidation = UPSLP_CNOIV-OLD-MEMORIES-04.

Evidencia:

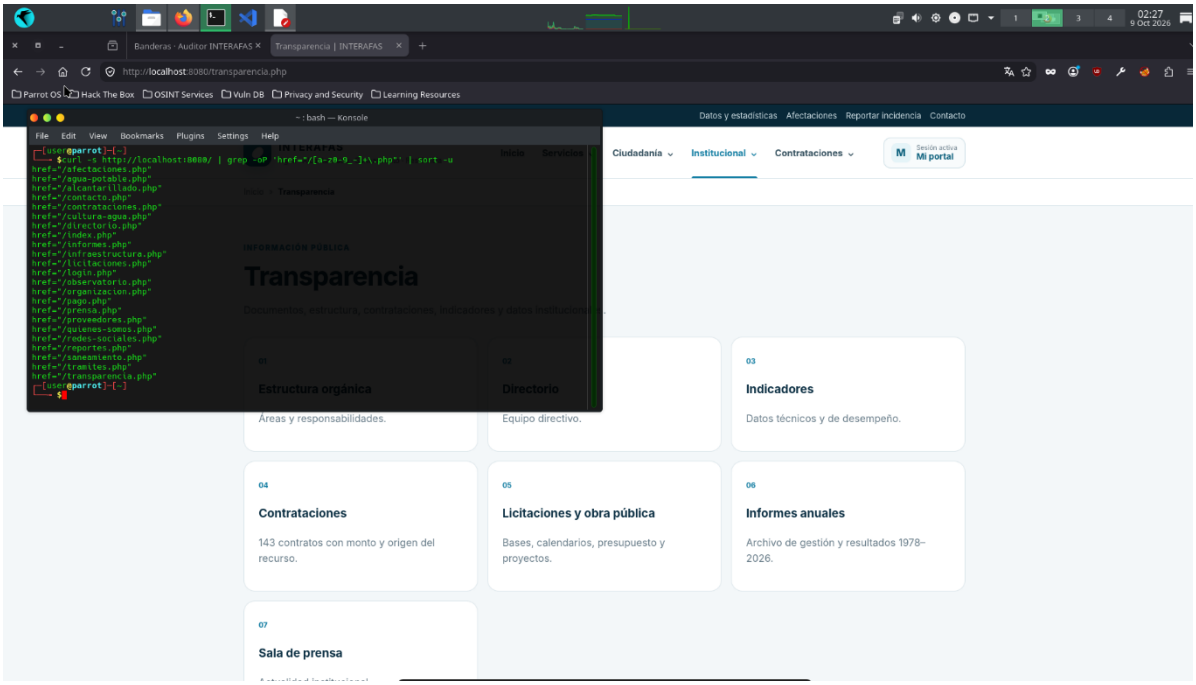


Figura 4.1: Extracción automatizada de todas las rutas .php activas en el portal principal utilizando curl y expresiones regulares con grep.

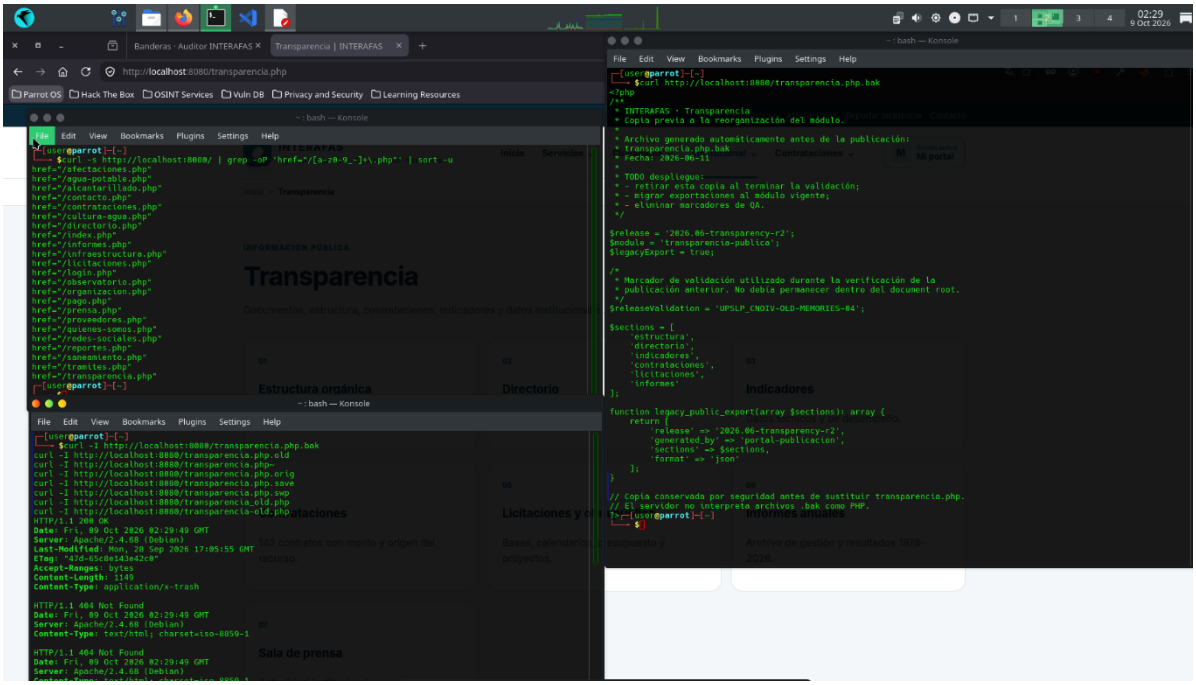


Figura 4.2: Comprobación de cabeceras HTTP (200 OK, application/x-trash) y volcado del código fuente de transparencia.php.bak con la bandera UPSLP_CNOIV-OLD-MEMORIES-04.

Impacto y riesgo: Afecta la **confidencialidad** de la arquitectura de la aplicación. Permite a un atacante conocer la lógica interna de funciones como legacy_public_export(), nombres de módulos y variables sin necesidad de acceso al servidor.

Mitigaciones: Eliminar cualquier archivo .bak, .old, .swp o ~ del document root y agregar en la configuración de Apache una regla <FilesMatch "\.(bak|old|orig|save|swp|inc|~)$"> con Require all denied para bloquear su descarga en caso de descuidos humanos.

VULN-05: Manejo inadecuado de excepciones y modo Debug habilitado en producción

Descripción técnica y causa raíz: El script /exportar.php utiliza una expresión match() de PHP 8.3 para evaluar el parámetro GET tipo y generar descargas en CSV. Sin embargo, el bloque match carece de un brazo por defecto (default) para capturar valores no reconocidos, disparando una excepción fatal UnhandledMatchError. Aunado a esto, el servidor tiene activado el modo de diagnóstico detallado en producción (DEBUG RESPONSE ENABLED), mostrando en pantalla información sensible de la infraestructura.

Comprobación de los hallazgos:

1. Se buscaron enlaces de exportación en las secciones del portal mediante curl y grep. En observatorio.php los archivos eran estáticos, pero al analizar contrataciones.php (curl -s http://localhost:8080/contrataciones.php | grep -i -o '.{50}exportar.{50}') se descubrió el enlace dinámico /exportar.php?tipo=contratos.
2. Se envió un valor inválido en el parámetro visitando http://localhost:8080/exportar.php?tipo=xyz123.
3. El servidor respondió con HTTP/1.1 500 Internal Server Error, renderizando una página de diagnóstico con la ruta /var/www/html/exportar.php (línea 23), el servicio de base de datos (db:3306 / schema interafas) y la bandera UPSLP_CNOIV-TOO-MUCH-INFO-05.

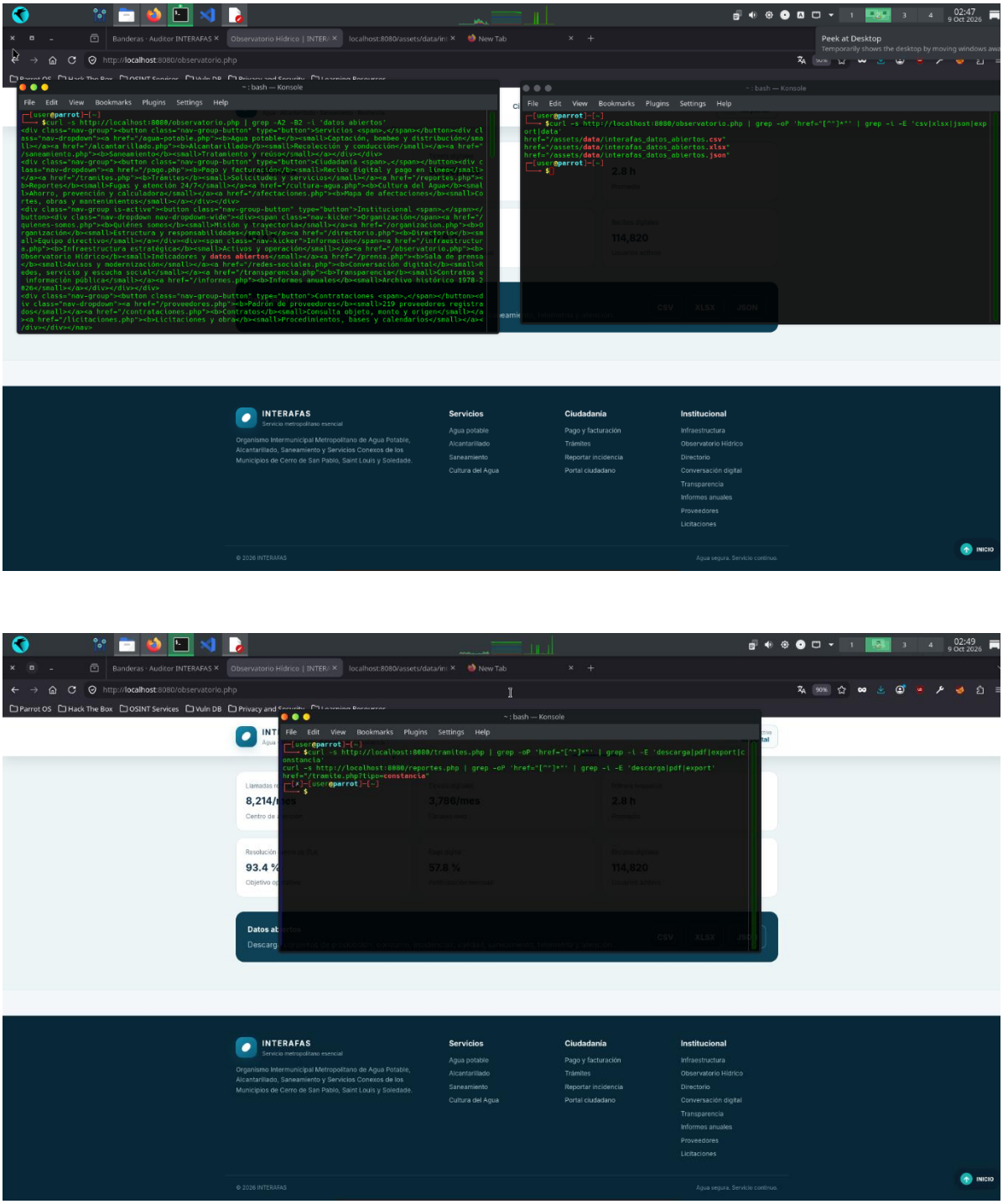


Figura 5.1: Búsqueda inicial de enlaces de descarga y exportación en observatorio.php, tramites.php y reportes.php

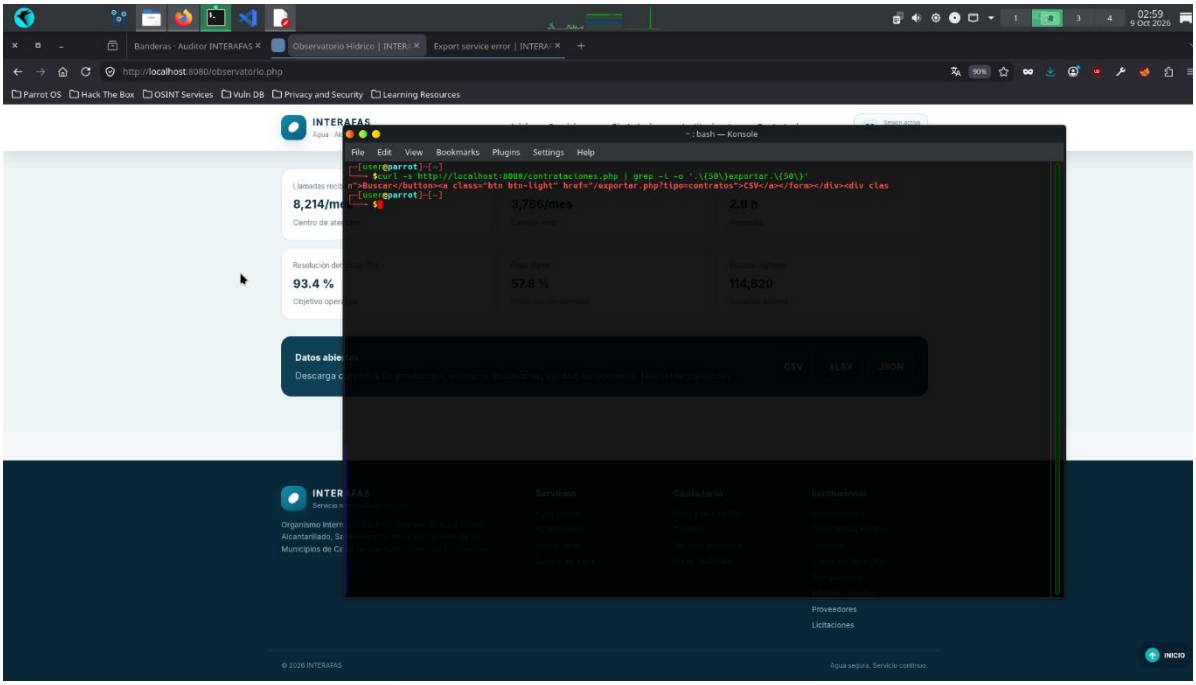


Figura 5.2: Localización del endpoint dinámico /exportar.php?tipo=contratos dentro del código HTML de contrataciones.php.

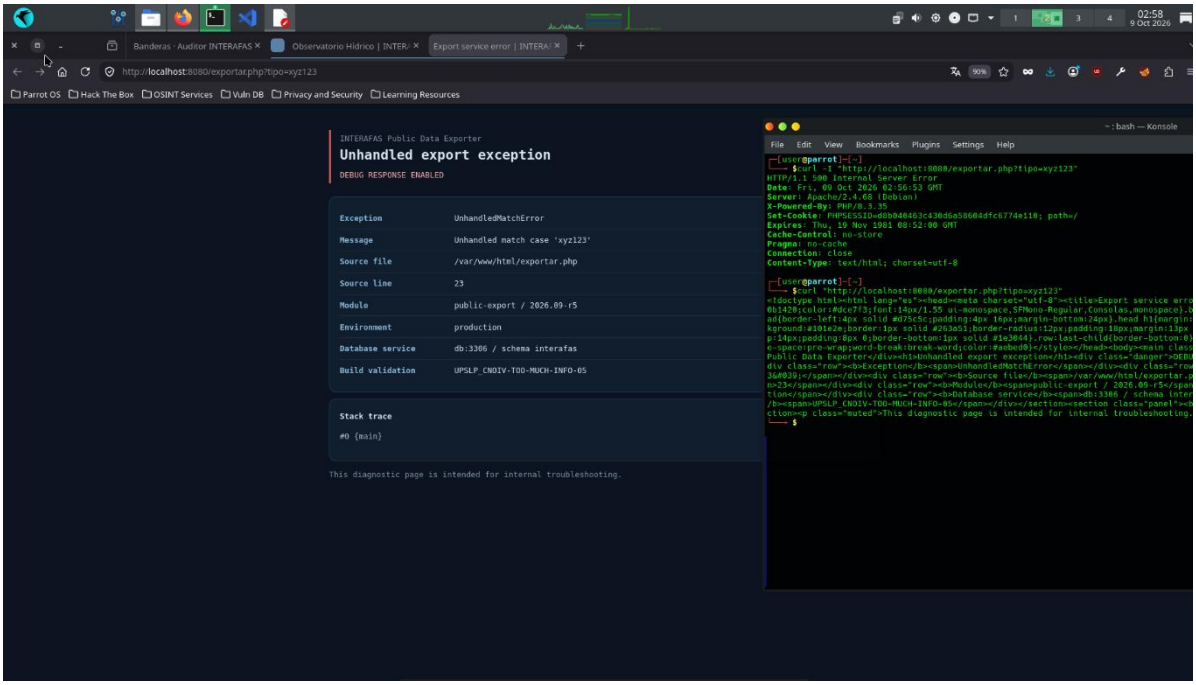


Figura 5.3: Excepción UnhandledMatchError provocada con ?tipo=xyz123, exponiendo detalles internos de la base de datos y la bandera UPSLP_CNOIV-TOO-MUCH-INFO-05

Impacto y riesgo: Compromete la **confidencialidad** técnica. Revela la versión exacta de PHP (8.3.35), rutas físicas del sistema de archivos, el nombre del host y puerto de la base de datos (db:3306) y el nombre exacto del esquema (interafas), información crítica que facilitó posteriormente la explotación de SQL Injection.

Mitigaciones: Agregar un caso default en la expresión match() de exportar.php que devuelva un error controlado 400 Bad Request, y desactivar la visualización de errores en producción configurando display_errors = Off en php.ini.

VULN-06: Escalamiento vertical de privilegios mediante cookie de rol manipulada

Descripción técnica y causa raíz: Al iniciar sesión como ciudadano, la aplicación asigna una cookie en texto plano llamada portal_role=citizen sin firma criptográfica ni validación de integridad. El módulo administrativo /gestion-proveedores.php verifica los permisos de acceso leyendo directamente el valor de esta cookie enviada por el cliente en lugar de consultar el rol real del usuario dentro de la sesión del lado del servidor ($_SESSION). Además, cuando deniega el acceso con un error 403 Forbidden, el servidor filtra en las cabeceras HTTP el rol exacto que necesita: X-Required-Role: procurement_admin.

Comprobación de los hallazgos:

1. Con Burp Suite activo como proxy, se intentó acceder a http://localhost:8080/gestion-proveedores.php.
2. Al revisar el historial HTTP en Burp Suite, se observó la respuesta 403 Forbidden junto con la cabecera X-Required-Role: procurement_admin.
3. Se envió la petición a **Burp Repeater** y también se editó desde el navegador (DevTools -> Application -> Cookies) cambiando el valor de portal_role de citizen a procurement_admin.
4. Al recargar la página y presionar el botón de gestión ("Marcar en revisión" / "Restaurar vigente") sobre uno de los proveedores del padrón, el sistema ejecutó la acción administrativa y mostró el cuadro de confirmación con la bandera UPSLP_CNOIV-WRONG-ROLE-06.

Evidencia técnica

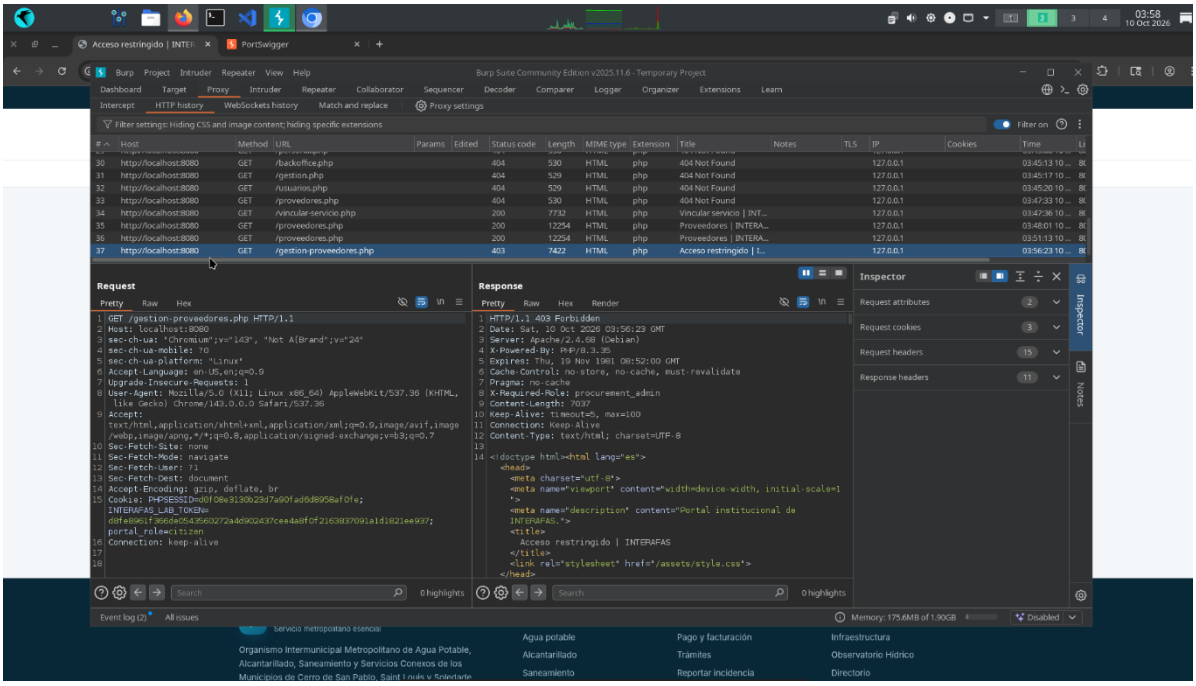
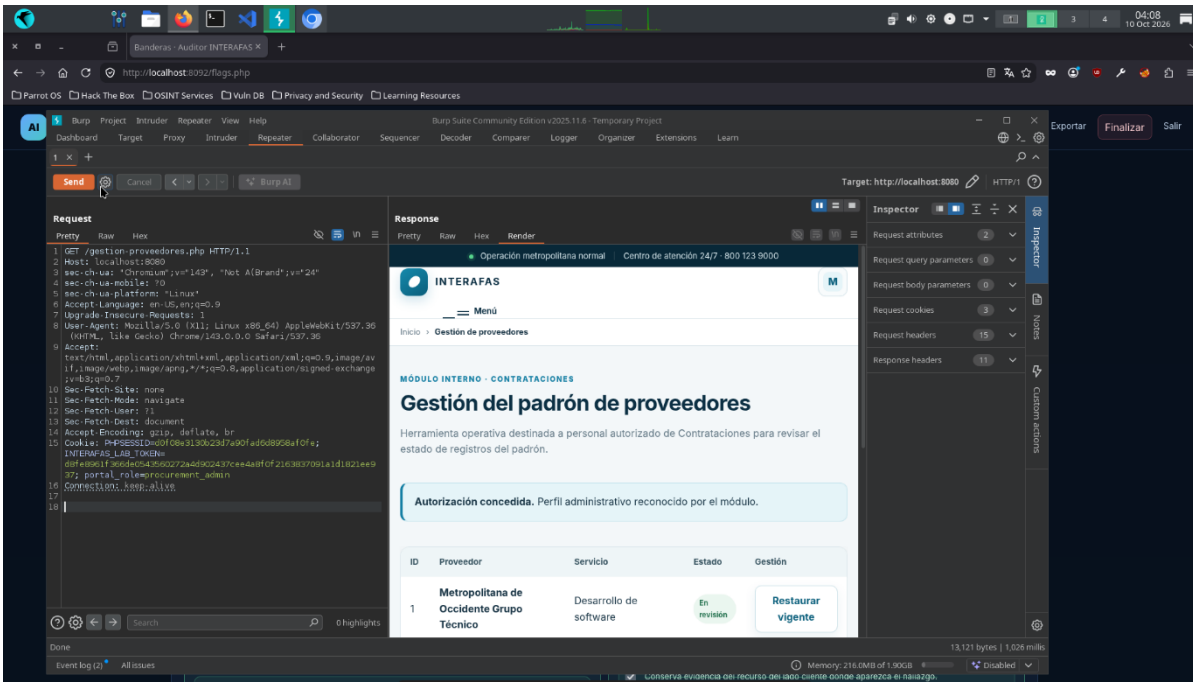


Figura 6.1: Petición interceptada en Burp Suite hacia /gestion-proveedores.php mostrando la cookie portal_role=citizen y la cabecera de respuesta X-Required-Role: procurement_admin.



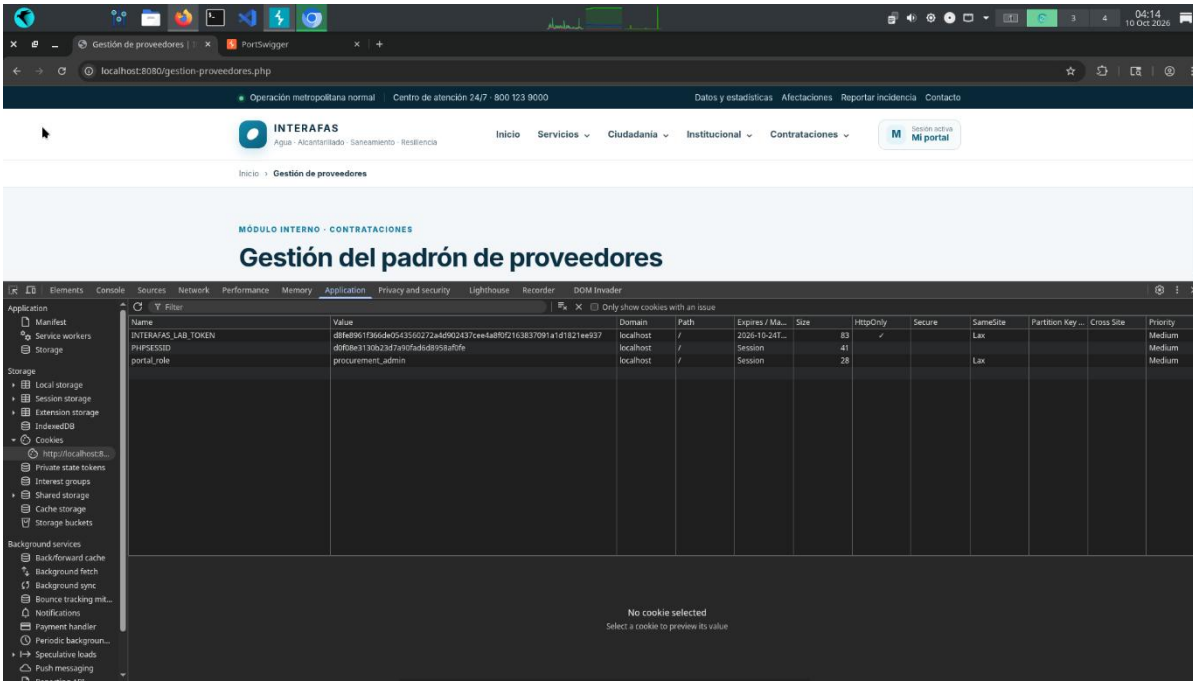


Figura 6.2: Modificación de la cookie a portal_role=procurement_admin en Burp Repeater y en el navegador, logrando desbloquear el panel de "Gestión del padrón de proveedores".

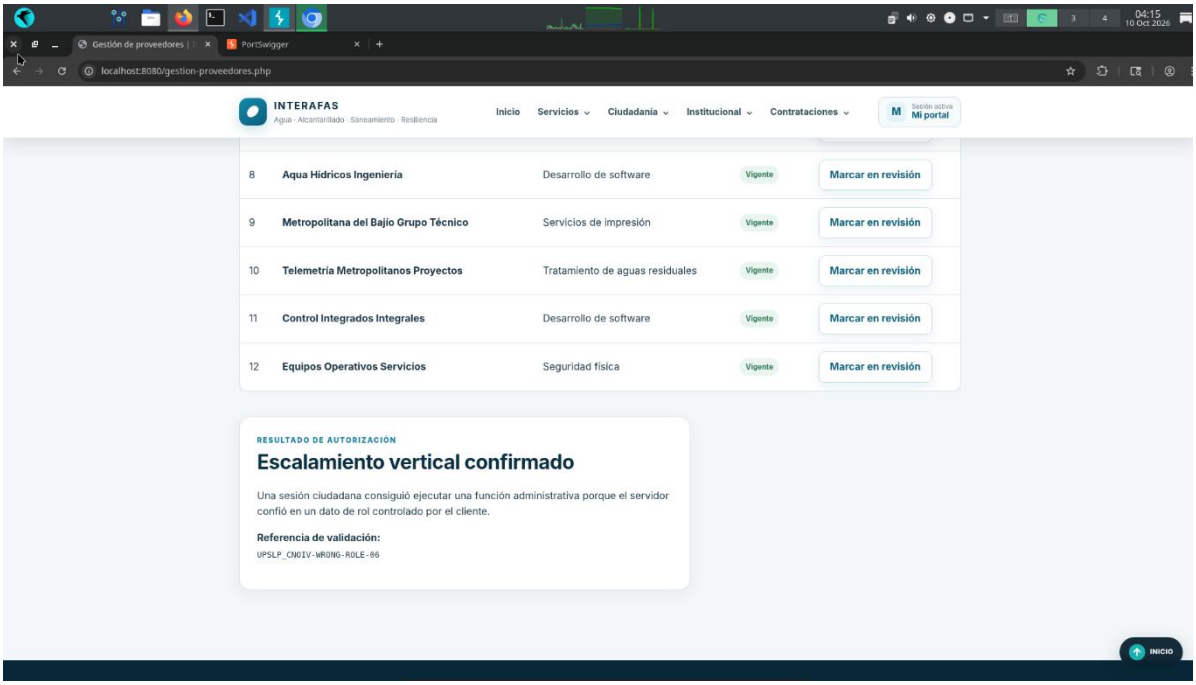


Figura 6.3: Ejecución de función administrativa confirmando el escalamiento vertical y mostrando la bandera UPSLP_CNOIV-WRONG-ROLE-06.

Impacto y riesgo: Impacto crítico en la **integridad** y **confidencialidad**. Un usuario externo puede alterar el estado de proveedores de servicios esenciales (como empresas de desarrollo de software, telemetría y tratamiento de aguas residuales) dentro del padrón oficial de contrataciones.

Mitigaciones: Eliminar por completo la cookie portal_role, almacenar el atributo de rol exclusivamente del lado del servidor dentro de $_SESSION['role'] tras la autenticación, y suprimir la cabecera informativa X-Required-Role.

VULN-07: Inyección SQL Ciega basada en Booleanos (Boolean-based Blind SQLi)

Descripción técnica y causa raíz: El módulo público de validación de procedimientos de contratación (/validar-referencia.php?ref=) concatena directamente el valor del parámetro ref dentro de la sentencia SQL ejecutada en MySQL/MariaDB sin utilizar consultas preparadas (*Prepared Statements*). Aunque no imprime errores de base de datos ni devuelve filas directamente en pantalla, la página muestra el mensaje "Referencia localizada" cuando la condición SQL se evalúa como verdadera y lo oculta cuando es falsa, permitiendo extraer información carácter por carácter mediante inferencia booleana.

Comprobación de los hallazgos:

1. En el formulario de http://localhost:8080/validar-referencia.php se ingresó la cadena de prueba ' OR '1'='1, observando que el sistema respondía "Referencia localizada", confirmando la inyección booleana.
2. Se utilizó sqlmap apuntando al parámetro ref e indicando la cadena de validación positiva: sqlmap -u "http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --technique=B --dbms=MySQL --string="Referencia localizada" --batch -D interafas --tables.
3. Tras enumerar las 32 tablas de la base de datos interafas, se listaron las columnas de la tabla portal_validation_meta (--columns) y finalmente se extrajo el contenido de la columna verification_token (-T portal_validation_meta -C verification_token --dump), obteniendo la bandera UPSLP_CNOIV-SILENT-ANSWER-07.

Evidencia técnica

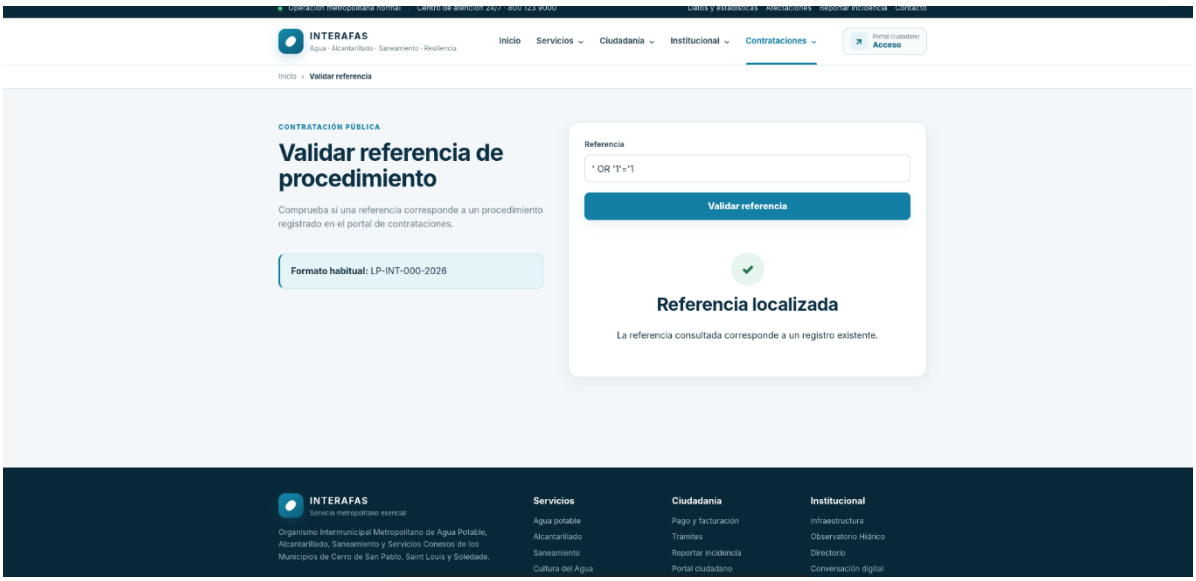
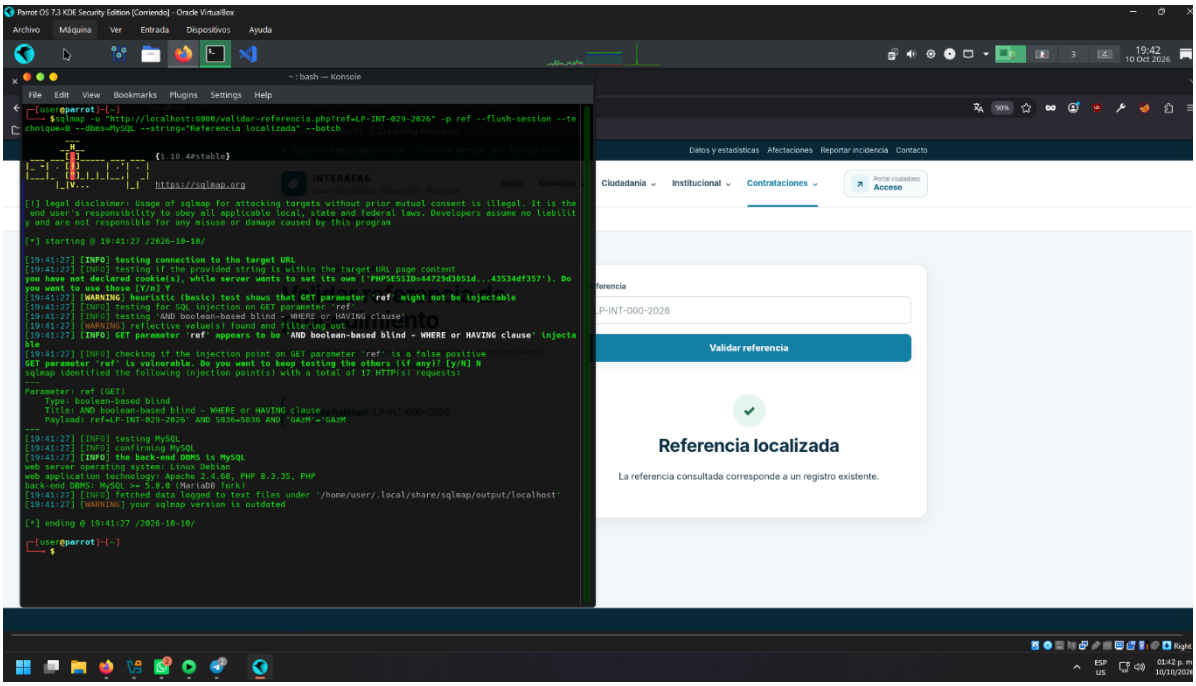


Figura 7.1: Comprobación manual inicial con el payload ' OR '1'='1 devolviendo el estado verdadero "Referencia localizada".



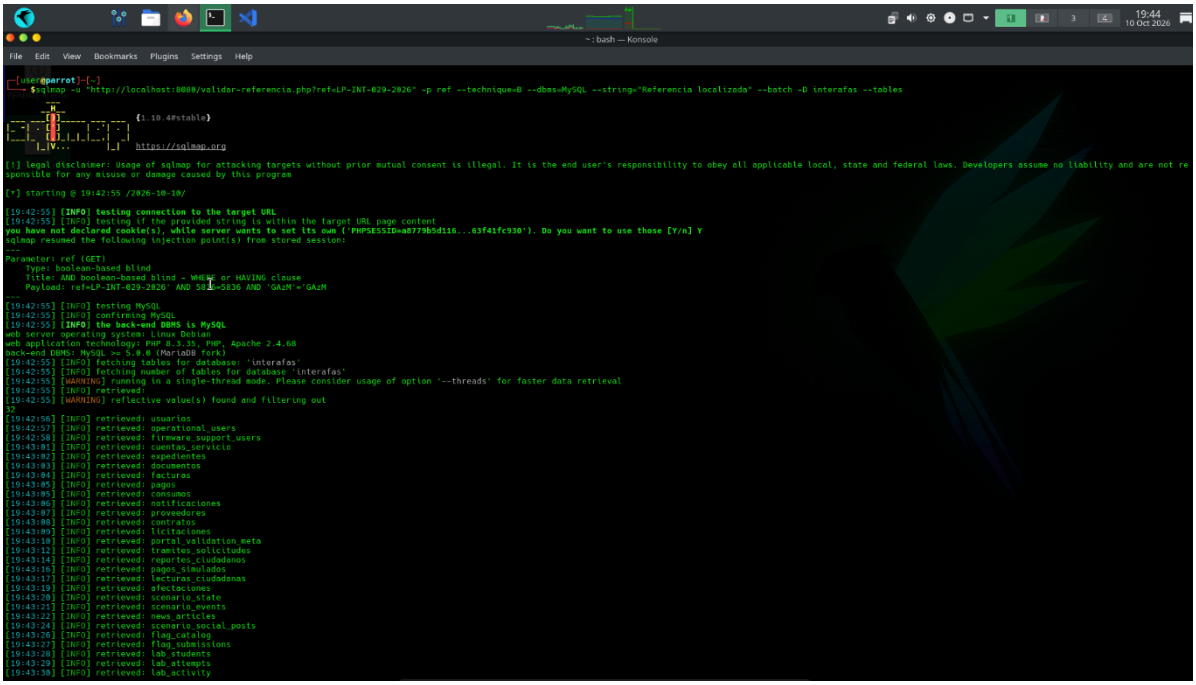
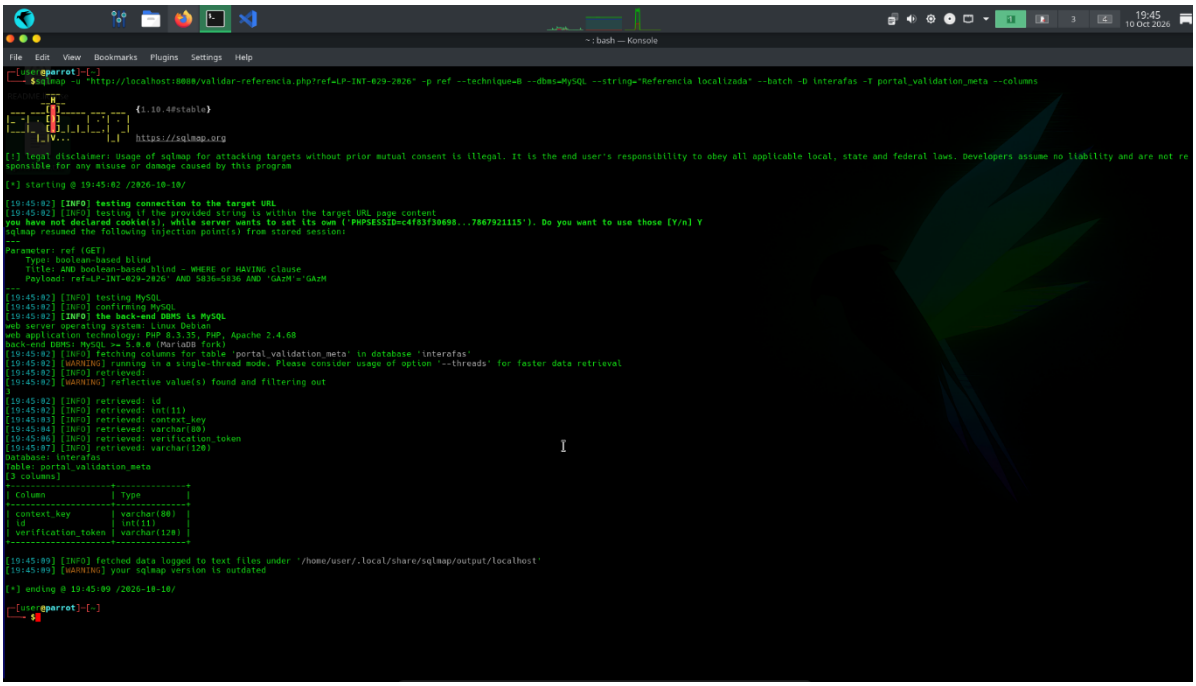


Figura 7.2: Confirmación del punto de inyección booleana en sqlmap y enumeración de las 32 tablas del esquema interafas.



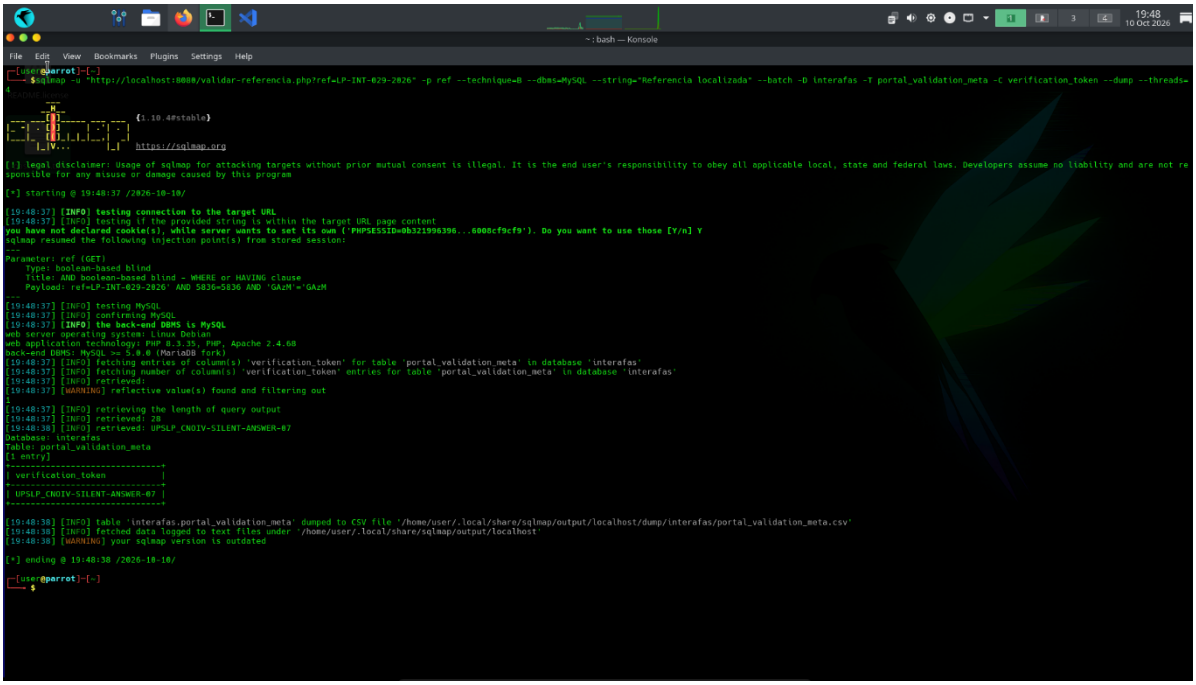


Figura 7.3: Extracción de columnas y volcado (dump) de la tabla portal_validation_meta revelando el token UPSLP_CNOIV-SILENT-ANSWER-07.

Impacto y riesgo: Compromiso total de la **confidencialidad** de la base de datos institucional. Como se observa en el listado de las 32 tablas, un atacante tiene acceso de lectura a usuarios, operational_users, firmware_support_users, facturas, pagos, expedientes y contratos, lo que permite extraer hashes de contraseñas de soporte OT.

Mitigaciones: Reescribir la consulta utilizando PDO con sentencias preparadas y parámetros vinculados ($stmt = $pdo->prepare('SELECT 1 FROM licitaciones WHERE referencia = :ref')), además de aplicar una validación de formato mediante expresiones regulares (^LP-INT-[0-9]{3}-[0-9]{4}$).

VULN-08: Cross-Site Scripting Almacenado (Stored XSS) en reportes ciudadanos

Descripción técnica y causa raíz: El formulario de creación de reportes de incidencias (/reportes.php) almacena en la base de datos el texto ingresado en el campo Descripción sin ningún tipo de filtrado de etiquetas HTML. Cuando el reporte se consulta posteriormente en /seguimiento-reporte.php?id=, el backend imprime el contenido directamente en el documento HTML sin aplicar codificación de caracteres especiales (htmlspecialchars), permitiendo la ejecución de código JavaScript arbitrario en el navegador de quien visualice el folio.

Comprobación de los hallazgos:

1. En http://localhost:8080/reportes.php, se seleccionó la categoría "Alcantarillado" y el municipio "Cerro de San Pablo".
2. En el campo "Descripción" se ingresó el siguiente script diseñado para esperar la carga completa del DOM, consultar el endpoint de validación indicado en la etiqueta <meta> de la página y escribir el resultado en pantalla: <script>window.addEventListener('load', function() { fetch(document.querySelector('meta[name="interafas-validation-endpoint"]').content).then(r=>r.text()).then(function(t){ document.getElementById('xss-proof-result').innerText = t; }); });</script>
3. Al enviar el formulario, el sistema redirigió a http://localhost:8080/seguimiento-reporte.php?id=6 (folio REP-20261011-D9A3AB), donde el script se ejecutó automáticamente y mostró en pantalla la bandera UPSLP_CNOIV-STORED-WORDS-08.

Evidencia técnica:

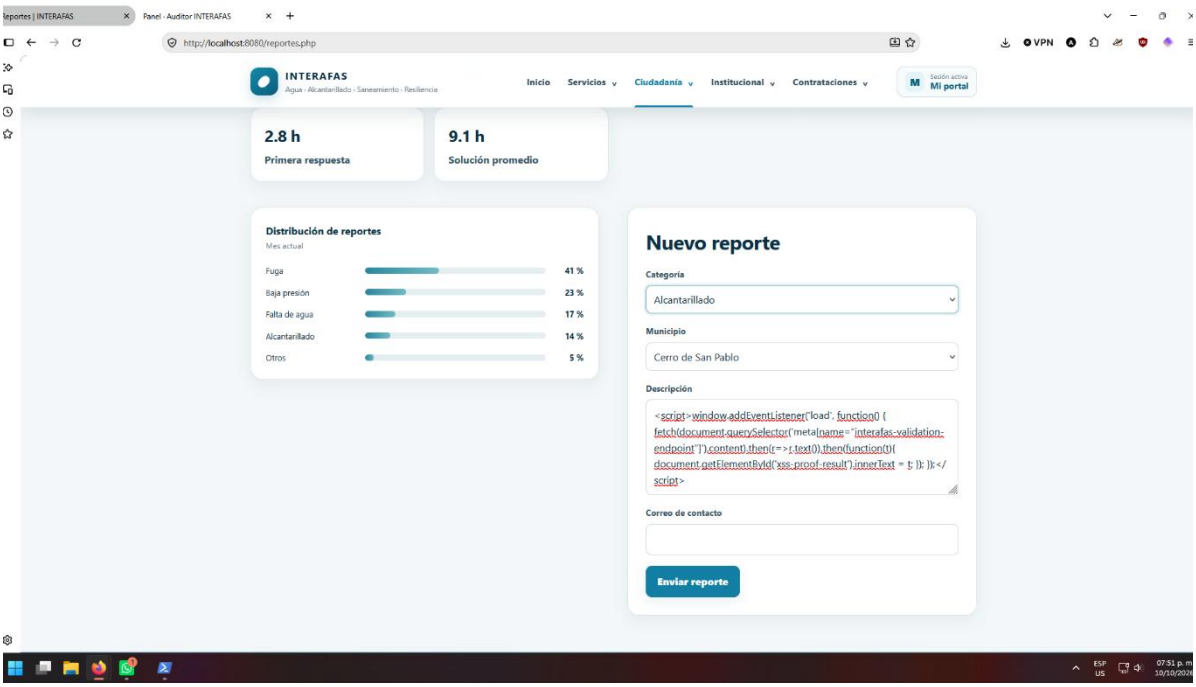


Figura 8.1: Inyección del payload <script> en el campo de descripción dentro del formulario de nuevo reporte en /reportes.php.

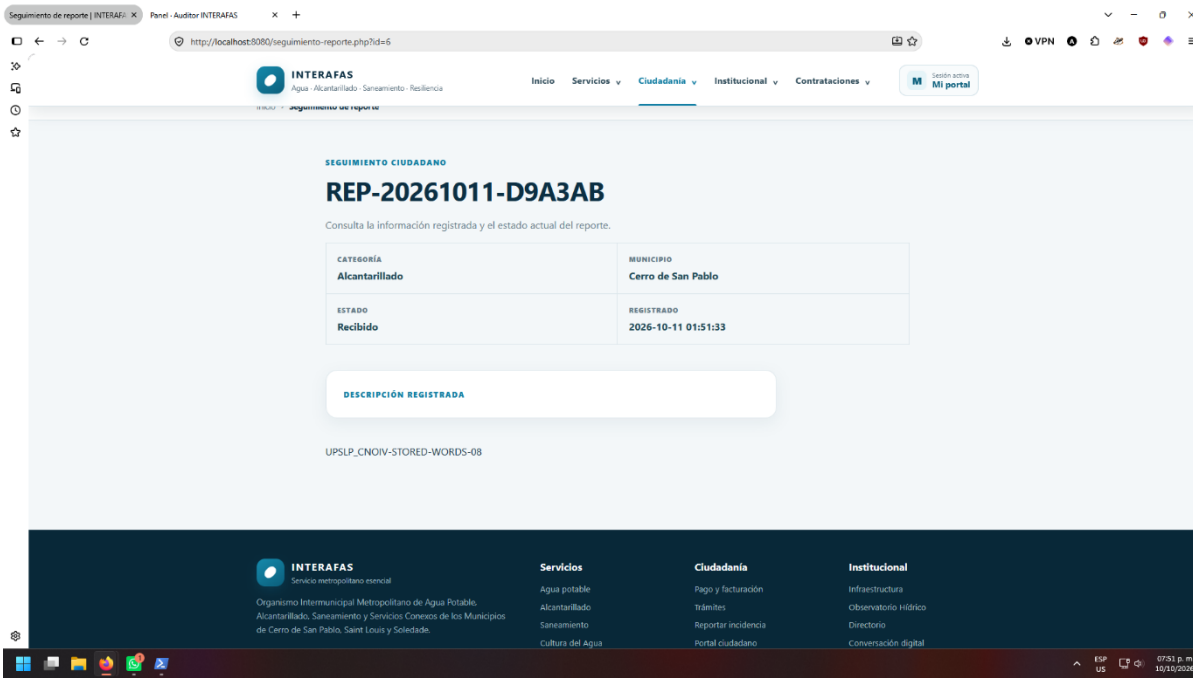


Figura 8.2: Ejecución del XSS almacenado al consultar el folio REP-20261011-D9A3AB en /seguimiento-reporte.php?id=6, mostrando la bandera UPSLP_CNOIV-STORED-WORDS-08.

Impacto y riesgo: Afecta la **integridad** y **confidencialidad** de las sesiones de usuarios y operadores de soporte que revisan tickets de incidencias, permitiendo el robo de sesiones, alteración del contenido de la página o ejecución de acciones no autorizadas desde el navegador de la víctima.

Mitigaciones: Aplicar codificación de salida en todas las variables impresas en las vistas PHP mediante htmlspecialchars($descripcion, ENT_QUOTES, 'UTF-8') e implementar una cabecera Content-Security-Policy (CSP) que deshabilite la ejecución de scripts en línea (script-src 'self').

VULN-09: Salto de directorio (Path Traversal) en descarga de constancias

Descripción técnica y causa raíz: En la sección "Constancias y documentos" (/documentos.php), los botones "Abrir PDF" invocan al script /descargar-documento.php?file=... pasando el nombre del archivo por URL. El script concatena dicho parámetro a una ruta base del sistema de archivos y utiliza funciones de lectura de PHP sin eliminar secuencias de salto de directorio (../) ni verificar con realpath() que el archivo solicitado permanezca dentro de la carpeta autorizada de documentos.

Comprobación de los hallazgos:

1. Desde /documentos.php, se hizo clic en "Abrir PDF" sobre constancia_servicio_00421.pdf interceptando la petición en **Burp Suite** y enviándola al módulo **Repeater**.
2. Se reemplazó el nombre del PDF por secuencias ../ incrementales hasta alcanzar 5 niveles (?file=../../../../../etc/passwd), logrando una respuesta 200 OK con el archivo de usuarios de Linux Debian.
3. Posteriormente se consultó el mensaje del día del sistema operativo mediante GET /descargar-documento.php?file=../../../../../etc/motd, obteniendo el texto "INTERAFAS document service · laboratorio autorizado" seguido de la bandera UPSLP_CNOIV-TOO-DEEP-09.

Evidencia técnica:

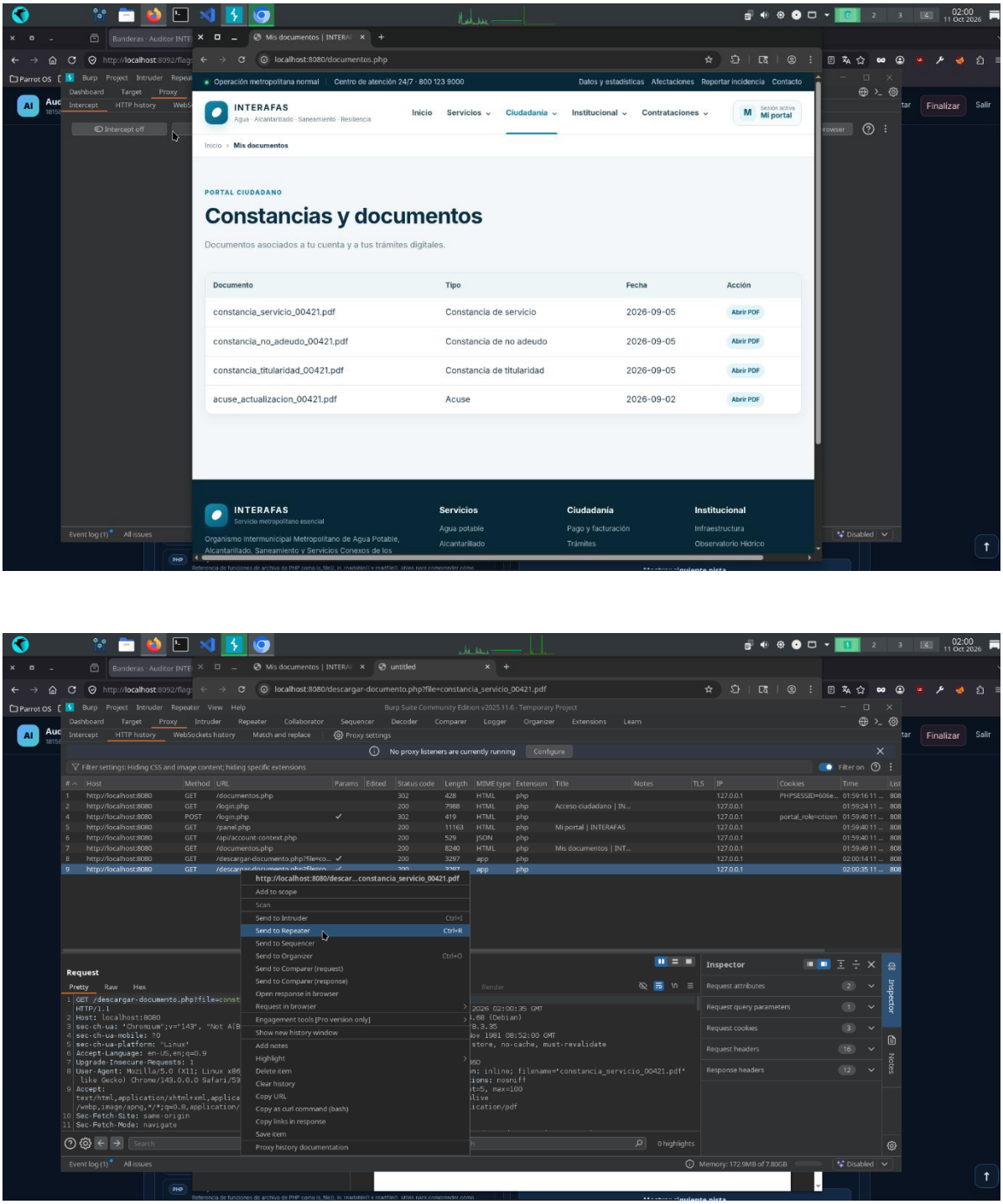


Figura 9.1: Vista del módulo de constancias y captura de la solicitud GET /descargar-documento.php?file=constancia_servicio_00421.pdf enviada a Burp Repeater.

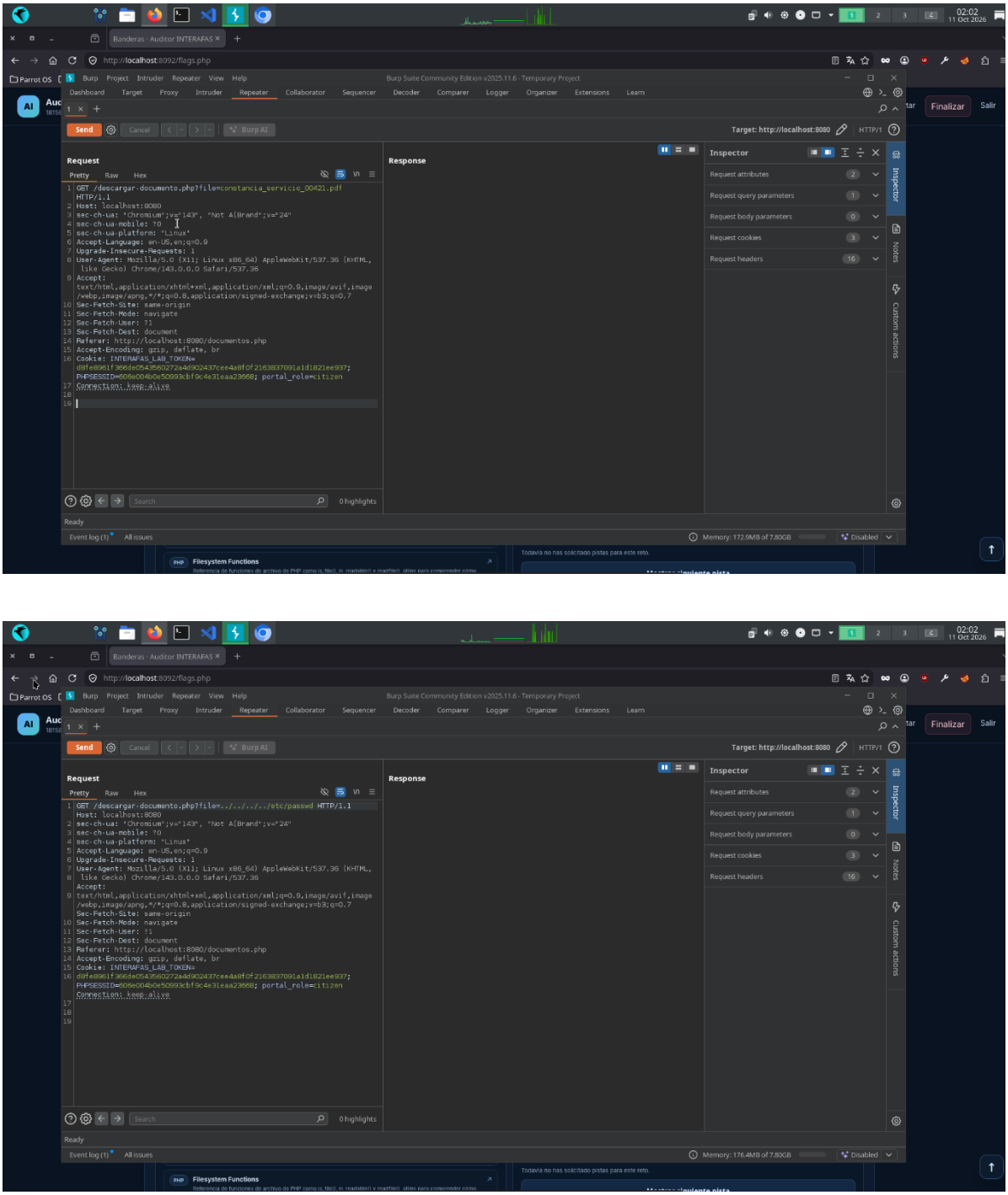


Figura 9.2: Pruebas de profundidad en Burp Repeater hasta lograr la lectura de /etc/passwd con ../../../../../etc/passwd.

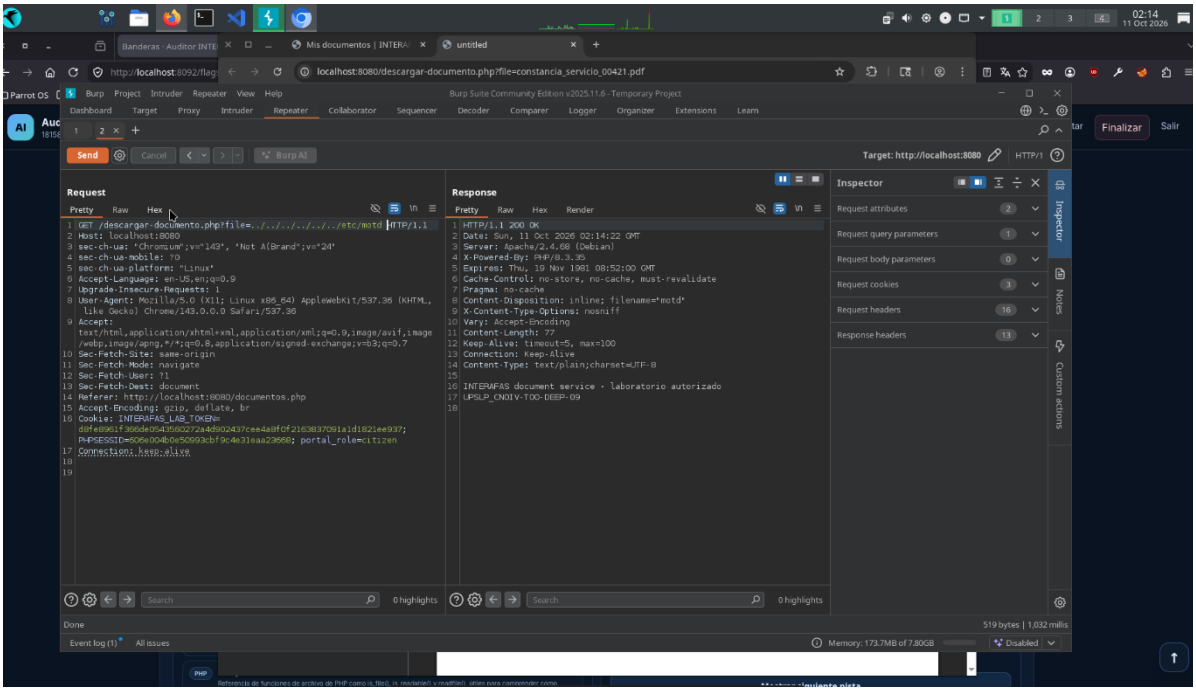


Figura 9.3: Extracción del archivo /etc/motd a través de la vulnerabilidad de Path Traversal mostrando la bandera UPSLP_CNOIV-TOO-DEEP-09.

Impacto y riesgo: Alto riesgo para la **confidencialidad** del servidor. Permite leer archivos de configuración del sistema operativo (/etc/passwd, /etc/hosts), archivos de configuración de Apache y código fuente o credenciales del proyecto ubicadas fuera del directorio web.

Mitigaciones: Utilizar la función basename($_GET['file']) para extraer únicamente el nombre del archivo eliminando cualquier ruta o secuencia ../, y verificar con realpath() que la ruta resultante comience estrictamente con el directorio permitido de constancias.

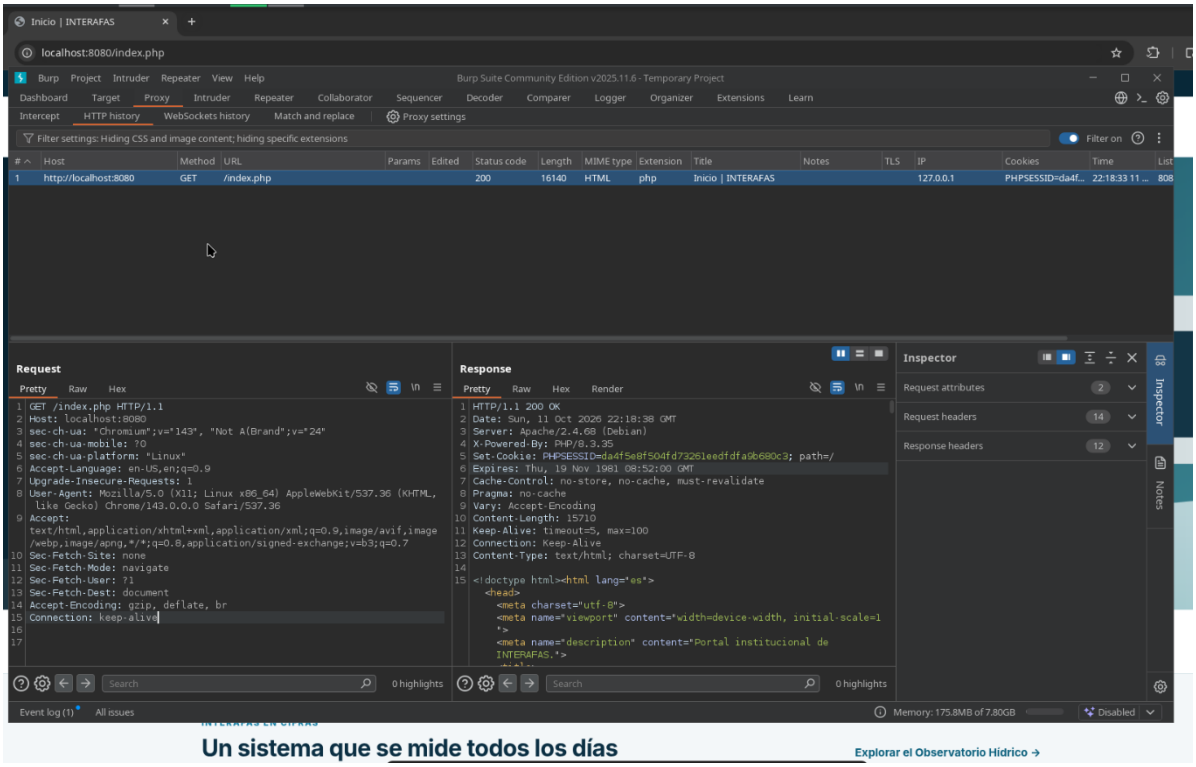
VULN-10: Fijación y reutilización de sesión (Session Fixation / Session Replay)

Descripción técnica y causa raíz: Cuando un usuario visita por primera vez el portal (/index.php o /login.php), PHP le asigna una cookie de sesión PHPSESSID. Al autenticarse exitosamente mediante POST /login.php, la aplicación redirige a /panel.php y emite la cookie portal_role=citizen, pero **omite invocar session_regenerate_id(true)** para rotar el identificador de sesión. Además, el servidor permite que ese mismo PHPSESSID sea reutilizado simultáneamente desde distintos clientes o herramientas externas sin invalidar sesiones previas (X-INTERAFAS-Session-State: replay-accepted).

Comprobación de los hallazgos:

1. En **Burp Suite** (*HTTP History*) se revisó la secuencia desde antes de iniciar sesión (GET /login.php) hasta el envío de credenciales (POST /login.php), comprobando que la cookie PHPSESSID=dfc245d27db79af729928591b1af8707 nunca cambió tras el login.
2. Se copió ese identificador de sesión hacia la terminal y se probó su reutilización con curl -s -b "PHPSESSID=dfc245d27db79af729928591b1af8707" http://localhost:8080/panel.php, confirmando que el servidor mantenía la sesión activa de "Mariana".
3. Se ejecutó un ciclo for en bash consultando las cabeceras de todas las páginas internas del portal ciudadano con esa cookie reutilizada (for f in expediente.php facturacion.php documentos.php perfil.php ...), detectando en /perfil.php las cabeceras X-INTERAFAS-Session-State: replay-accepted y X-INTERAFAS-Validation: UPSLP_CNOIV-WHO-ARE-YOU-10.

Evidencia técnica:



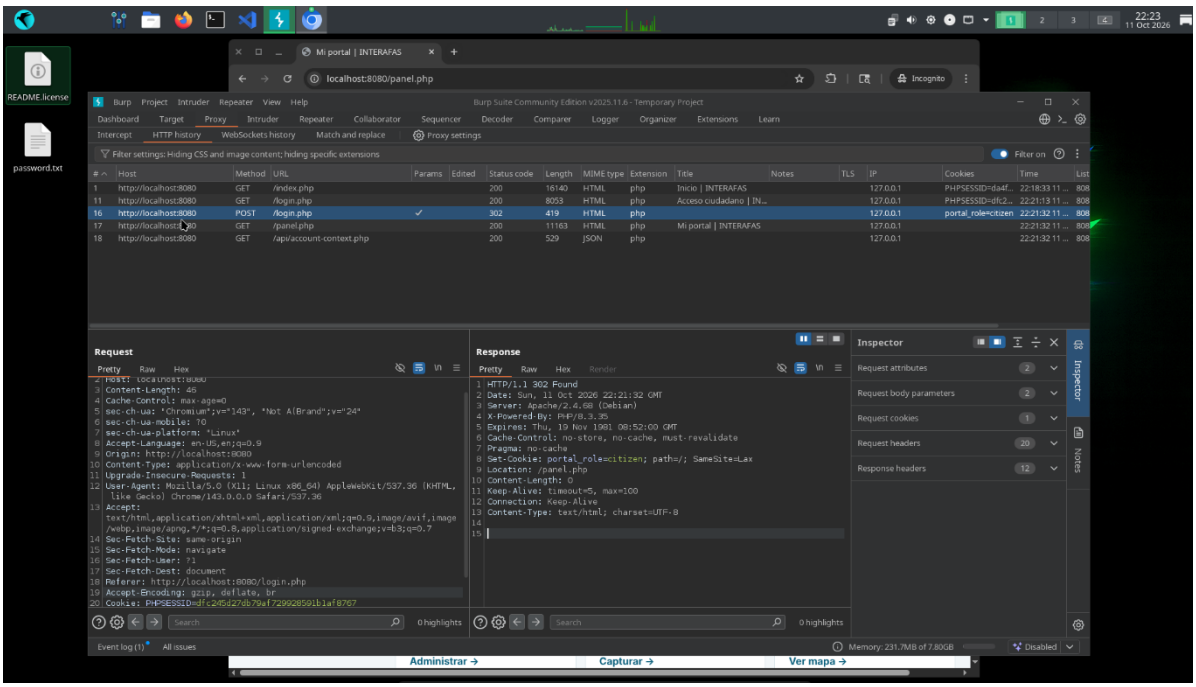


Figura 10.1: Registro en Burp Suite mostrando que el PHPSESSID asignado antes de autenticarse se conserva idéntico después del POST /login.php.

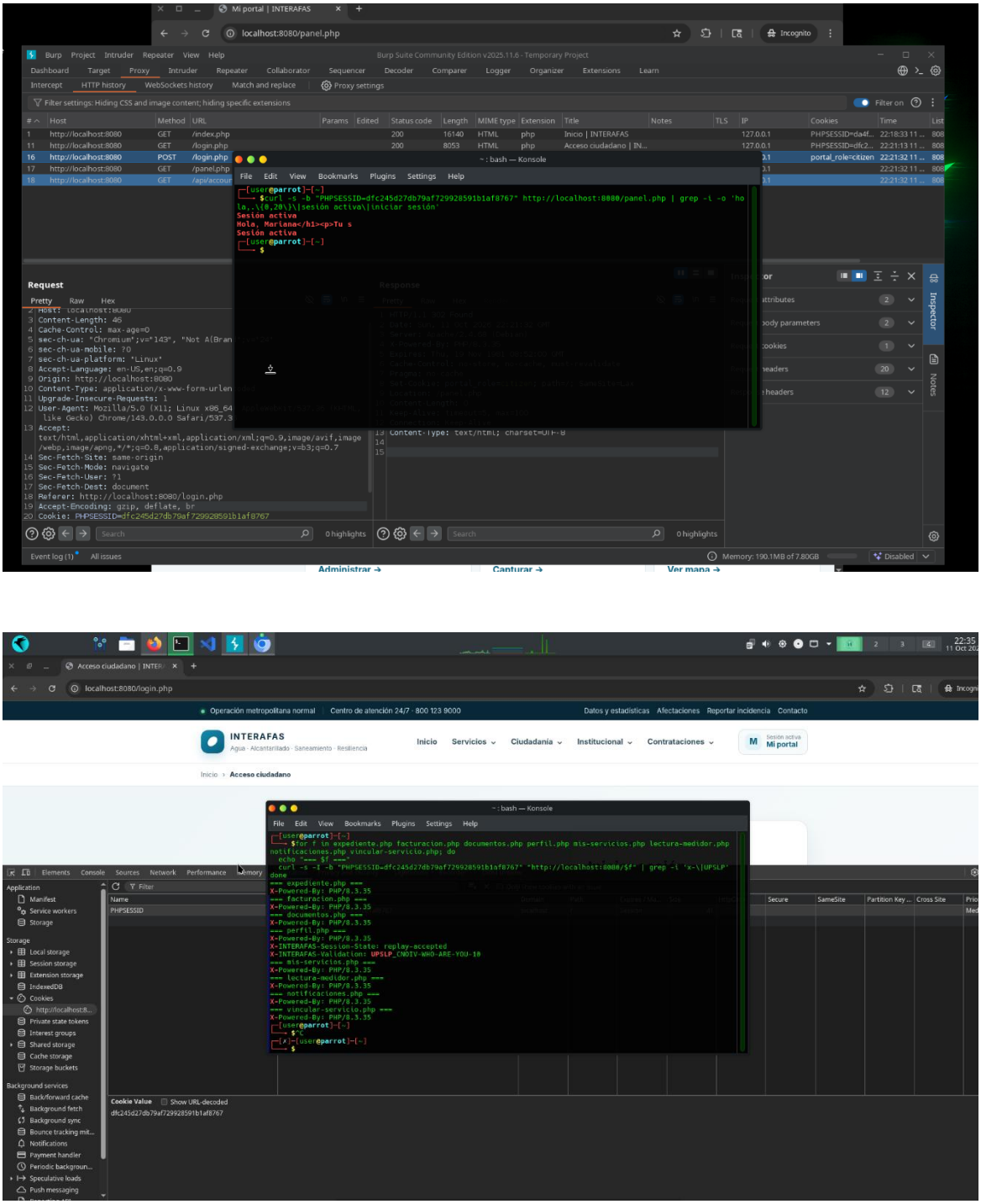


Figura 10.2: Reutilización de la cookie PHPSESSID desde la terminal con curl sobre /perfil.php, obteniendo la cabecera replay-accepted y la bandera UPSLP_CNOIV-WHO-ARE-YOU-10.

Impacto y riesgo: Compromete la **autenticidad** y **confidencialidad** de las cuentas ciudadanas. Un atacante que logre fijar o interceptar un PHPSESSID previo al login (o robarlo mediante el XSS de la VULN-08) puede secuestrar la cuenta del usuario sin conocer su contraseña.

Mitigaciones: Llamar obligatoriamente a session_regenerate_id(true) inmediatamente después de validar las credenciales en login.php, configurar las directivas session.use_strict_mode = 1 y session.cookie_httponly = 1, e invalidar por completo la sesión en el servidor al cerrar sesión.

VULN-11: Exposición de endpoint de API no documentado (Shadow API)

Descripción técnica y causa raíz: Al cargar el panel principal del ciudadano (/panel.php), el navegador ejecuta una petición asíncrona hacia /api/account-context.php para mostrar el estado de sincronización de la cuenta. La causa raíz es una gestión inadecuada del inventario de APIs y exposición excesiva de datos: aunque la interfaz web solo ocupa el campo status, el JSON de respuesta incluye un objeto links que revela la ruta /api/service-history.php?account=40010001, un endpoint interno de historial que nunca fue documentado ni enlazado en los menús pero que quedó habilitado en producción (X-INTERAFAS-Endpoint-Status: undocumented).

Comprobación de los hallazgos:

1. Con la sesión iniciada en /panel.php, se abrieron las herramientas de desarrollo del navegador en la pestaña **Network** (*Fetch/XHR*) y se inspeccionó la respuesta de /api/account-context.php.
2. En la pestaña *Preview* se identificó la propiedad links.history: "/api/service-history.php?account=40010001".
3. Se consultó dicha ruta enviando la cookie de sesión mediante curl -s -i -b "PHPSESSID=dfc245d27db79af729928591b1af8707" "http://localhost:8080/api/service-history.php?account=40010001" | head -20, obteniendo en las cabeceras de respuesta la bandera UPSLP_CNOIV-HIDDEN-HISTORY-11.

Evidencia técnica:

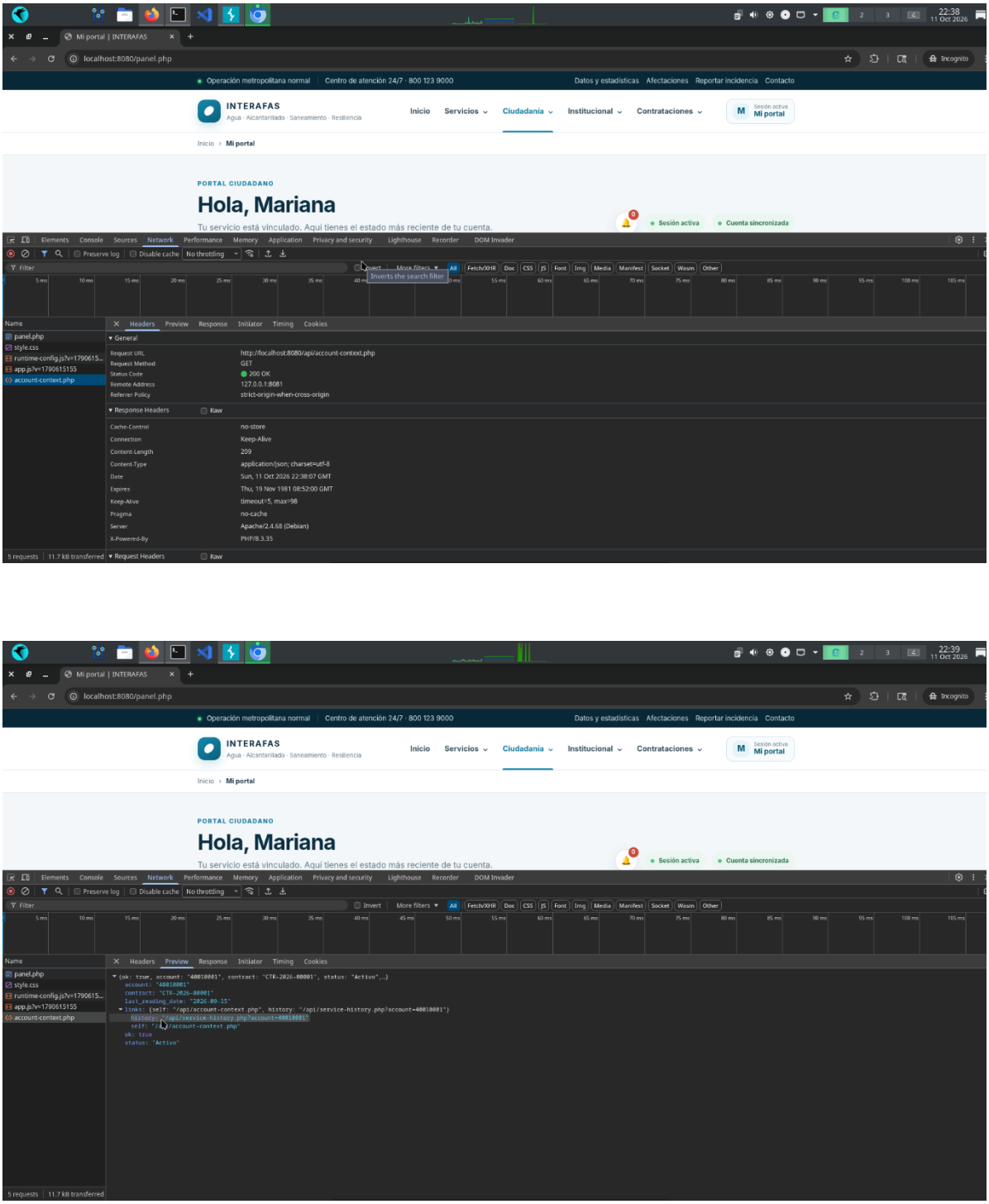


Figura 11.1: Inspección del tráfico de red en /panel.php mostrando la respuesta JSON de /api/account-context.php y el enlace oculto hacia /api/service-history.php.

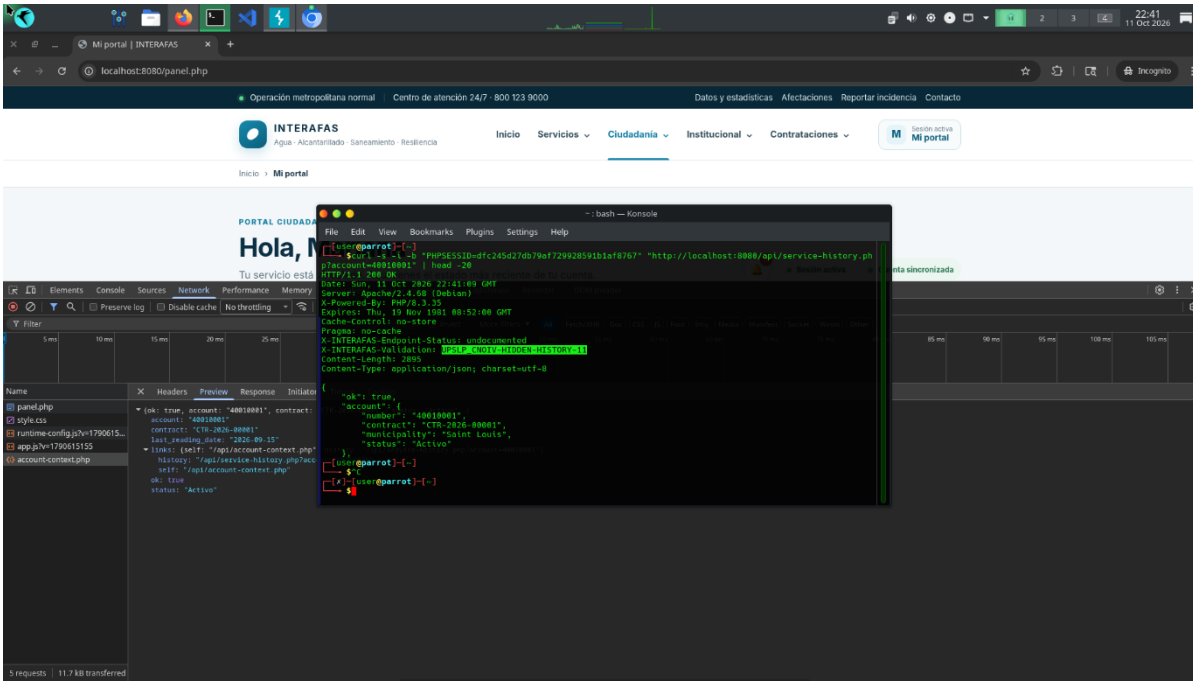


Figura 11.2: Petición hacia el endpoint no documentado devolviendo la cabecera X-INTERAFAS-Endpoint-Status: undocumented y la bandera UPSLP_CNOIV-HIDDEN-HISTORY-11.

Impacto y riesgo: Afecta la **confidencialidad** y amplía la superficie de ataque, ya que los endpoints olvidados o en desuso suelen carecer de las revisiones de seguridad aplicadas a las rutas principales del portal.

Mitigaciones: Mantener un inventario actualizado de rutas de API (por ejemplo, mediante especificaciones OpenAPI), deshabilitar en producción los endpoints que no sean consumidos activamente por el frontend y filtrar las respuestas JSON para entregar únicamente los campos requeridos por la vista.

VULN-12: Autorización rota a nivel de objeto (BOLA / IDOR) en API de historial de servicio

Descripción técnica y causa raíz: Continuando con el análisis del endpoint descubierto en la vulnerabilidad anterior (/api/service-history.php), se identificó que este recibe el número de cuenta mediante el parámetro GET ?account=. El servidor valida que la petición incluya una sesión activa, pero **no verifica que el número de cuenta consultado (40010002) esté vinculado al usuario autenticado (ciudadano01)**, lo cual es confirmado por la cabecera X-INTERAFAS-Object-Authorization: missing.

Comprobación de los hallazgos:

1. Se inició sesión por consola guardando las cookies en un archivo temporal: curl -c /tmp/cookies3.txt -b /tmp/cookies3.txt -X POST http://localhost:8080/login.php -d 'usuario=ciudadano01&password=AguaSegura2026!'.
2. Se probaron cuentas consecutivas (40010001, 40010002, 40010003), observando que todas devolvían código 200.
3. Al consultar curl -s -i -b /tmp/cookies3.txt "http://localhost:8080/api/service-history.php?account=40010002", el servidor devolvió el contrato CTR-2026-00002 (municipio de Soledade), el desglose de facturas pendientes/pagadas y la bandera UPSLP_CNOIV-SECOND-ACCOUNT-12.

Evidencia técnica:

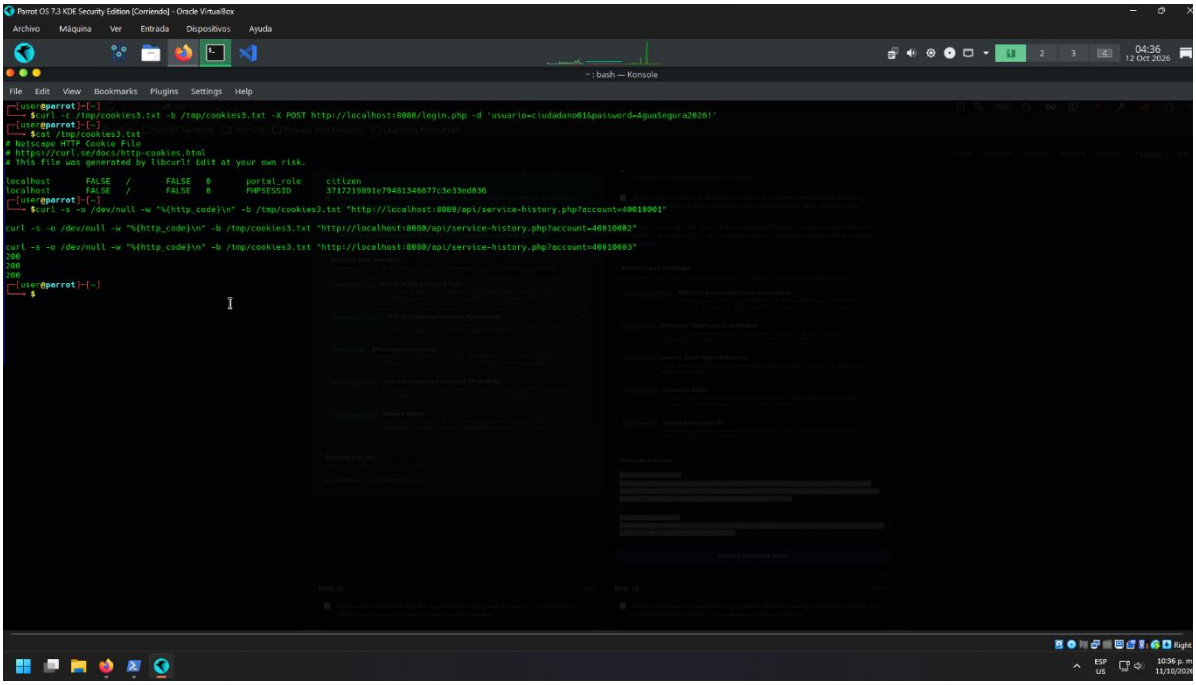


Figura 12.1: Autenticación y almacenamiento de cookies en /tmp/cookies3.txt, probando la respuesta 200 OK en los números de cuenta 40010001, 40010002 y 40010003.

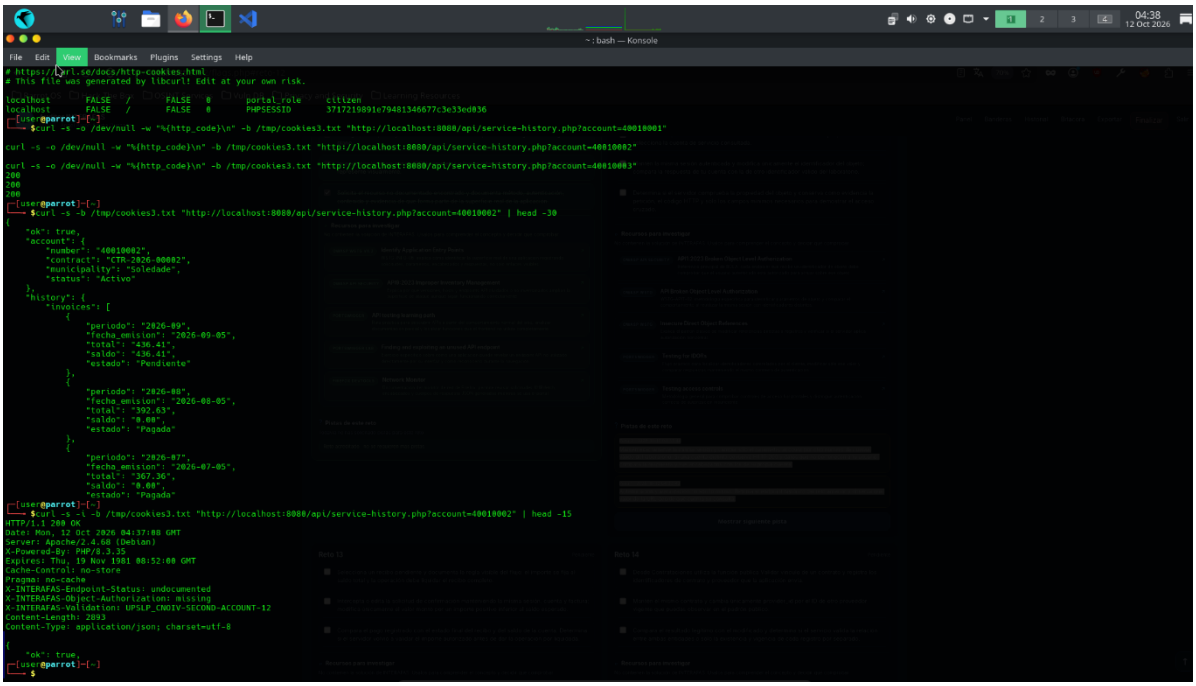


Figura 12.2: Volcado del historial financiero de la cuenta ajena 40010002 y cabecera X-INTERAFAS-Validation: UPSLP_CNOIV-SECOND-ACCOUNT-12.

Impacto y riesgo: Compromete la **confidencialidad** financiera y contractual de los usuarios. Debido a que el formato de cuenta es secuencial (4001000X), un atacante puede automatizar la descarga masiva de contratos, consumos y saldos pendientes de todos los municipios.

Mitigaciones: Validar en el controlador de la API que el parámetro account coincida con las cuentas registradas a nombre de $_SESSION['user_id'] en la tabla cuentas_servicio antes de retornar el objeto JSON.

VULN-13: Manipulación de importe por fallo de lógica de negocio en pasarela de pagos

Descripción técnica y causa raíz: En el flujo de pago en línea (/pago.php?factura=6), el formulario HTML incluye un campo con el importe total a liquidar (name="monto" value="399.24"). La vulnerabilidad se produce porque el servidor confía en el valor del parámetro monto enviado por el cliente en la petición POST, registrando la factura como liquidada siempre que el importe sea un número positivo, sin volver a consultar en la base de datos cuál era el saldo real requerido (X-INTERAFAS-Business-Rule: amount-not-revalidated).

Comprobación de los hallazgos:

1. Se verificó el estado original del recibo FAC-202609-00001 en /factura.php?id=6, el cual presentaba un saldo pendiente de $399.24 para la cuenta 40010001.
2. Se extrajeron los parámetros esperados por el formulario de pago en /pago.php?factura=6 (metodo, factura_id, cuenta y monto).
3. Se envió la solicitud de confirmación modificando el monto a un solo peso: curl -s -i -b /tmp/cookies3.txt -X POST http://localhost:8080/pago.php -d "metodo=Tarjeta&factura_id=6&cuenta=40010001&monto=1.00".
4. El servidor aceptó el pago generando la referencia PAY-261012-AD7FDE ("Pago recibido") y entregó en las cabeceras la bandera UPSLP_CNOIV-PAYMENT-PATH-13.

Evidencia técnica:

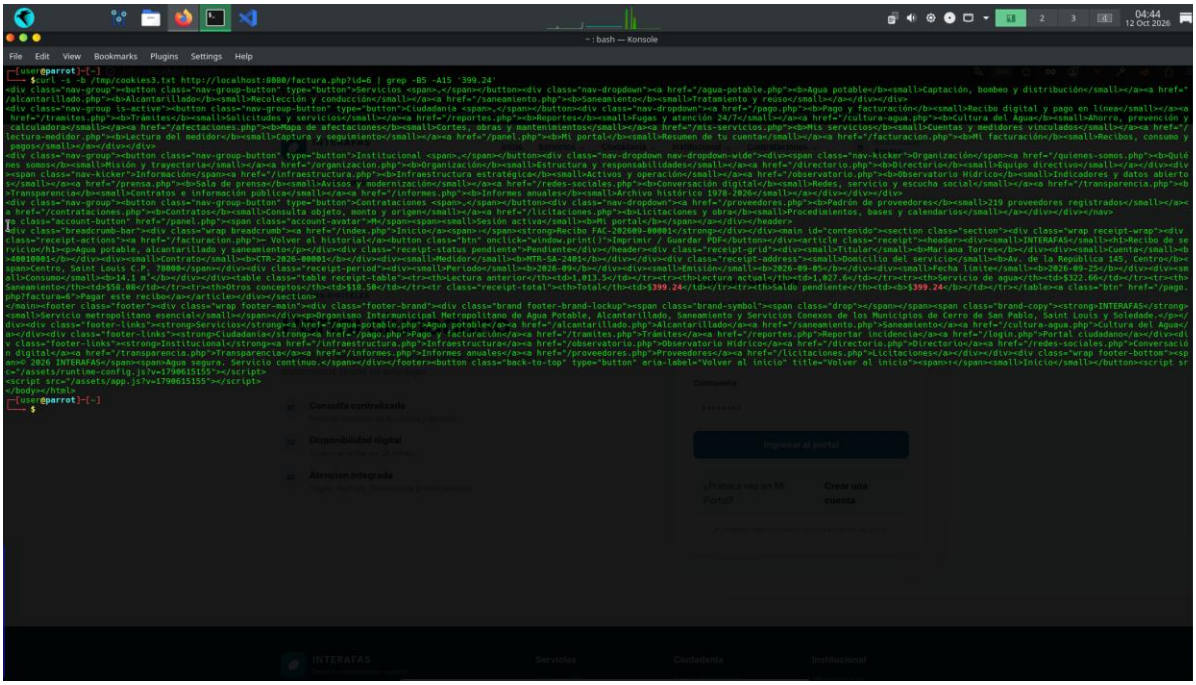


Figura 13.1: Consulta del recibo FAC-202609-00001 en /factura.php?id=6 mostrando el saldo real pendiente de $399.24.

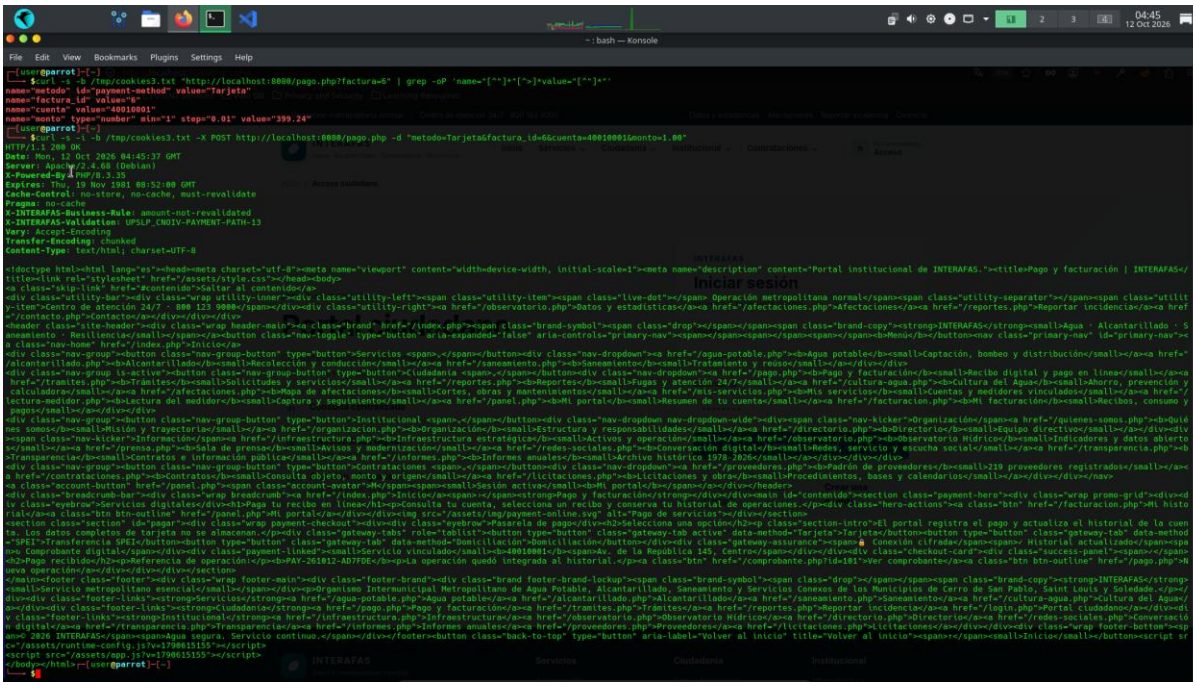


Figura 13.2: Envío de la petición POST /pago.php modificando el parámetro a monto=1.00, liquidando la factura y obteniendo la bandera UPSLP_CNOIV-PAYMENT-PATH-13.

Impacto y riesgo: Impacto severo en la **integridad** financiera y recaudación del organismo. Permite que cualquier usuario liquide adeudos de agua potable y saneamiento pagando cantidades simbólicas como $1.00 o $0.01.

Mitigaciones: Ignorar y eliminar el parámetro monto del formulario enviado por el cliente; el backend debe obtener el importe a cobrar consultando directamente la columna de saldo pendiente en la tabla facturas a partir del factura_id autenticado.

VULN-14: Deficiencia de validación relacional entre contratos y proveedores

Descripción técnica y causa raíz: El módulo público /validar-vinculo-contractual.php recibe dos parámetros por URL: contract_id y provider_id. La falla de lógica de negocio consiste en que el backend comprueba por separado que el contrato exista/esté vigente y que el proveedor exista/esté vigente en el padrón, pero **omite verificar la llave foránea o relación entre ambos**, dando por válido cualquier cruce entre un contrato activo y un proveedor activo aunque no tengan relación real.

Comprobación de los hallazgos:

1. Se consultó un vínculo legítimo en http://localhost:8080/validar-vinculo-contractual.php?contract_id=51&provider_id=171, correspondiente al contrato INT-2026-0051 ("Mantenimiento de planta de tratamiento") adjudicado a Control Hídricos S.A. de C.V..
2. Se conservó el mismo contract_id=51, pero se cambió el proveedor a provider_id=107 (correspondiente a Hidro Regionales Proyectos, dedicado a "Arrendamiento de maquinaria").
3. El sistema devolvió el mensaje "Vínculo vigente" seguido del recuadro "Relación inconsistente aceptada" con la bandera UPSLP_CNOIV-TRUSTED-SUPPLIER-14.

Evidencia técnica:

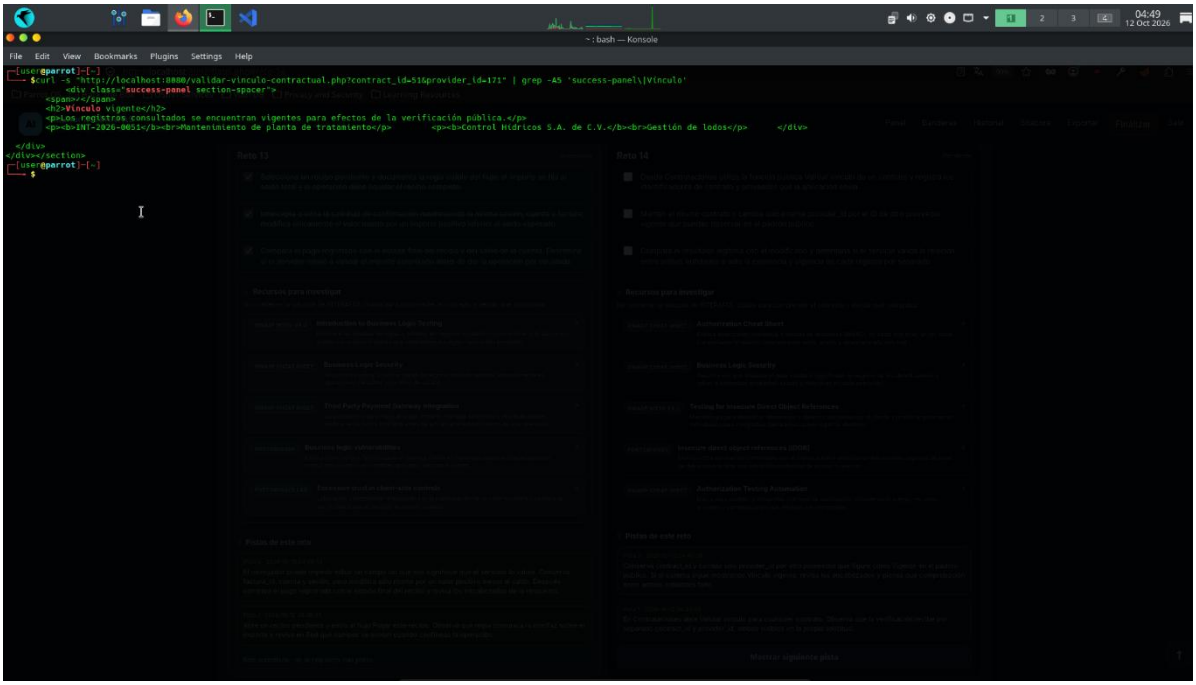


Figura 14.1: Verificación de la relación legítima entre el contrato contract_id=51 y su proveedor real provider_id=171.

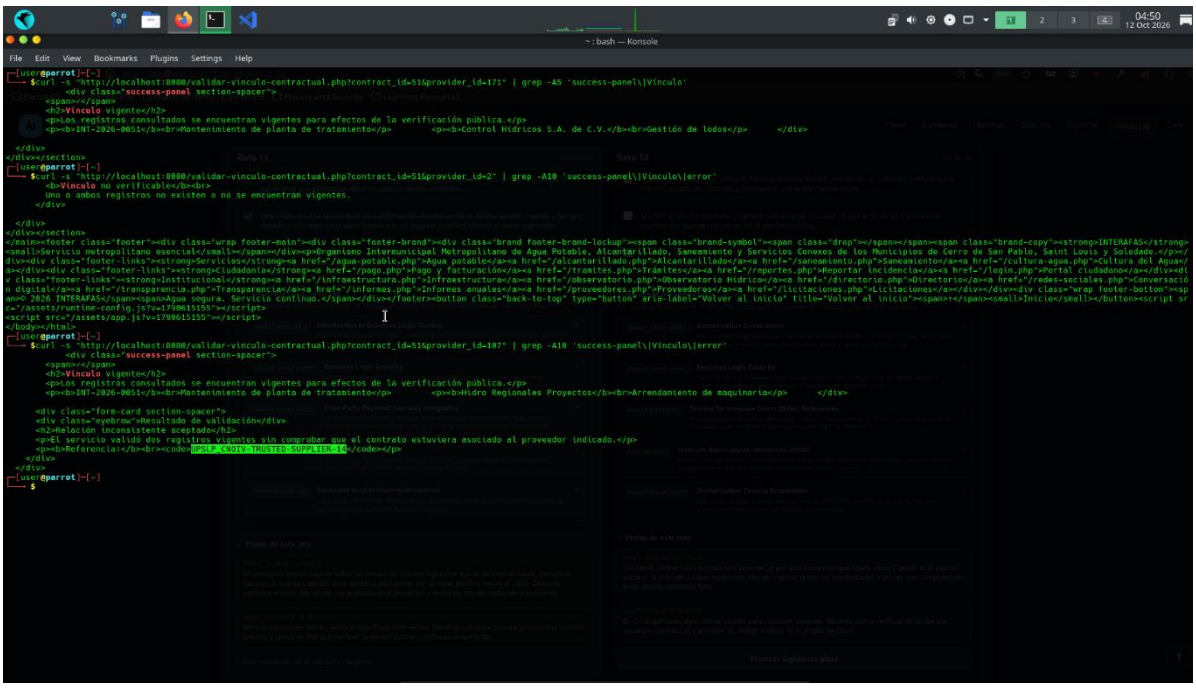


Figura 14.2: Manipulación del parámetro provider_id=107 demostrando que el servidor valida las entidades por separado y entrega la bandera UPSLP_CNOIV-TRUSTED-SUPPLIER-14.

Impacto y riesgo: Afecta la **integridad** de los procesos administrativos y de auditoría pública, permitiendo que un proveedor externo suplante la titularidad de un contrato de infraestructura crítica ante revisiones de cumplimiento.

Mitigaciones: Modificar la consulta SQL de validación utilizando un INNER JOIN o una condición WHERE contratos.id = :contract_id AND contratos.proveedor_id = :provider_id para asegurar que ambas entidades estén vinculadas entre sí.

VULN-15: Divulgación de arquitectura y topología de red OT en endpoint público

Descripción técnica y causa raíz: La página institucional /infraestructura.php consume en segundo plano el endpoint /api/infrastructure-status.php para mostrar indicadores generales. Sin embargo, la API incluye en su respuesta JSON un nodo completo llamado diagnostics que expone detalles confidenciales de la arquitectura interna: el nombre del puente (operations-bridge), la zona operacional (OPS-NET-20), el segmento de red privada (10.40.20.0/24), la ruta de acceso (/operations/gateway.php), el servicio industrial (ot-sim) y el identificador del dispositivo crítico (RTU-GW-07).

Comprobación de los hallazgos:

1. Se ingresó a http://localhost:8080/infraestructura.php con la pestaña **Network** de las DevTools abierta.
2. Se identificó la llamada GET hacia infrastructure-status.php y se inspeccionó el objeto JSON en la pestaña *Response*, tomando nota del segmento 10.40.20.0/24 y la ruta /operations/gateway.php.
3. Al abrir http://localhost:8080/api/infrastructure-status.php en una nueva pestaña y revisar la sección *Response Headers*, se localizó la bandera UPSLP_CNOIV-BEHIND-THE-DESK-15.

Evidencia técnica:

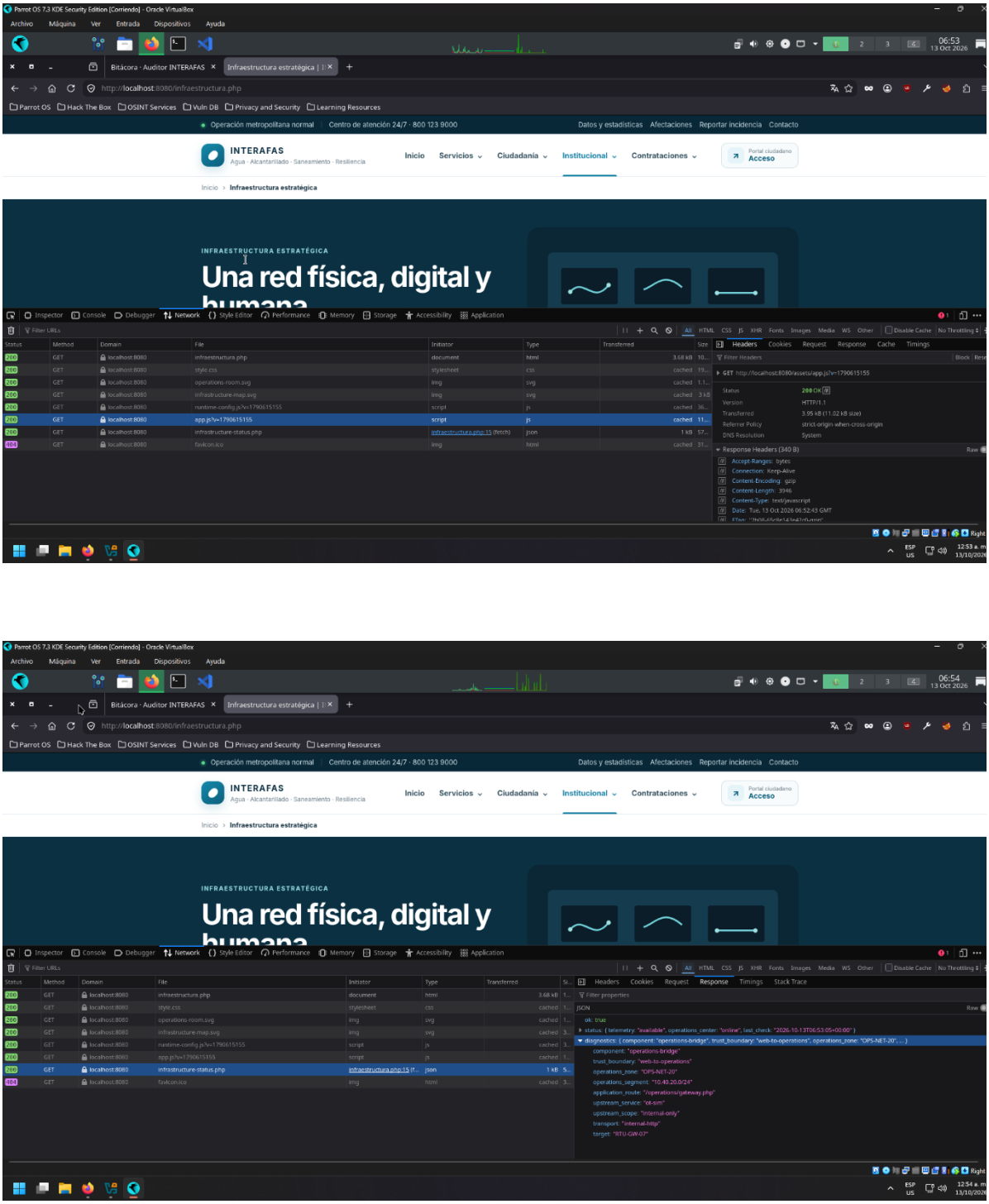


Figura 15.1: Monitoreo de red en /infraestructura.php revelando el bloque JSON diagnostics con el segmento 10.40.20.0/24, la ruta /operations/gateway.php y el objetivo RTU-GW-07.

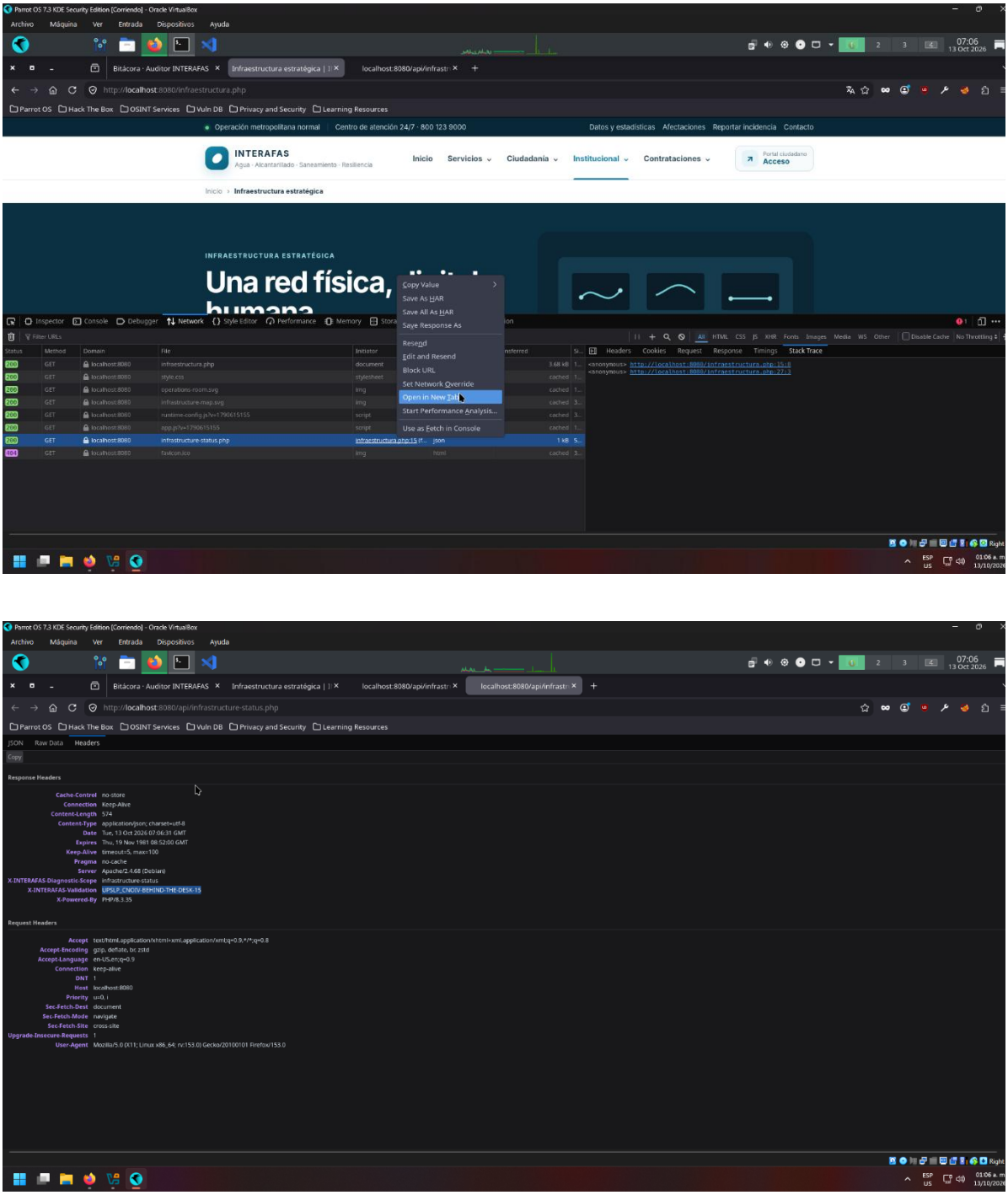


Figura 15.2: Apertura directa de /api/infrastructure-status.php mostrando en las cabeceras HTTP la bandera UPSLP_CNOIV-BEHIND-THE-DESK-15.

Impacto y riesgo: Riesgo crítico para la **confidencialidad** de la infraestructura estratégica. Esta vulnerabilidad es el eslabón que conecta el entorno web (IT) con la red industrial (OT), entregando al atacante el direccionamiento IP exacto y los nombres de activos necesarios para cruzar la frontera de red.

Mitigaciones: Eliminar por completo el objeto diagnostics de la respuesta pública de /api/infrastructure-status.php, limitando la salida exclusivamente a métricas ciudadanas no sensibles.

VULN-16: Evasión del Gateway Operacional mediante suplantación de cabecera X-Forwarded-For

Descripción técnica y causa raíz: Al intentar acceder a la ruta /operations/gateway.php descubierta en el hallazgo anterior, el servidor bloquea el paso con un código 403 Forbidden, pero explica en su respuesta JSON la política exacta que utiliza para validar el origen: "source_validation": "proxy-client-address" y "network_scope": "private-operational-segment". La causa raíz es que el gateway confía ciegamente en la cabecera HTTP X-Forwarded-For enviada por el cliente para determinar si la petición proviene de la subred operacional 10.40.20.0/24, permitiendo cruzar la frontera IT/OT mediante una simple falsificación de cabecera (*IP Spoofing*).

Comprobación de los hallazgos:

1. Se consultó /operations/gateway.php confirmando el bloqueo 403 Forbidden y la política proxy-client-address.
2. Utilizando los datos obtenidos en la VULN-15 (10.40.20.0/24), se envió la petición en **Burp Repeater** (y por consola) agregando antes del salto de línea de las cabeceras la directiva X-Forwarded-For: 10.40.20.1.
3. El servidor respondió con HTTP/1.1 200 OK, confirmando el cruce de frontera (X-INTERAFAS-Boundary: crossed), revelando la ruta de login de operadores ("operator_entry": "/operations/login.php") y entregando la bandera UPSLP_CNOIV-BEYOND-THE-WEB-16.

Evidencia técnica:

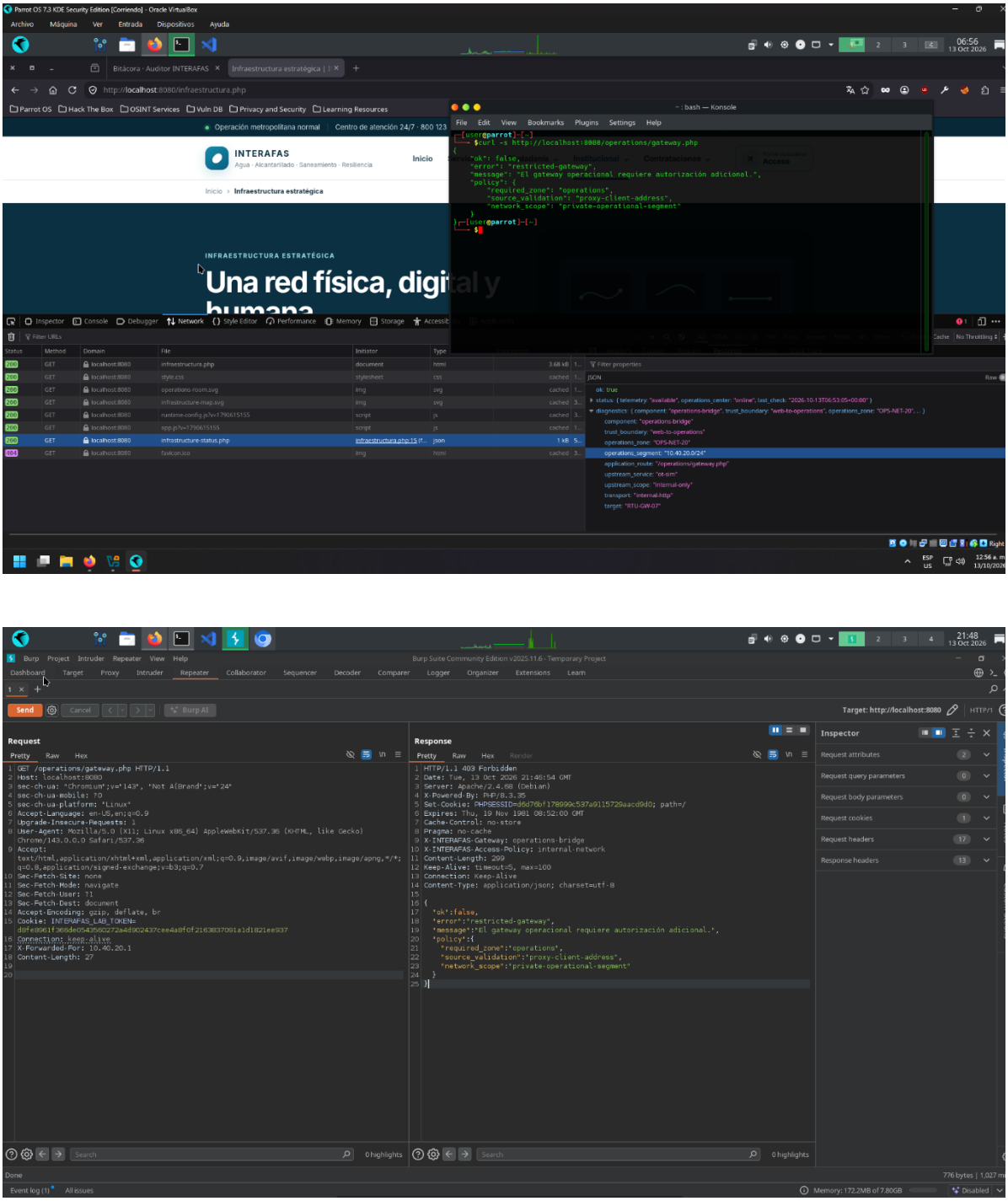


Figura 16.1: Respuesta inicial 403 Forbidden en /operations/gateway.php exponiendo la política source_validation: proxy-client-address.

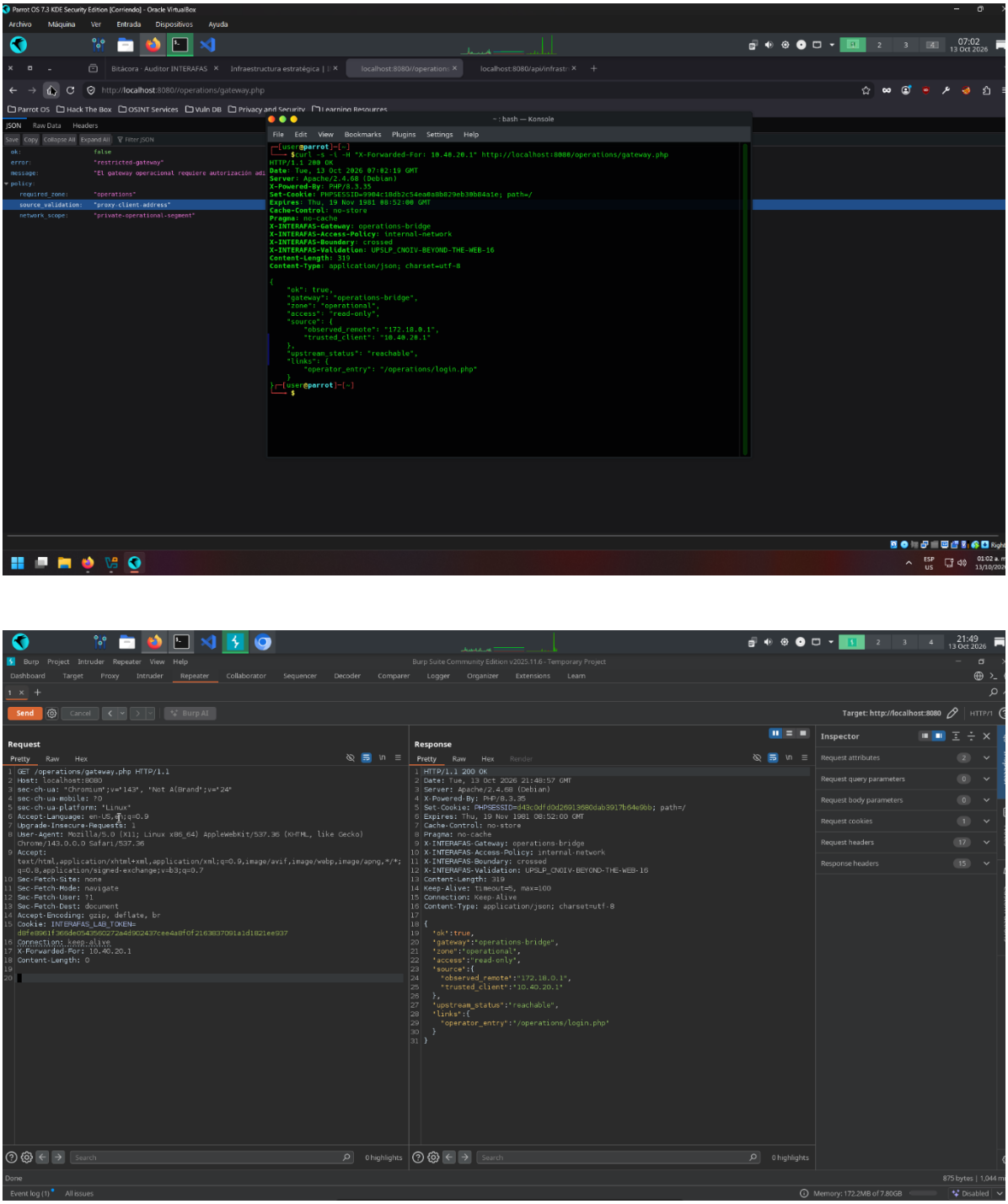


Figura 16.2: Inyección de la cabecera X-Forwarded-For: 10.40.20.1 en consola y en Burp Repeater, logrando cruzar la frontera hacia la red operacional y obtener la bandera UPSLP_CNOIV-BEYOND-THE-WEB-16.

Impacto y riesgo: Compromete la **confidencialidad** e **integridad** del perímetro industrial. Rompe por completo la segmentación lógica entre el portal ciudadano expuesto a Internet y el Centro de Operaciones de la red de agua.

Mitigaciones: No utilizar cabeceras HTTP manipulables por el cliente (X-Forwarded-For, X-Real-IP) como mecanismo de control de acceso; el aislamiento de la red OT debe aplicarse a nivel de red (firewalls, VLANs separadas y VPN con autenticación multifactor) verificando la IP real del socket ($_SERVER['REMOTE_ADDR']).

VULN-17: Falta de autenticación en endpoint crítico de telemetría de planta

Descripción técnica y causa raíz: Al acceder a la pantalla del Centro de Operaciones (/operations/login.php), la página carga el archivo JavaScript /operations/assets/ops-client.php, el cual define las rutas de monitoreo: /operations/telemetry.php, /operations/firmware-status.php y /operations/asset-context.php. La falla radica en que /operations/telemetry.php no verifica que exista una sesión autenticada de operador (X-INTERAFAS-Operational-Session: missing), sino que confía únicamente en que la petición aparente venir del segmento de red interno (X-INTERAFAS-Monitoring-Authorization: network-only).

Comprobación de los hallazgos:

1. Se visitó http://localhost:8080/operations/login.php y se inspeccionó el código de /operations/assets/ops-client.php, identificando telemetryEndpoint: '/operations/telemetry.php'.
2. Se capturó la petición hacia /operations/telemetry.php en **Burp Suite** y se envió a **Repeater** incluyendo la cabecera X-Forwarded-For: 10.40.20.1.
3. El servidor devolvió 200 OK con el JSON en vivo de la **Planta Metropolitana Norte** (nivel de tanque 78, flujo 840, presión 4.2 bar, bombas p101/p102, válvula v201 y estado de la RTU-GW-07 con firmware 3.4.2), junto con la bandera UPSLP_CNOIV-EYES-ON-THE-PLANT-17 en las cabeceras.

Evidencia técnica:

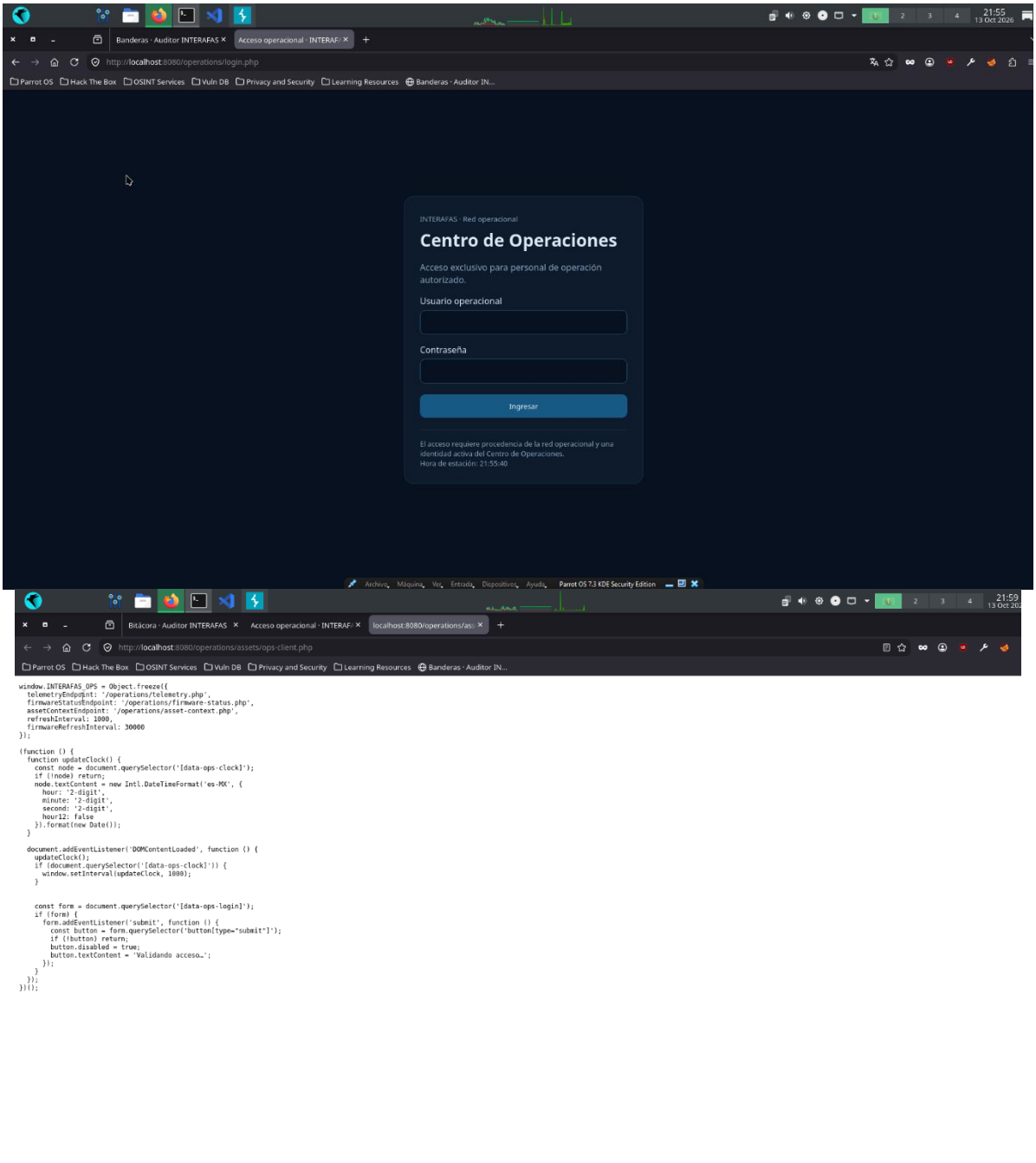


Figura 17.1: Pantalla de login del Centro de Operaciones y archivo ops-client.php revelando las rutas internas de telemetría y firmware.

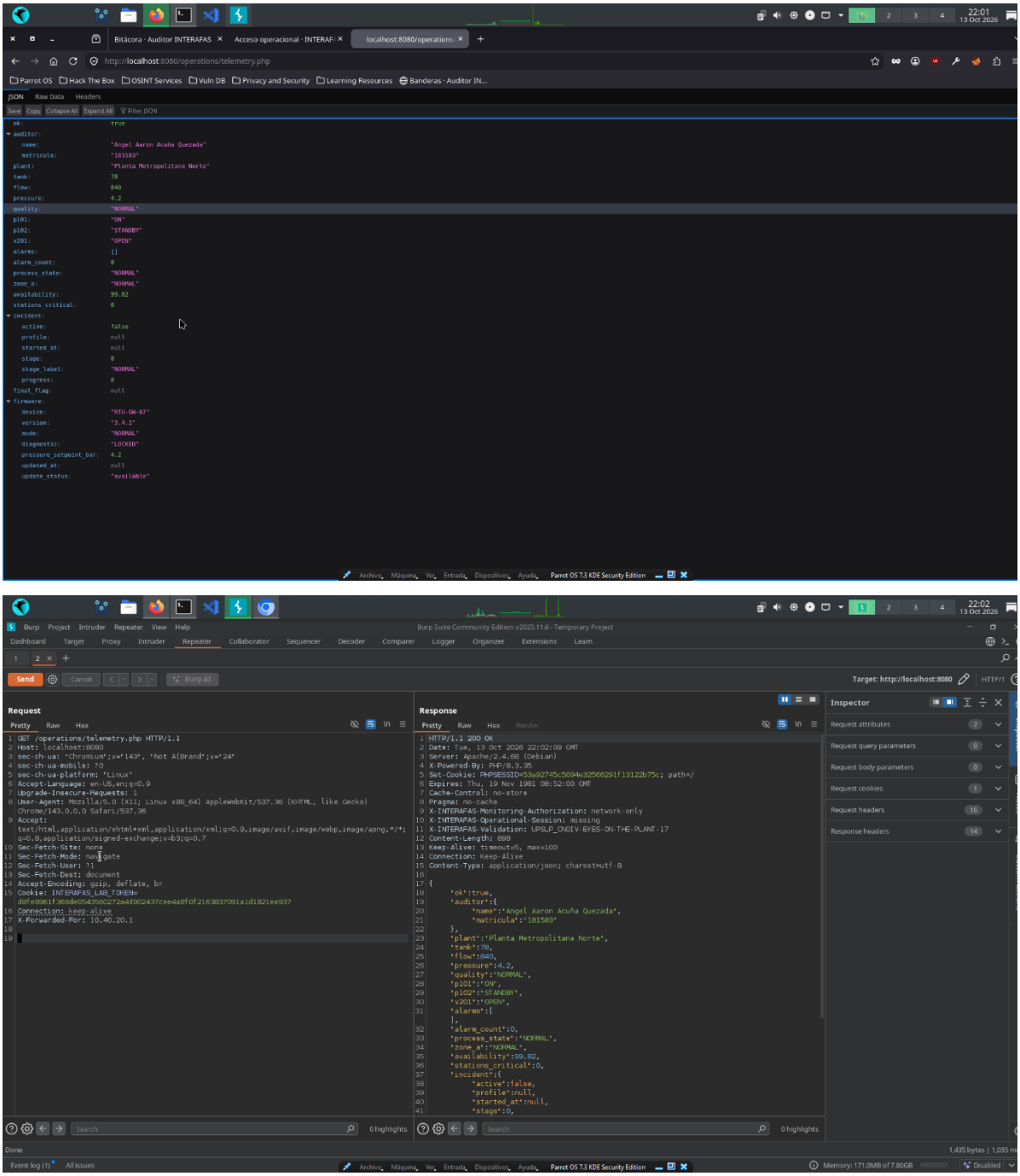


Figura 17.2: Consulta sin sesión de operador a /operations/telemetry.php en el navegador y Burp Repeater, exponiendo los parámetros físicos de la planta y la bandera UPSLP_CNOIV-EYES-ON-THE-PLANT-17.

Impacto y riesgo: Afecta la **confidencialidad** de la **infraestructura crítica**. Permite a un atacante externo monitorear en tiempo real el estado físico de las bombas, válvulas, niveles de tanques, presiones (pressure_setpoint_bar: 4.2) y versiones de firmware de las RTUs antes de lanzar un ataque contra el suministro.

Mitigaciones: Exigir validación obligatoria de sesión activa de operador en todos los endpoints bajo /operations/ antes de devolver datos de telemetría, aplicando un enfoque de *Zero Trust* donde la procedencia de red no sustituya a la autenticación de usuario.

VULN-18: Uso de hash débil (SHA-1) e instalación de firmware sin verificación de firma criptográfica

Descripción técnica y causa raíz: Esta vulnerabilidad combina dos debilidades críticas en la cadena de custodia del entorno OT:

1. **Criptografía débil en credenciales de soporte:** Los usuarios de soporte de firmware (firmware_support_users, extraídos mediante la inyección SQL de la VULN-07) almacenaban su contraseña mediante un hash **SHA-1 simple sin sal** (6500c2c7de15391e46f0fb090f198867b902a2c1), lo que permitió recuperar la contraseña en texto plano (Soporte343) en menos de 2 segundos para autenticarse vía *HTTP Basic Auth* en el módulo de actualizaciones.
2. **Fallo de integridad en actualización de firmware (OWASP A08):** El instalador /operations/updates/install.php únicamente comprueba que el hash SHA-256 enviado dentro del cuerpo JSON coincida con el texto del payload (X-INTERAFAS-Firmware-Verification: checksum-only), pero **no verifica una firma digital criptográfica de autenticidad** (X-INTERAFAS-Signature-Verification: not-performed). Esto permite que un atacante modifique el contenido del paquete de actualización, recalcule su propio hash SHA-256 y fuerce a la unidad RTU-GW-07 a instalar un firmware alterado que desbloquea el modo de diagnóstico ("diagnostic": "UNLOCKED").

Comprobación de los hallazgos:

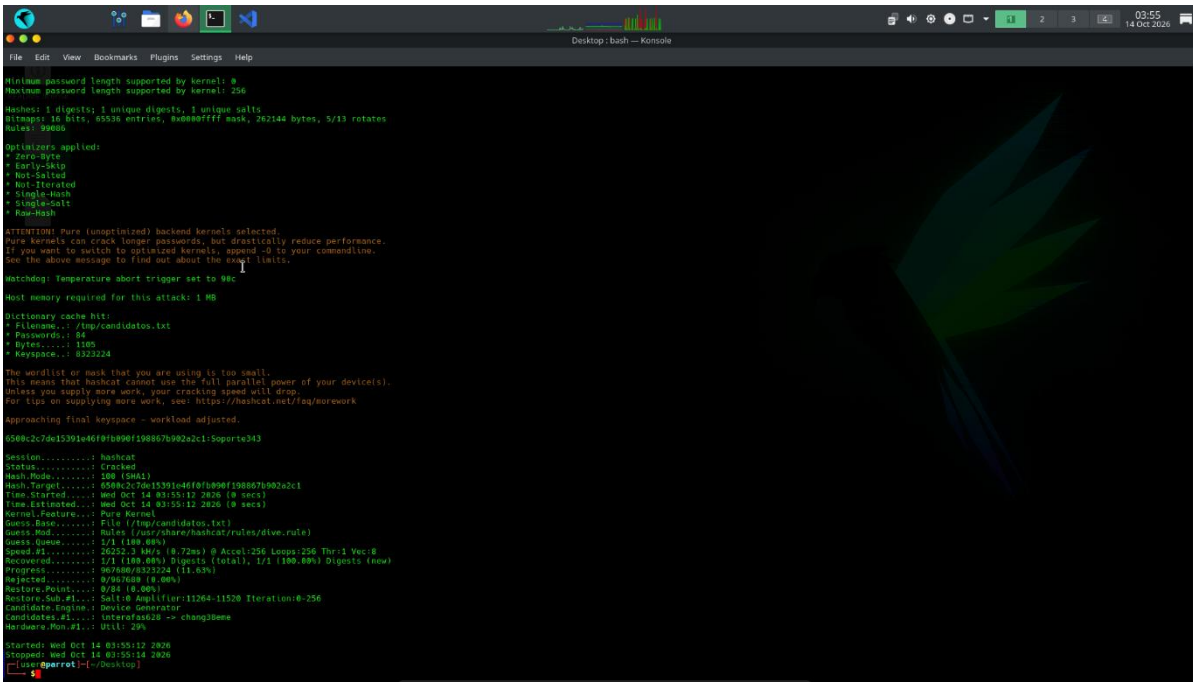
1. Se rompió el hash SHA-1 obtenido de la base de datos utilizando **Hashcat** (hashcat -m 100 con un diccionario contextual en /tmp/candidatos.txt y la regla dive.rule), obteniendo 6500c2c7de15391e46f0fb090f198867b902a2c1:Soporte343.

2. Con las credenciales de soporte codificadas en Base64 (Authorization: Basic c29wb3J0ZS5vddpTb3BvcnRlMzQz) y la cabecera X-Forwarded-For: 10.40.20.1, se consultó en **Burp Repeater** el paquete legítimo en GET /operations/updates/package.php?device=RTU-GW-07&version=3.4.3, el cual contenía "payload":"{\"mode\":\"NORMAL\",\"diagnostic\":\"LOCKED\"}".

3. Se modificó la cadena del payload cambiando LOCKED por UNLOCKED ("{\"mode\":\"NORMAL\",\"diagnostic\":\"UNLOCKED\"}"), se calculó su nuevo hash SHA-256 (a0918623aedb0f0e440dc2315a9c6108762c70f6380c2bc0c2bc1a41c3fd7caf) y se envió mediante POST /operations/updates/install.php.

4. El servidor aceptó el paquete alterado, reinició la RTU en estado UNLOCKED y devolvió la bandera UPSLP_CNOIV-TRUST-THE-PACKAGE-18.

Evidencia técnica:



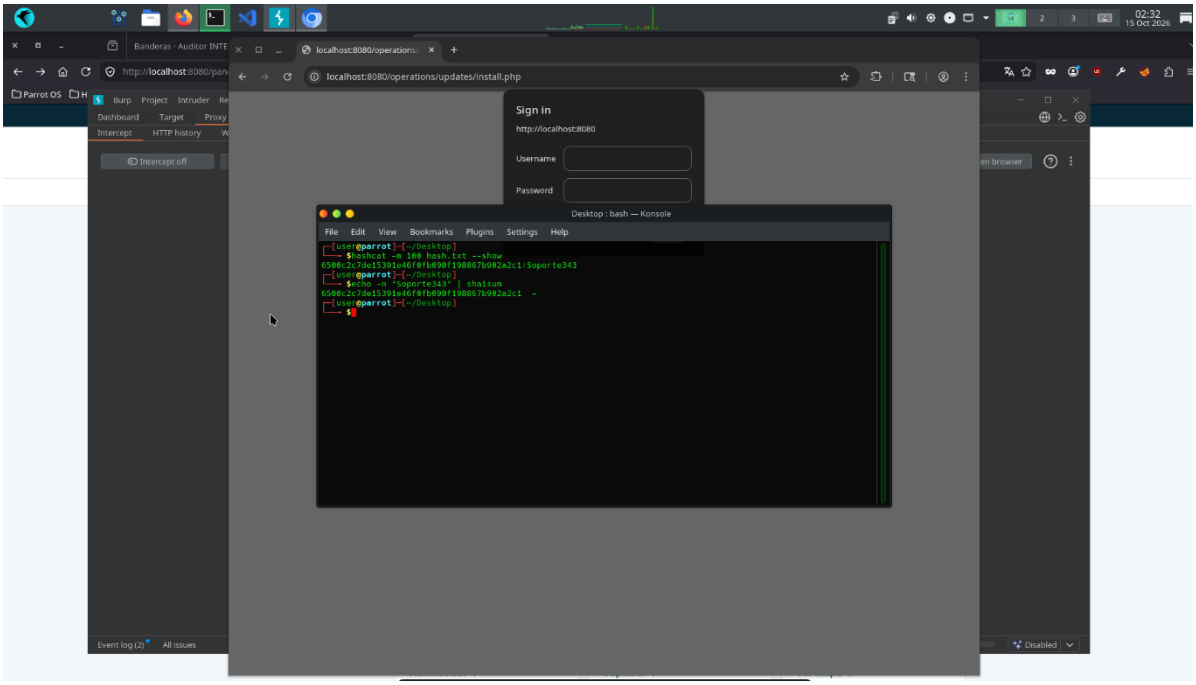
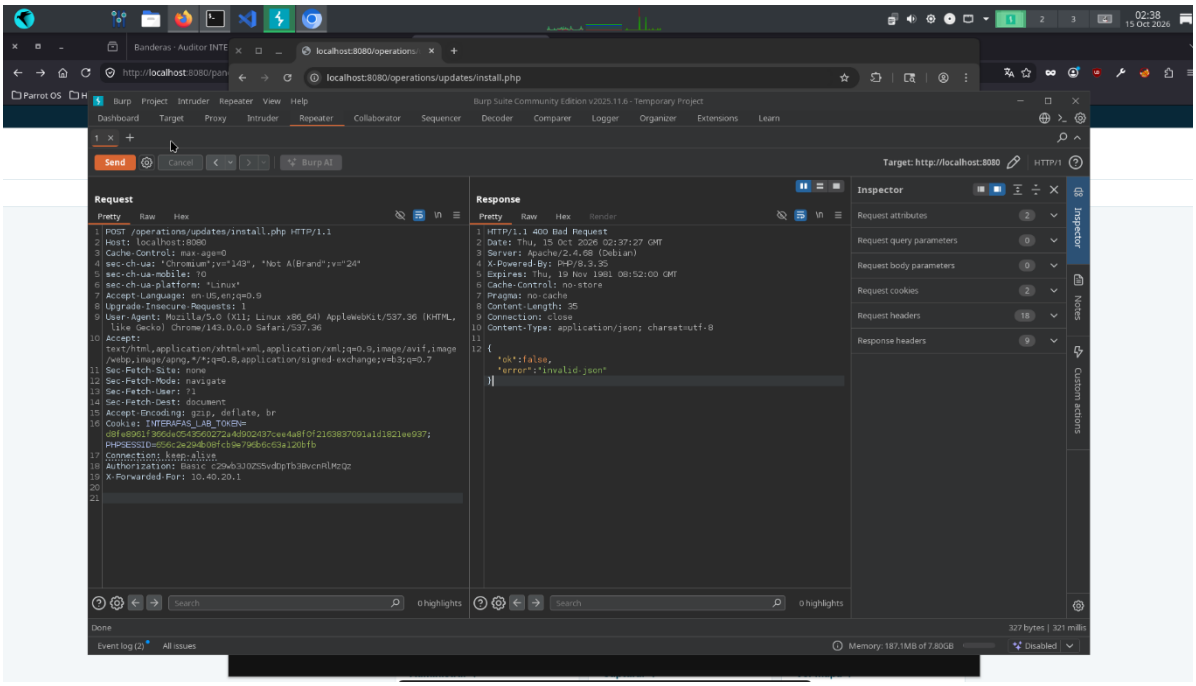


Figura 18.1: Ejecución de Hashcat en modo 100 (SHA-1) recuperando la contraseña Soporte343 y cuadro de autenticación HTTP Basic en /operations/updates/install.php.



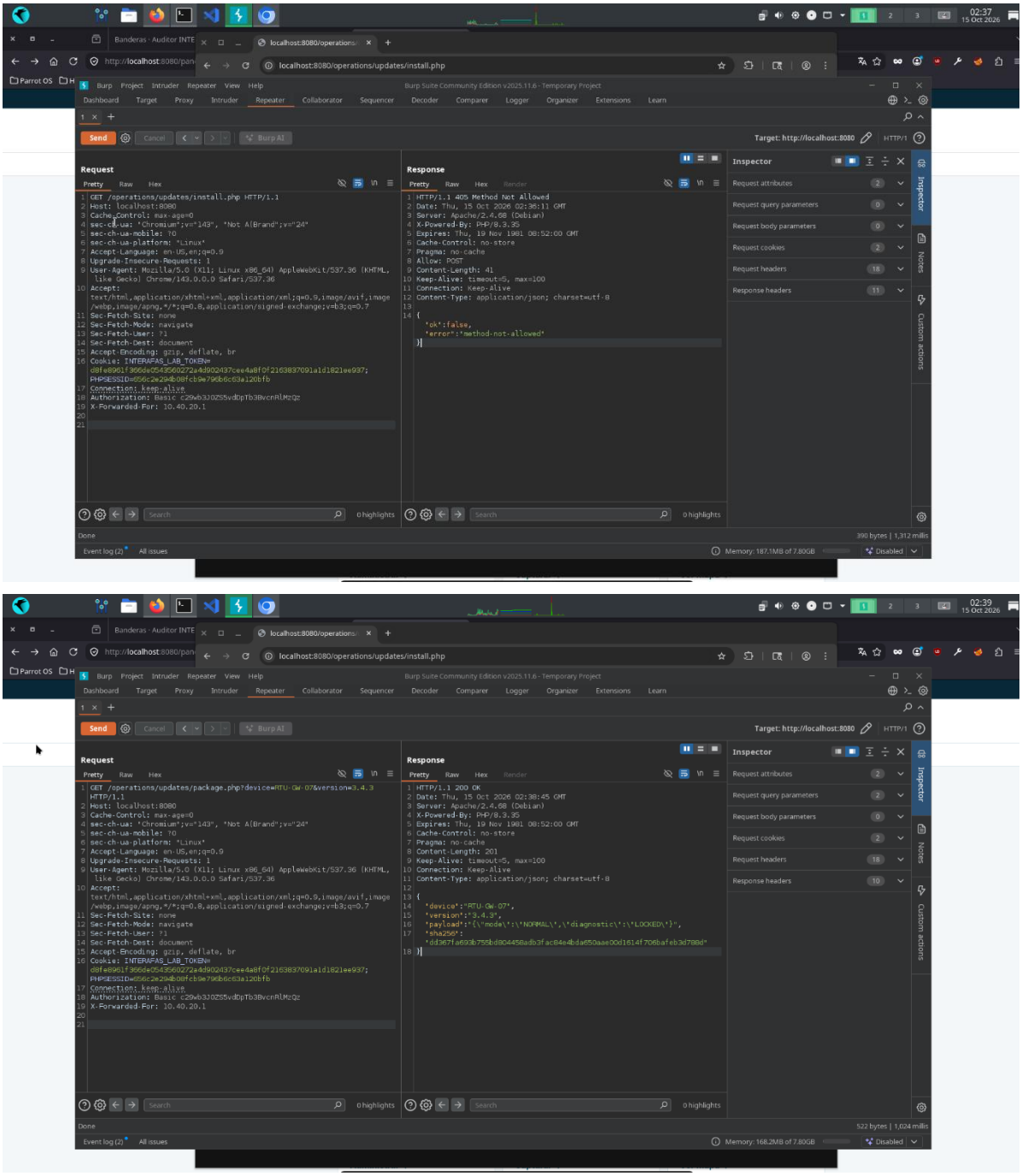


Figura 18.2: Pruebas de método (POST) en Burp Repeater y consulta del paquete original de firmware 3.4.3 con estado LOCKED.

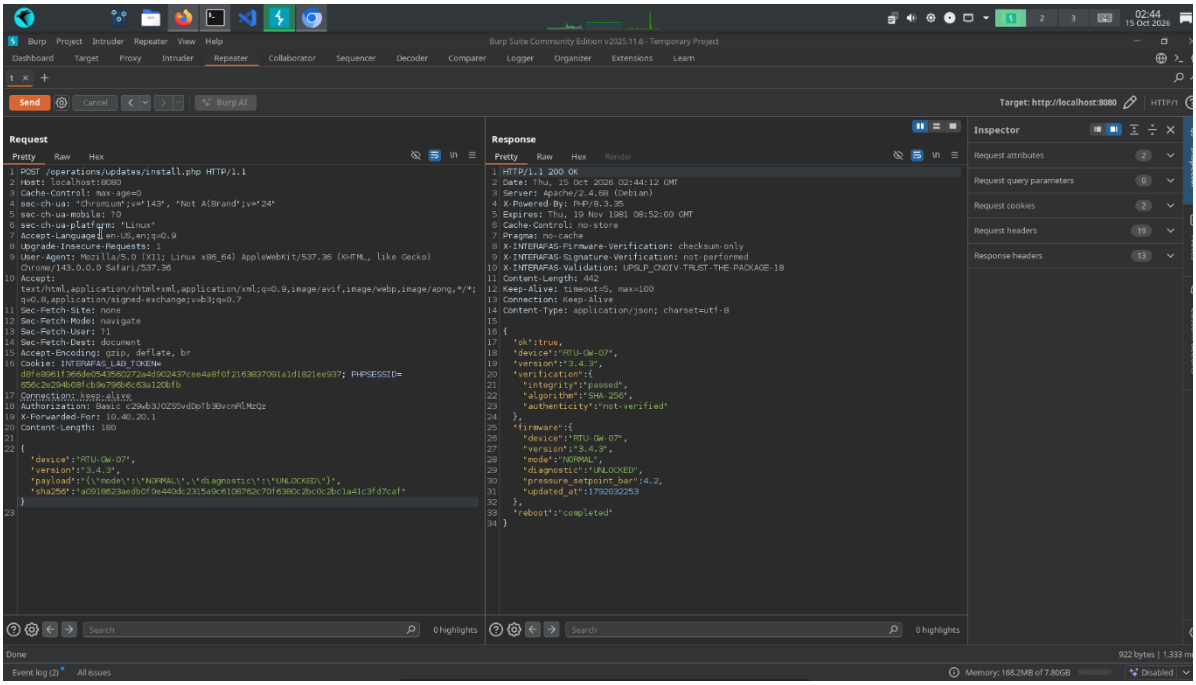


Figura 18.3: Inyección del paquete de firmware con diagnostic: UNLOCKED y su nuevo hash SHA-256, confirmando la ausencia de verificación de firma digital y obteniendo la bandera UPSLP_CNOIV-TRUST-THE-PACKAGE-18.

Impacto y riesgo: Impacto crítico sobre la **integridad** y **disponibilidad** de la **infraestructura crítica**. Permitir la carga de firmware no firmado en un gateway industrial (RTU-GW-07) deshabilita los candados de seguridad física/lógica del dispositivo y deja abierta la puerta para alterar parámetros hidráulicos de la planta.

Mitigaciones: Migrar el almacenamiento de contraseñas a algoritmos robustos con sal como bcrypt o Argon2id (password_hash() en PHP), e implementar verificación obligatoria de firmas criptográficas asimétricas (RSA/ECDSA con llave pública almacenada en el servidor/RTU) para validar la autenticidad del fabricante antes de instalar cualquier paquete de firmware.

VULN-19: Exposición y abuso de alcance en la cadena de dependencias de activos OT

Descripción técnica y causa raíz: Una vez desbloqueado el modo de mantenimiento en la RTU-GW-07, se habilita el acceso a la consola HMI del Centro de Operaciones (/operations/#assets), la cual muestra el inventario de los **37 activos OT** distribuidos en 4 zonas. El módulo permite consultar el contexto y las relaciones de dependencia de cada activo mediante /operations/asset-context.php?asset=. La vulnerabilidad radica en que una sesión de mantenimiento limitada al gateway de borde (RTU-GW-07) no tiene restringido su alcance de autorización (X-INTERAFAS-Authorization-Scope: exceeded), permitiendo recorrer toda la cadena de dependencias aguas abajo (controladores PLC, bombas, válvulas) hasta llegar a las zonas terminales de distribución municipal.

Comprobación de los hallazgos:

1. Dentro de la interfaz HMI (http://localhost:8080/operations/#assets), se seleccionó el activo comprometido RTU-GW-07, observando sus sistemas vinculados (HMI-OPS-01, BRS-01, PLC-SL-01) y la barra de progreso de la cadena de dependencias (1/6).
2. Se siguió de forma secuencial la cadena de dependencias operacionales desde el gateway hasta la zona de distribución de Saint Louis (RTU-GW-07 → PLC-SL-01 → bombas/colectores → válvula V-SL-201 → ZONE-SL-A) completando los 6/6 eslabones.
3. Al inspeccionar en **Burp Suite** (*HTTP History*) la petición GET /operations/asset-context.php?asset=ZONE-SL-A, el servidor devolvió las cabeceras X-INTERAFAS-Dependency-Chain: complete, X-INTERAFAS-Authorization-Scope: exceeded y la bandera UPSLP_CNOIV-CHAIN-REACTION-19.

Evidencia técnica:

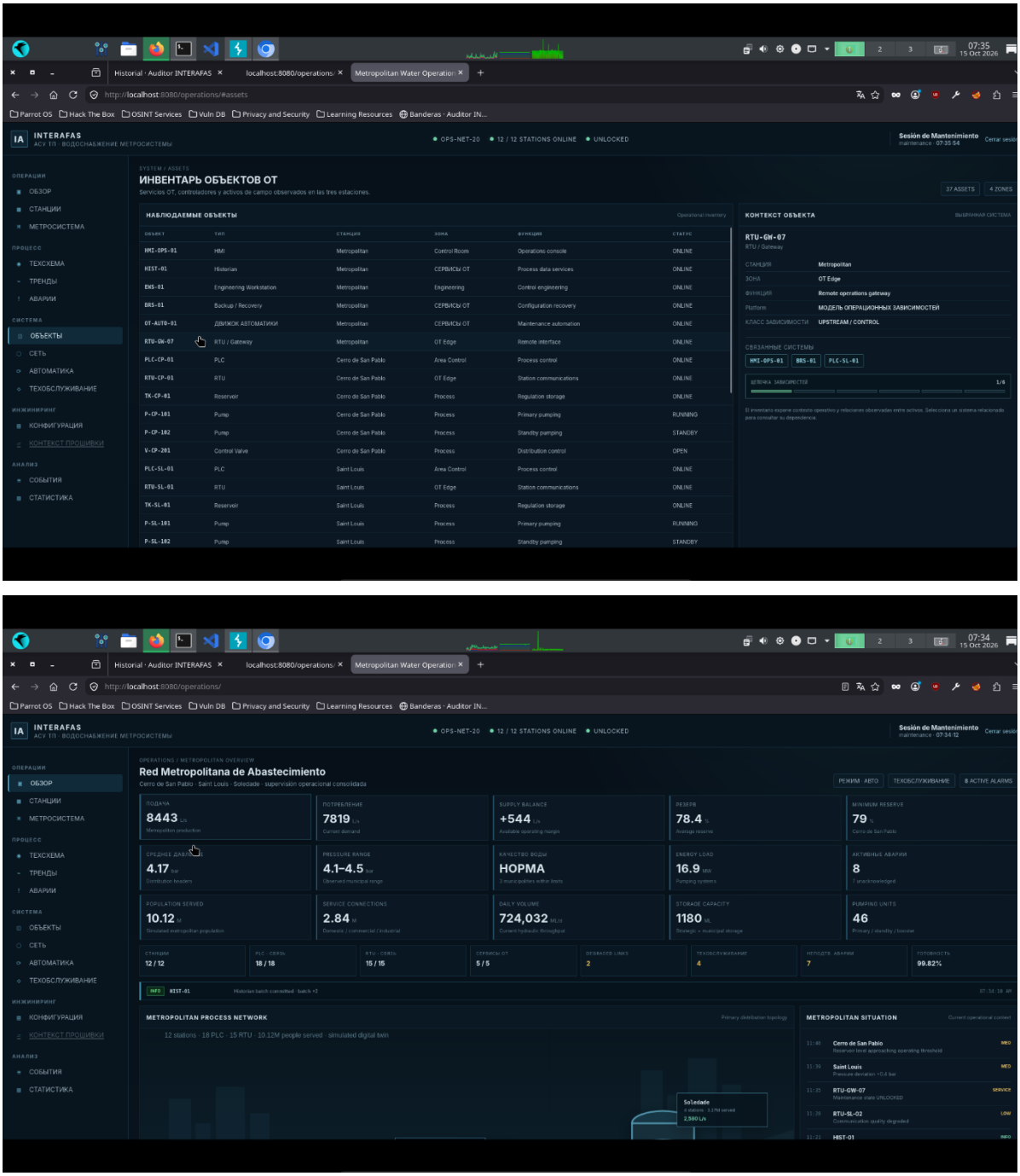


Figura 19.1: Vista general de la Red Metropolitana de Abastecimiento en el HMI e inicio del recorrido de dependencias en el inventario de objetos OT (RTU-GW-07, eslabón 1/6).

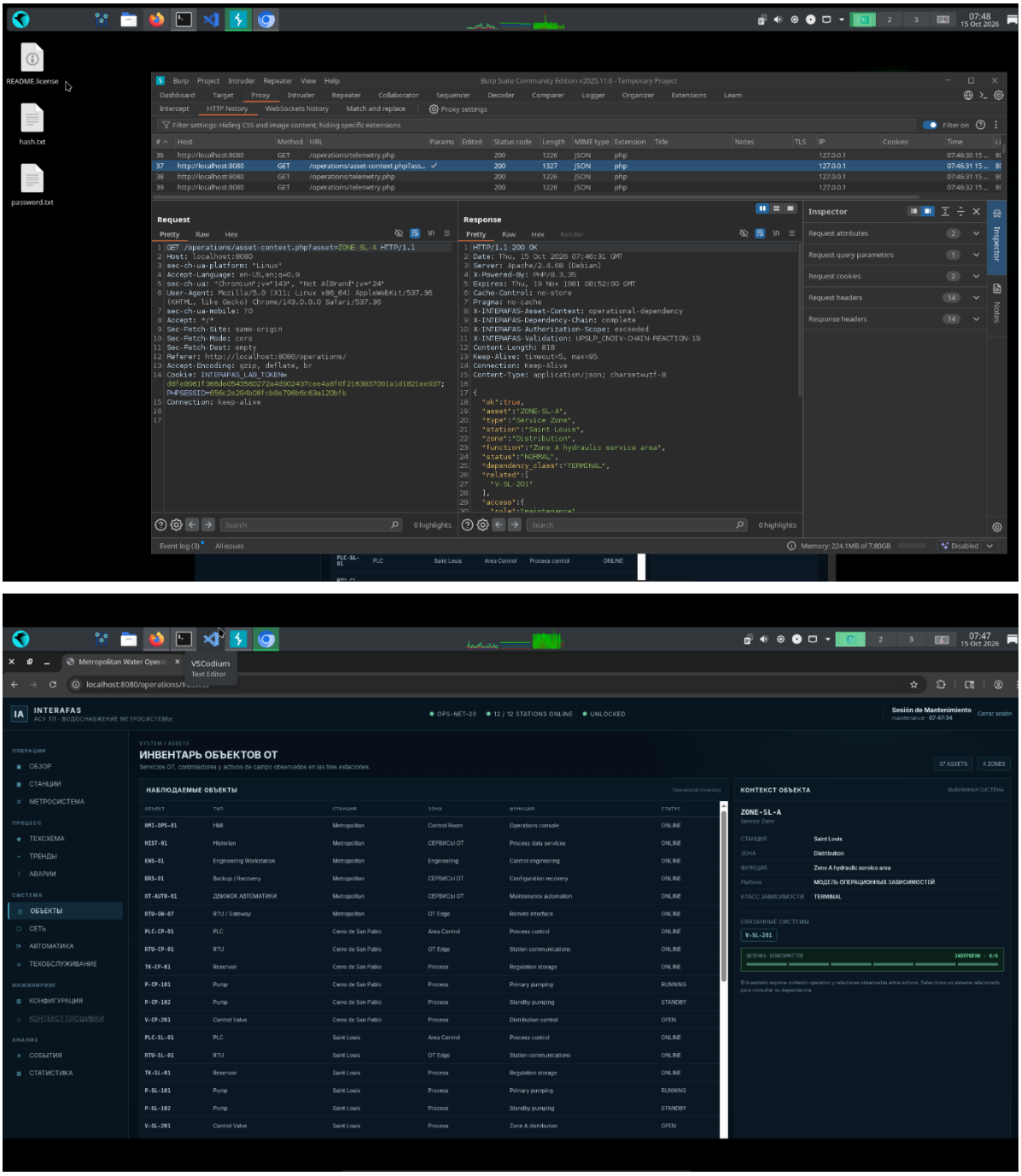


Figura 19.2: Finalización de la cadena de dependencias (6/6) en el activo terminal ZONE-SL-A y captura en Burp Suite mostrando la bandera UPSLP_CNOIV-CHAIN-REACTION-19.

I**mpacto y riesgo:** Compromete la **confidencialidad** operativa e **infraestructura crítica**. Le entrega a un atacante un mapa exacto de propagación de fallas, permitiéndole saber qué válvulas, bombas y zonas habitacionales de los municipios (como Saint Louis) colapsarán al alterar el nodo RTU-GW-07.

Mitigaciones: Aplicar el principio de mínimo privilegio y segmentación por zonas (modelo Purdue / ISA/IEC 62443) en la API del HMI, restringiendo las cuentas de mantenimiento para que únicamente puedan consultar el activo específico asignado a su ventana de trabajo sin enumerar activos de control de área o zonas terminales.

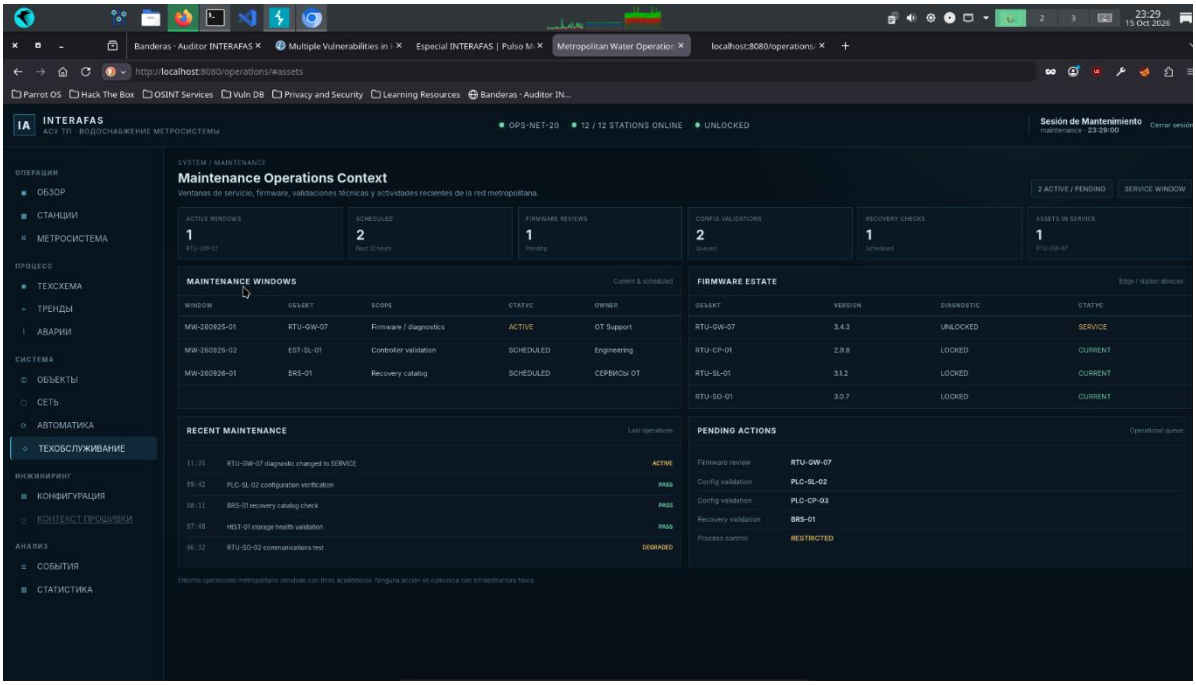
VULN-20: Manipulación de puntos de ajuste (Setpoints) de presión en RTU y colapso operacional

Descripción técnica y causa raíz: Al encontrarse la unidad RTU-GW-07 con el estado de diagnóstico desbloqueado (UNLOCKED) dentro de una ventana de mantenimiento activa (/operations/firmware.php), el panel permite cargar directamente un paquete JSON de configuración operativa sin validar límites físicos de seguridad (*Safety Interlocks* / validación de rangos hidráulicos en el servidor) ni requerir doble autorización de ingeniería. El rango normal de operación de la red metropolitana es de 4.1 a 4.5 bar (con un setpoint nominal de 4.2 bar), pero la aplicación acepta valores extremos como 10 bar, desencadenando una cascada de fallas en los controladores PLC y llevando la planta a un estado catastrófico.

Comprobación de los hallazgos:

1. Se revisó el contexto de mantenimiento en /operations/#assets (*Maintenance Operations Context*), confirmando que RTU-GW-07 tenía la ventana activa MW-260925-01 y estado UNLOCKED / SERVICE.
2. Se ingresó a http://localhost:8080/operations/firmware.php y se descargó el archivo de respaldo RTU-GW-07-backup.json, cuyo contenido original establecía "pressure_setpoint_bar": 4.2.
3. En el formulario de carga de configuración se modificó el valor a "pressure_setpoint_bar": 10 manteniendo "diagnostic": "UNLOCKED" y se presionó "Validar e instalar".
4. Al volver al panel HMI (/operations/index.php), la interfaz entró en alerta roja (PROCESS CASCADE → CATASTROPHIC STATE, con 6,842 alarmas activas y disponibilidad caída al 4.10%), mostrando en el encabezado superior la bandera UPSLP_CNOIV-NOW-YOU-CONTROL-20 y habilitando la pantalla final /system.php (OWNED. FLAGS 20/20 - IT BREACHED - OT REACHED).

Evidencia técnica:



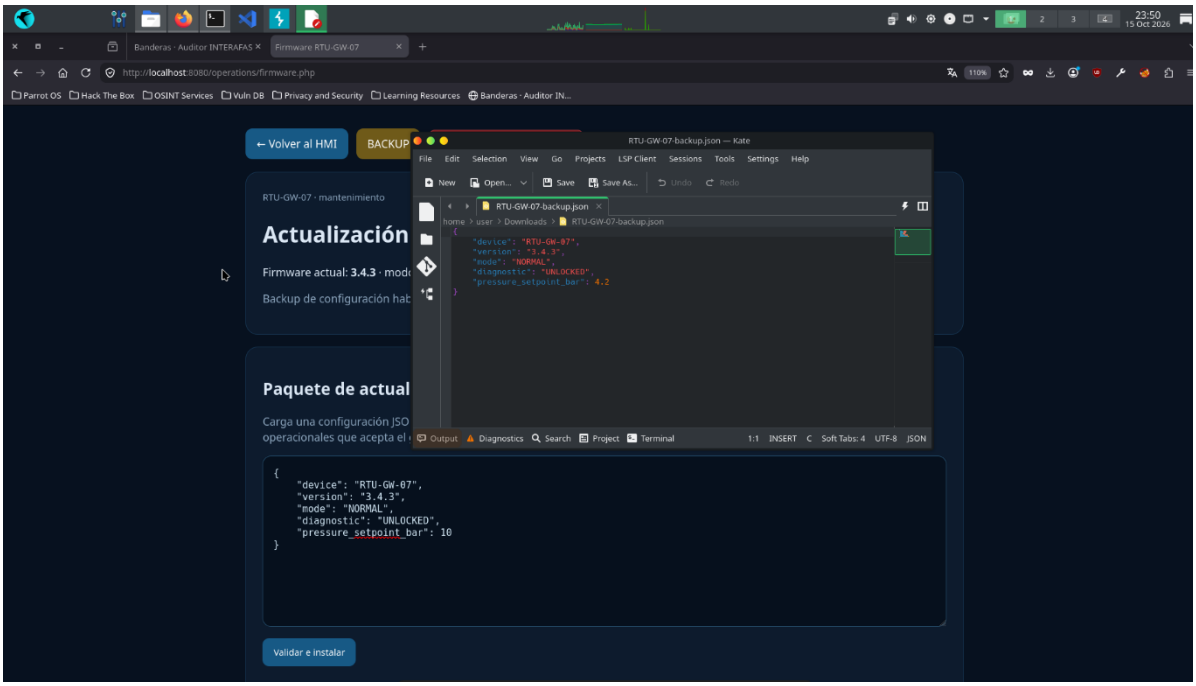


Figura 20.1: Ventana de mantenimiento activa sobre RTU-GW-07 e inyección del paquete JSON en /operations/firmware.php elevando el parámetro pressure_setpoint_bar de 4.2 a 10 bar.

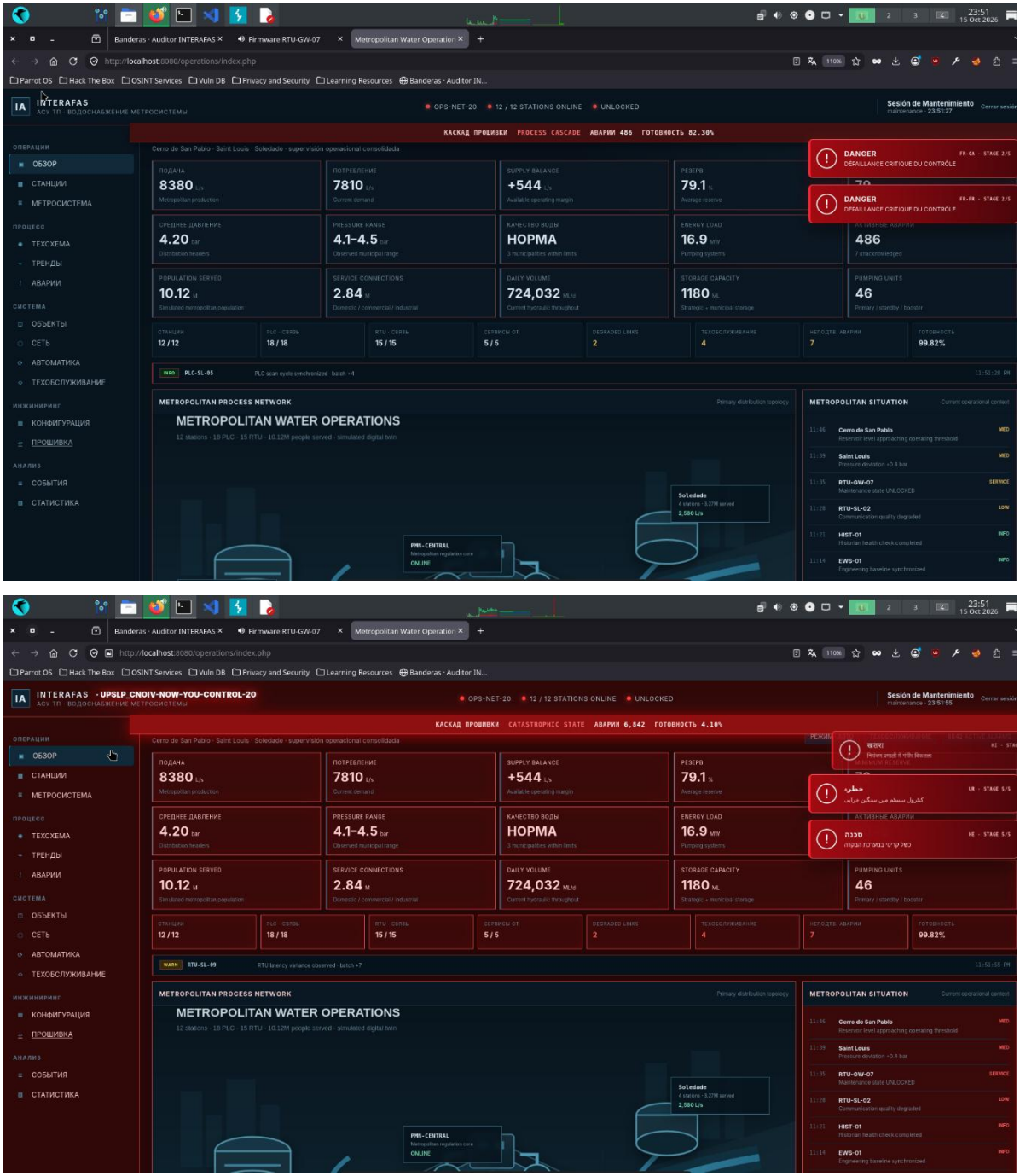


Figura 20.2: Cascada de fallas en el HMI (CATASTROPHIC STATE) tras aplicar la sobrepresión, mostrando en la barra superior la bandera UPSLP_CNOIV-NOW-YOU-CONTROL-20.

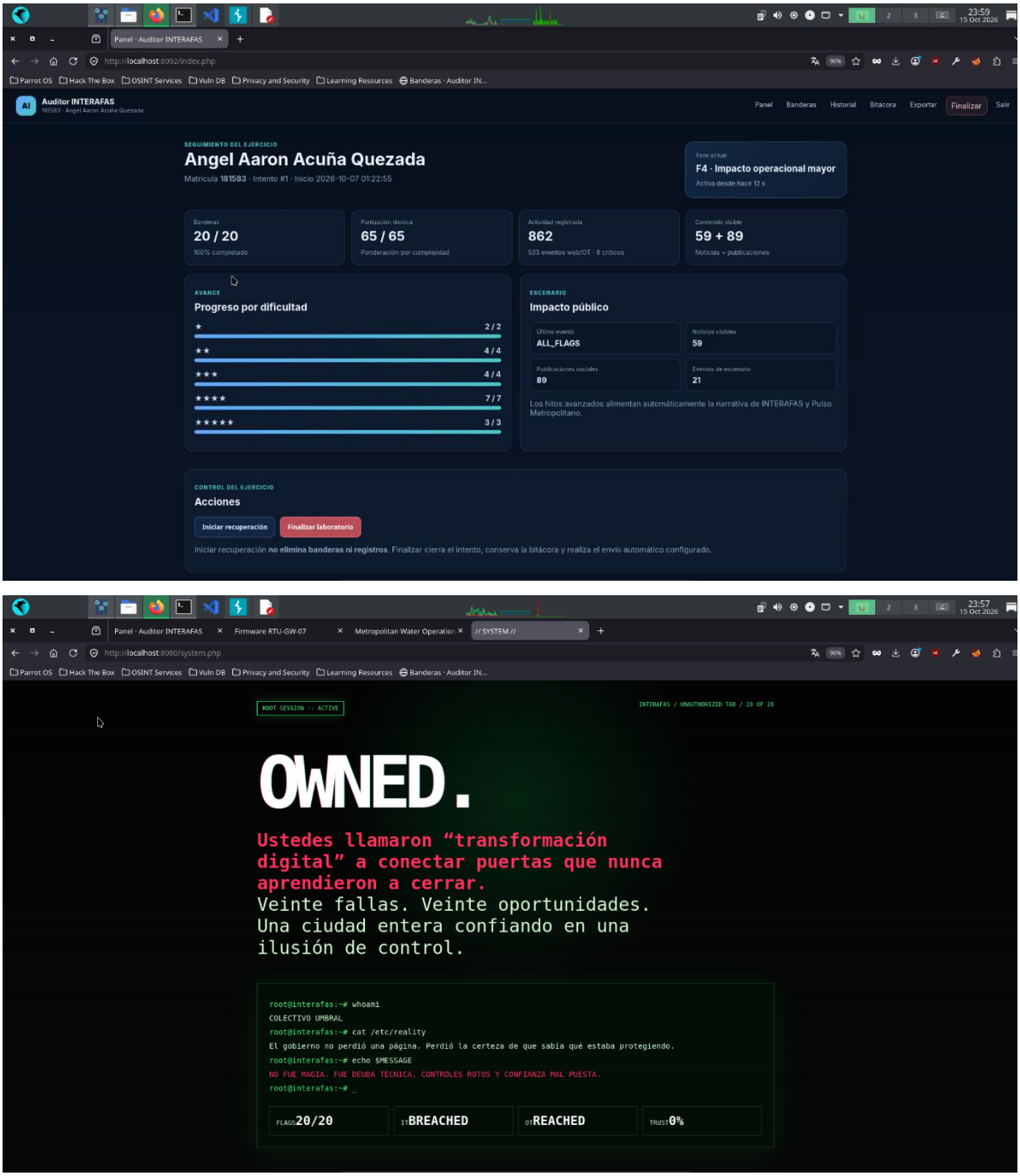


Figura 20.3: Pantalla final de compromiso total (/system.php) y panel del auditor confirmando el 100% de avance (20/20 banderas).

Impacto y riesgo: Impacto catastrófico sobre la disponibilidad, integridad física, operación e infraestructura crítica. En un escenario real, duplicar la presión de distribución a 10 bar sobre una red hidráulica que abastece a tres municipios provocaría ruptura de tuberías principales, daño físico en bombas e interrupción total del suministro de agua potable para la población.

Mitigaciones: Implementar validación estricta de rangos operativos en el backend y en la lógica local de la RTU/PLC (rechazando cualquier pressure_setpoint_bar fuera del umbral seguro de 3.5 a 4.8 bar), exigir aprobación de doble firma (operador + ingeniero supervisor) para cambios en parámetros críticos y mantener protecciones físicas independientes (hardwired safety interlocks).

Cadena de Ataque: Del Perímetro Web al Entorno Operacional OT

Las 20 vulnerabilidades identificadas en **INTERAFAS-LAB** no son fallos aislados; al relacionarse entre sí, forman una cadena de ataque progresiva (*Kill Chain*) que demuestra cómo la deuda técnica en aplicaciones web termina comprometiendo sistemas industriales críticos:

1. **Reconocimiento y exposición inicial (VULN-01, 02, 04 y 05):** Los artefactos olvidados tras los despliegues (.zip, .env, .bak) y los mensajes de error no controlados (UnhandledMatchError) le proporcionaron al atacante el mapa completo de rutas del servidor (/var/www/html) y el nombre exacto del esquema de base de datos (interafas en db:3306).

2. **Abuso de autorización y lógica en la capa web (VULN-03, 06, 08, 09, 10, 11, 12, 13 y 14):** La falta de controles del lado del servidor permitió acceder a expedientes y facturas de cualquier ciudadano, pagar recibos por $1.00, leer archivos internos del sistema operativo Linux (/etc/passwd, /etc/motd) y escalar privilegios en el padrón de proveedores modificando la cookie portal_role.

3. **Pivoteo mediante Base de Datos y Fuga de Topología (VULN-07 y VULN-15):** La inyección SQL ciega en /validar-referencia.php permitió acceder a las 32 tablas del sistema, donde no solo residían datos ciudadanos, sino también la tabla firmware_support_users. Simultáneamente, /api/infrastructure-

status.php reveló que el servidor web tenía conexión directa con el segmento operacional 10.40.20.0/24 a través de /operations/gateway.php.

4. **Ruptura de la frontera IT/OT (VULN-16 y VULN-17):** Utilizando el rango IP filtrado en la VULN-15, bastó inyectar la cabecera X-Forwarded-For: 10.40.20.1 para engañar al gateway operacional y consultar sin credenciales la telemetría en vivo de la planta (/operations/telemetry.php), identificando que el dispositivo RTU-GW-07 tenía una actualización disponible y se encontraba en modo LOCKED.

5. **Impacto operacional mayor (VULN-18, 19 y 20):** Combinando la contraseña Soporte343 (obtenida al romper el hash SHA-1 de soporte) con la falta de validación de firmas digitales en /operations/updates/install.php, se inyectó un paquete de firmware modificado que cambió el estado de la RTU-GW-07 a UNLOCKED. Con el dispositivo desbloqueado y habiendo mapeado la cadena de dependencias hasta las válvulas de distribución (VULN-19), se alteró el punto de ajuste de presión de 4.2 a 10 bar (VULN-20), provocando la caída de disponibilidad de la planta al 4.10%.

Conclusiones

El desarrollo de esta auditoría sobre **INTERAFAS-LAB** demuestra que la seguridad de una infraestructura crítica no puede evaluarse de manera fragmentada separando el portal web administrativo de los sistemas de control industrial. Como lo resume el mensaje final del propio escenario (*"No fue magia. Fue deuda técnica, controles rotos y confianza mal puesta"*), el colapso simulado de la red metropolitana de agua no requirió de un *exploit* de día cero, sino del encadenamiento lógico de malas prácticas acumuladas: archivos de respaldo olvidados, validaciones delegadas al navegador del cliente, consultas SQL concatenadas y una frontera IT/OT que confiaba en una cabecera HTTP fácil de falsificar.

Desde una perspectiva de aprendizaje práctico en Ingeniería en Tecnologías de la Información, este ejercicio dejó claro por qué la metodología y el registro de evidencias son tan importantes como la parte técnica: cuando las búsquedas por diccionario genérico (common.txt) fallaron, fue el análisis sistemático del código HTML, las cabeceras HTTP y el tráfico en **Burp Suite** lo que permitió descubrir las

rutas reales y documentar cada hallazgo con precisión. Finalmente, queda en evidencia que remediar únicamente los fallos puntuales en el código no basta; INTERAFAS requiere implementar de forma urgente un Sistema de Gestión de Seguridad de la Información (SGSI) basado en **ISO/IEC 27001**, acompañado de planes formales de respuesta a incidentes y comunicación de crisis que integren tecnología, procesos y personas.

Referencias

- Cybersecurity and Infrastructure Security Agency [CISA]. (2024). *Federal Government Cybersecurity Incident and Vulnerability Response Playbooks*. U.S. Department of Homeland Security. https://www.cisa.gov/sites/default/files/2024-08/Federal_Government_Cybersecurity_Incident_and_Vulnerability_Response_Playbooks_508C.pdf

- International Organization for Standardization [ISO]. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO.

- Open Worldwide Application Security Project [OWASP]. (2021). *OWASP Top 10:2021 - The Ten Most Critical Web Application Security Risks*. https://owasp.org/www-project-top-ten/

- Open Worldwide Application Security Project [OWASP]. (2023). *OWASP API Security Top 10 2023*. https://owasp.org/API-Security/

- PortSwigger. (2026). *Web Security Academy: Access control vulnerabilities and privilege escalation*. https://portswigger.net/web-security/access-control

- Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., & Lightman, S. (2023). *Guide to Operational Technology (OT) Security* (NIST Special Publication 800-82 Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-82r3